Cahiers de santé publique appliquée à la nutrition

Vol. 3 (2026)
Chapitre 21

ARTICLE DE SYNTHÈSE · REVIEW ARTICLE

BTS DIÉTÉTIQUE ET NUTRITION · ÉPREUVE E5



Cybersécurité et environnement numérique sécurisé

Cybersecurity and a secure digital work environment

REVUE BC3 · DIÉTÉTIQUE, NUTRITION & SANTÉ PUBLIQUE

Cahiers de santé publique appliquée à la nutrition · Vol. 3 (2026) · Chapitre 21

Article de synthèse · Review article

Chapitre 21 – Cybersécurité et environnement numérique sécurisé

Cybersécurité et environnement numérique de travail sécurisé

Cybersecurity and a secure digital work environment

Dossier pédagogique personnel · BTS Diététique et nutrition, bloc BC3 (référentiel du 27 novembre 2024, guide d'accompagnement 2025)

INFORMATIONS

Volume cours

Chapitre 21

Version du 25 octobre 2026

Source : cours complet BC3, contrôlé (référentiel 2024, guide 2025)

MOTS-CLÉS / KEYWORDS

ANSSI; cybermalveillance.gouv.fr; CERT Santé; Mots de passe; Authentification; Sauvegardes; Hameçonnage; Rançongiciel; Incident

RÉSUMÉ STRUCTURÉ

Contexte. Bloc de compétences 3 du BTS Diététique et nutrition (référentiel du 27 novembre 2024, guide d'accompagnement du 29 avril 2025), épreuve E5.

Objectif. citer les référentiels et acteurs de la cybersécurité (ANSSI, cybermalveillance.gouv.fr, CERT Santé, politique de sécurité des systèmes d'information de santé) ; organiser un environnement numérique de travail sécurisé : postes, comptes, mots de passe, authentification, mises à jour, sauvegardes, messagerie ; reconnaître les principales actions malveillantes (hameçonnage, rançongiciel, usurpation, ingénierie sociale) et appliquer les mesures de prévention ; réagir face à un incident et le signaler aux bons interlocuteurs ; sensibiliser une équipe aux bonnes pratiques.

Contenu. 21.2.1 Contrôle de conformité avec le référentiel 2024 et le guide 2025 ; 21.2.2 Contrôle de conformité avec les cours du CNED ; 21.3.1 Les référentiels et les acteurs de la cybersécurité ; 21.3.2 L'environnement numérique de travail sécurisé ; 21.3.3 Les actions malveillantes et leur prévention ; 21.3.4 Réagir face à un incident et le signaler ; 21.3.5 Fil rouge : un environnement de travail sûr pour le projet des Tilleuls ; 21.4.1 Les objets connectés et les applications ; 21.4.2 Le télétravail ; 21.4.3 La sécurité dans les petites structures.

Conclusion. Le cours donne les notions exigibles, les méthodes et les situations professionnelles du chapitre.

ABSTRACT

Cybersecurity and a secure digital work environment. This review belongs to block 3 of the French BTS in dietetics and nutrition (public health interventions, exam E5) and follows the 2024 national curriculum.

POINTS CLÉS

■ Acteurs : ANSSI, cybermalveillance.gouv.fr, CERT Santé (ANS), CNIL ; référentiels du numérique en santé (PGSSI-S, e-CPS).

■ Six gestes : mots de passe longs et uniques, double authentification, mises à jour, sauvegardes, vigilance, usages séparés et écran verrouillé.

■ Sauvegardes 3-2-1 : 3 copies, 2 supports, 1 hors site ou hors ligne ; tester la restauration.

■ Menaces : hameçonnage, rançongiciel, usurpation (fraude au président), faux support, ingénierie sociale.

■ Incident : isoler sans éteindre, alerter, ne pas payer, signaler (CNIL 72 h, CERT Santé, cybermalveillance.gouv.fr), restaurer, porter plainte, tirer les leçons.

Sommaire

21.1 Compétences mobilisées 4

21.2 Croisement référentiel × précisions × indications 4

21.2.1 Contrôle de conformité avec le référentiel 2024 et le guide 2025 4

21.2.2 Contrôle de conformité avec les cours du CNED 4

21.3 Cours 5

21.3.1 Les référentiels et les acteurs de la cybersécurité 5

21.3.2 L'environnement numérique de travail sécurisé 10

21.3.3 Les actions malveillantes et leur prévention 20

21.3.4 Réagir face à un incident et le signaler 26

21.3.5 Fil rouge : un environnement de travail sûr pour le projet des Tilleuls 33

21.4 Approfondissements 33

21.4.1 Les objets connectés et les applications 33

21.4.2 Le télétravail 34

21.4.3 La sécurité dans les petites structures 36

21.5 Pour aller plus loin – niveau Licence 3 39

21.6 Lien avec les compétences : situations professionnelles 40

21.7 L'essentiel à retenir 53

21.8 Entraînement 57

21.8.1 QCM (une ou plusieurs bonnes réponses) 57

21.8.2 Exercices 57

21.8.3 Mises en situation express 58

21.9 Glossaire 58

21.10 Renvois bibliographiques par notion 59

21.12 Bibliographie numérotée 59

Objectifs du chapitre (référentiel)

À la fin de ce chapitre, vous devez être capable de :

- citer les référentiels et acteurs de la cybersécurité (ANSSI, cybermalveillance.gouv.fr, CERT Santé, politique de sécurité des systèmes d'information de santé) ;
- organiser un environnement numérique de travail sécurisé : postes, comptes, mots de passe, authentification, mises à jour, sauvegardes, messagerie ;
- reconnaître les principales actions malveillantes (hameçonnage, rançongiciel, usurpation, ingénierie sociale) et appliquer les mesures de prévention ;
- réagir face à un incident et le signaler aux bons interlocuteurs ;
- sensibiliser une équipe aux bonnes pratiques.

21.1 Compétences mobilisées

Compétence · Ce que le chapitre apporte · Indicateurs du référentiel travaillés

C3.6 — *Ce que le chapitre apporte :* Environnement numérique sécurisé, prévention et réaction aux incidents ; *Indicateurs du référentiel travaillés :* Environnement numérique de travail sécurisé ; règles de sécurité appliquées

C3.5 — *Ce que le chapitre apporte :* Messagerie et outils collaboratifs sûrs ; *Indicateurs du référentiel travaillés :* Communication professionnelle sécurisée

C3.1 — *Ce que le chapitre apporte :* Continuité d'un projet malgré un incident ; *Indicateurs du référentiel travaillés :* Gestion des risques du projet

21.2 Croisement référentiel × précisions × indications

Notion (guide 2025) · Objectifs pour l'apprenant · Limites et attendus

Référentiels de cybersécurité — *Objectifs pour l'apprenant :* Connaître ANSSI, cybermalveillance.gouv.fr, CERT Santé, référentiels du numérique en santé ; *Limites et attendus :* Rôles principaux

Environnement numérique de travail — *Objectifs pour l'apprenant :* Mots de passe, authentification, sauvegardes, messagerie ; *Limites et attendus :* Gestes appliqués au quotidien

Actions malveillantes — *Objectifs pour l'apprenant :* Reconnaître hameçonnage, rançongiciel, usurpation, ingénierie sociale ; *Limites et attendus :* Prévention

Incident — *Objectifs pour l'apprenant :* Réagir et signaler ; *Limites et attendus :* Interlocuteurs et délais

21.2.1 Contrôle de conformité avec le référentiel 2024 et le guide 2025

Le chapitre a été vérifié ligne par ligne par rapport à trois textes :

- le référentiel du BTS Diététique et nutrition (arrêté publié au *Journal officiel* du 17 décembre 2024) : activité 3.6 « Application des règles de cyber sécurité en santé » et compétence C3.6 « Maintenir son environnement numérique de travail sécurisé » ;
- les critères de la compétence C3.5 qui touchent au numérique ;
- le guide d'accompagnement pédagogique de 2025, qui rattache au BC3 les compétences de cybersécurité du référentiel socle du numérique en santé (environ 10 heures sur les deux années).

Chaque critère a été retrouvé dans le cours ; ceux qui manquaient dans la première version ont été ajoutés.

Texte · Critère ou indication · Où dans ce cours

Référentiel, C3.6 — *Critère ou indication :* Référentiels de référence en cybersécurité identifiés ; *Où dans ce cours :* 21.3.1 (acteurs, histoire, PGSSI-S, CaRE, obligations selon la structure)

Référentiel, C3.6 — *Critère ou indication :* Environnement numérique de travail géré et sécurisé ; *Où dans ce cours :* 21.3.2 (gestes d'hygiène, mots de passe, double authentification, mises à jour, comptes, chiffrement, sauvegardes)

Référentiel, C3.6 — *Critère ou indication :* Bonnes pratiques d'utilisation de messagerie et de courriels respectées ; *Où dans ce cours :* 21.3.2 (messagerie et partage de fichiers) ; 21.3.3 (hameçonnage)

Référentiel, C3.6 — *Critère ou indication :* Différents types d'actions malveillantes connues ; *Où dans ce cours :* 21.3.3 (rançongiciel, hameçonnage, fraude au virement, ingénierie sociale, prestataires, menaces non malveillantes)

Référentiel, C3.6 — *Critère ou indication :* Prévention contre les virus et les actes malveillants mise en œuvre ; *Où dans ce cours :* 21.3.2 (antivirus, pare-feu, filtrage, ajouté) ; 21.3.4 (sensibilisation)

Référentiel, C3.6 — *Critère ou indication :* Réaction face aux incidents appropriée ; *Où dans ce cours :* 21.3.4 (main courante, déclarations, continuité, communication, retour d'expérience)

Référentiel, activité 3.6 — *Critère ou indication :* Moyens et ressources ; processus et outils ; **formation professionnelle continue** ; *Où dans ce cours :* 21.3.1 (se former tout au long de sa carrière, ajouté)

Référentiel, C3.5 — *Critère ou indication :* Bonnes pratiques de connexion à des plateformes ; gestion de l'identité numérique ; *Où dans ce cours :* 21.3.2 (se connecter aux plateformes, ajouté) ; 21.3.1 (identité numérique des professionnels) ; e-réputation au chapitre 15

Guide 2025 — *Critère ou indication :* Outils d'accès aux données de l'usager : CPS, e-CPS, Pro Santé Connect ; *Où dans ce cours :* 21.3.1 (prouver qui l'on est)

Guide 2025 — *Critère ou indication :* Utilisation maîtrisée des objets connectés ou applications mobiles ; analyser leur fiabilité ; *Où dans ce cours :* 21.4.1 (objets connectés, recommander une application)

Guide 2025 — *Critère ou indication :* Mettre en œuvre la cybersécurité en santé : sécurité de l'environnement numérique de travail, prévention et gestion des incidents ; *Où dans ce cours :* Ensemble du chapitre ; cas guidés en 21.7

Référentiel, épreuve E5 — *Critère ou indication :* Temps 1 : projet d'intervention présenté et défendu devant le jury ; *Où dans ce cours :* 21.6 et cas guidés : volet cybersécurité d'un projet, réponses au jury

21.2.2 Contrôle de conformité avec les cours du CNED

Le chapitre a été vérifié par rapport aux parties des cours du CNED qui traitent du numérique et de la sécurité des

données. Il s'agit de la séquence 7 « Santé et numérique » du module 1 du fascicule *Environnement professionnel – Les essentiels*, 2e année (CNED 3-6124-AN-WT-00-21, © 2022, p. 25 à 27). On y ajoute le passage sur l'archivage des étiquettes du module 1 *Hygiène en restauration collective*, séquence 4 « Plan de maîtrise sanitaire ». Toutes les notions de ces passages sont reprises. Le chapitre va plus loin sur la cybersécurité, que le fascicule ne fait qu'évoquer. Les données dépassées sont corrigées dans l'encadré « Attention » ci-dessous.

Module CNED · Contenu CNED · Où dans ce cours

Env. pro. M1 S7 §1 – E-santé, m-santé (p. 25) — *Contenu CNED :* Définition de l'e-santé citée d'après Eysenbach (2001) : « services de santé fournis grâce à Internet ou à des technologies numériques » ; m-santé ; télémédecine ; *Où dans ce cours :* Chapitre 20 pour la définition ; 21.4.1 (objets connectés et applications), 21.4.2 (travail à distance) pour leur sécurité

Env. pro. M1 S7 §2 – Stratégie nationale en e-santé (p. 25-26) — *Contenu CNED :* Quatre axes de la stratégie « e-santé 2020 », dont « assurance de la sécurité des systèmes d'information » ; *Où dans ce cours :* 21.3.1 (histoire de la cybersécurité, programme CaRE) ; stratégie mise à jour dans l'encadré ci-dessous

Env. pro. M1 S7 §3 – Le DMP (p. 26) — *Contenu CNED :* « Confidentiel et sécurisé », « Hautement sécurisé » ; accès du professionnel avec une carte CPS, un lecteur et un logiciel « DMP compatible » ; *Où dans ce cours :* 21.3.1 (identité numérique des professionnels : CPS, e-CPS, Pro Santé Connect)

Env. pro. M1 S7 §4 – Protection des données : RGPD (p. 27) — *Contenu CNED :* Données de santé « sensibles » ; données « adéquates, pertinentes et limitées » ; « L'accès aux données de santé des patients doit être limité » ; durée de conservation déterminée ; *Où dans ce cours :* 21.3.2 (moindre privilège, comptes et droits) ; 21.3.1 (violation de données) ; chapitre 20 pour les principes

Env. pro. M1 S7 §5 – Objets connectés (p. 27) — *Contenu CNED :* Définition de la HAS ; capteurs (température, pouls, tension, glycémie) ; enjeu : « garantir la sécurité et la confidentialité des données personnelles et notamment les données de santé » ; *Où dans ce cours :* 21.4.1 (risques et mesures, calcul du capteur de glycémie)

Hygiène M1 S4 §5 – Traçabilité (archivage) — *Contenu CNED :* Les étiquettes des denrées avec les numéros de lots : « ces documents peuvent être conservés en l'état ou scannés pour un archivage informatique » ; conservation 6 mois ; *Où dans ce cours :* 21.3.2 (sauvegardes : un archivage numérique doit être sauvegardé et restaurable) ; cas guidé 20 (étiquettes scannées d'une cuisine centrale)

Attention – corrections apportées aux documents sources – Données du fascicule CNED mises à jour dans ce cours

Sources : ministère chargé de la santé, Agence du numérique en santé, consultés en octobre 2026.

- **Stratégie « e-santé 2020 »** : elle a été remplacée. Le virage numérique de « Ma santé 2022 » a été annoncé en 2019. La **feuille de route du numérique en santé 2023-2027** a été présentée en mai 2023. La cybersécurité y est renforcée par le programme **CaRE**, présenté en décembre 2023 (21.3.1).
- **DMP présenté comme un service à créer** : depuis 2022, le dossier médical partagé est intégré à **Mon espace santé**. Ce service est ouvert pour chaque assuré, sauf s'il s'y oppose (chapitre 20).
- **Accès du professionnel par carte CPS et lecteur** : il existe aussi l'**e-CPS** sur téléphone et la connexion par **Pro Santé Connect** (21.3.1).
- **« Hautement sécurisé »** : aucun service n'est sûr à lui seul. La sécurité dépend aussi des pratiques des utilisateurs : mots de passe, double authentification, poste verrouillé, vigilance face à l'hameçonnage (21.3.2 et 21.3.3).

21.3 Cours

NIVEAU BTS – EXIGIBLE

21.3.1 Les référentiels et les acteurs de la cybersécurité

Module · Référentiel : C3.6, activité 3.6, C3.5 · Guide 2025 · CNED : Essentiels M1 S7 §2 (p. 25-26) ; Essentiels M1 S7 §3 (p. 26) ; Essentiels M1 S7 §4 (p. 27)

Définition – Cybersécurité

Ensemble des mesures techniques, organisationnelles et humaines qui protègent les systèmes d'information et les données contre les atteintes à leur **disponibilité** (pouvoir y accéder), leur **intégrité** (ne pas être modifiées) et leur **confidentialité** (n'être accessibles qu'aux personnes autorisées), et qui permettent d'en garder la **traçabilité**.

Acteur ou référentiel · Rôle

ANSSI (Agence nationale de la sécurité des systèmes d'information) — *Rôle :* Autorité nationale en matière de cybersécurité ; publie des guides, dont le guide d'hygiène informatique, et des recommandations (mots de passe, sauvegardes)

cybermalveillance.gouv.fr — *Rôle :* Dispositif national d'assistance aux victimes (particuliers, entreprises, associations, collectivités), de prévention et d'observation de la menace ; fiches pratiques et diagnostic en ligne

CERT Santé — *Rôle :* Centre d'appui aux structures de santé pour la gestion des incidents de sécurité, opéré par l'Agence du numérique en santé (ANS) ; reçoit les signalements des établissements de santé

Référentiels du numérique en santé — *Rôle :* Politique générale de sécurité des systèmes d'information de santé (PGSSI-S), référentiels d'identification électronique des professionnels (carte de professionnel de santé, e-CPS, Pro Santé Connect), identité nationale de santé

CNIL — *Rôle :* Protection des données ; notification des violations de données (chapitre 20)

Police et gendarmerie — *Rôle :* Plainte ; assistance aux victimes

État de la veille – État de la veille au 26 octobre 2026

- **NIS 2** : la directive (UE) 2022/2555 renforce les obligations de cybersécurité de nombreux secteurs, dont la santé ; sa transposition en droit français (projet de loi relatif à la résilience des infrastructures critiques et au renforcement de la cybersécurité) était en cours d'examen au Parlement : vérifier son adoption et ses décrets.
- **Signalement** : les établissements de santé ont l'obligation de signaler les incidents graves de sécurité de leurs systèmes d'information (portail de signalement des événements sanitaires indésirables, CERT Santé) ; vérifier les modalités en vigueur sur

esante.gouv.fr.

- **Mots de passe** : consulter les recommandations à jour de l'ANSSI et de la CNIL.

Comment la cybersécurité s'est organisée en France

La cybersécurité n'est pas seulement une affaire de techniciens. En quinze ans, l'État et l'Union européenne ont créé des institutions, des guides et des obligations. Connaître ces étapes aide à comprendre qui fait quoi aujourd'hui, et pourquoi les structures de santé sont particulièrement concernées.

Date · Étape · Ce qu'elle apporte

7 juillet 2009 — *Étape :* Création de l'ANSSI (décret n° 2009-834) ; *Ce qu'elle apporte :* Une autorité nationale chargée de la sécurité des systèmes d'information de l'État et des opérateurs importants ; elle publie guides et alertes

2017 — *Étape :* *Guide d'hygiène informatique* de l'ANSSI (nouvelle version) ; *Ce qu'elle apporte :* 42 mesures concrètes, utilisables par toute organisation

2017 — *Étape :* Lancement de *cybermalveillance.gouv.fr* ; *Ce qu'elle apporte :* Un service public d'assistance aux victimes : particuliers, entreprises, associations, collectivités

25 mai 2018 — *Étape :* Application du RGPD ; *Ce qu'elle apporte :* Obligation de sécurité adaptée au risque (article 32) et de notification des violations de données (article 33)

14 décembre 2022 — *Étape :* Directive (UE) 2022/2555 (NIS 2) ; *Ce qu'elle apporte :* Des obligations de cybersécurité pour beaucoup plus de secteurs, dont la santé ; transposition attendue avant le 17 octobre 2024

Décembre 2023 — *Étape :* Programme CaRE du ministère chargé de la santé ; *Ce qu'elle apporte :* Un plan pour renforcer la cybersécurité des établissements de santé et médico-sociaux

17 décembre 2024 — *Étape :* Ouverture de 17Cyber ; *Ce qu'elle apporte :* Une plateforme d'assistance et de mise en relation avec un policier ou un gendarme

Définition – Système d'information

Ensemble organisé des **personnes**, des **procédures**, des **outils** (ordinateurs, logiciels, réseaux, téléphones) et des **données** qui permettent à une structure de recueillir, de conserver, de traiter et de transmettre l'information. Dans une cuisine centrale, le système d'information comprend le logiciel de commande des repas, les postes, la messagerie, mais aussi la liste papier des régimes et les agents qui la consultent.

Attention – La transposition de NIS 2

Une directive doit être **transposée** dans le droit national avant de s'appliquer aux structures. Au 26 octobre 2026, la loi française de transposition de NIS 2 n'était pas définitivement adoptée. Avant de citer ses obligations, vérifiez l'état du texte sur *legifrance.gouv.fr* et sur le site de l'ANSSI.

À vous de jouer – Exercice d'application 21.1

Classez dans l'ordre chronologique : ouverture de 17Cyber ; création de l'ANSSI ; application du RGPD ; adoption de NIS 2 ; lancement de *cybermalveillance.gouv.fr*. Pour chacune, écrivez en une ligne ce qu'elle change pour une diététicienne libérale.

Corrigé

1. **2009, ANSSI** : des guides gratuits et fiables pour sécuriser son poste. 2. **2017, cybermalveillance.gouv.fr** : un service vers lequel se tourner en cas d'attaque, avec des fiches pratiques. 3. **2018, RGPD** : l'obligation de protéger ses dossiers et de notifier une violation. 4. **2022, NIS 2** : peu de changement direct pour une diététicienne libérale (la directive vise surtout des entités d'une certaine taille), mais ses partenaires (hôpitaux, laboratoires) deviennent plus exigeants. 5. **2024, 17Cyber** : un point d'entrée unique pour être aidée et porter plainte.

Les mots de la sécurité : menace, vulnérabilité, risque

Pour parler de sécurité avec un prestataire, une direction ou un jury, il faut employer les bons mots. Ils permettent aussi de raisonner : on ne supprime pas les menaces, mais on peut réduire les vulnérabilités et limiter les conséquences.

Terme · Définition simple · Exemple dans un service de restauration

Bien à protéger — *Définition simple :* Ce qui a de la valeur pour la structure et les personnes ; *Exemple dans un service de restauration :* La liste des régimes et textures des patients

Menace — *Définition simple :* Ce qui peut porter atteinte au bien : un attaquant, une erreur, une panne, un incendie ; *Exemple dans un service de restauration :* Un groupe criminel qui diffuse des rançongiciels

Vulnérabilité — *Définition simple :* Une faiblesse qui permet à la menace d'agir ; *Exemple dans un service de restauration :* Un poste qui ne reçoit plus de mises à jour

Risque — *Définition simple :* La possibilité qu'une menace exploite une vulnérabilité, avec des conséquences ; il se mesure par sa **vraisemblance** et sa **gravité** ; *Exemple dans un service de restauration :* Le logiciel de commande chiffré un vendredi, plus de liste des régimes

Incident — *Définition simple :* Un événement qui a réellement porté atteinte à la sécurité ; *Exemple dans un service de restauration :* Le poste a été chiffré

Violation de données — *Définition simple :* Un incident qui entraîne la destruction, la perte, la modification, la divulgation ou l'accès non autorisé à des données personnelles (RGPD, article 4) ; *Exemple dans un service de restauration :* Les fiches des patients sont illisibles ou copiées

Définition – Les trois objectifs de sécurité (DIC)

- **Disponibilité** : l'information et les outils sont accessibles quand on en a besoin.
- **Intégrité** : l'information est exacte, complète et n'a pas été modifiée sans autorisation.
- **Confidentialité** : seules les personnes autorisées y ont

accès.

On ajoute souvent la **traçabilité** (savoir qui a fait quoi et quand) et l'**authentification** (vérifier l'identité de l'utilisateur).

Exemple – Un même incident, trois atteintes

Un rançongiciel touche le serveur d'un centre de santé. **Disponibilité** : les agendas et les dossiers sont inaccessibles pendant 9 jours. **Intégrité** : les dernières modifications sont perdues, restaurées à partir d'une sauvegarde ancienne. **Confidentialité** : les attaquants ont copié les dossiers avant de les chiffrer et menacent de les publier. Une attaque moderne touche souvent les **trois** objectifs à la fois.

À vous de jouer – Exercice d'application 21.2

Pour chacune des situations suivantes, nommez l'objectif de sécurité atteint : a) une diététicienne envoie un bilan au mauvais médecin ; b) la texture d'un résident passe de « mixée » à « normale » sans que l'on sache pourquoi ; c) la messagerie est en panne toute une matinée ; d) plusieurs agents se connectent avec le même identifiant.

Corrigé

a) **Confidentialité**. b) **Intégrité** (avec un risque direct de fausse route pour le résident). c) **Disponibilité**. d) **Traçabilité** (et authentification) : on ne sait plus qui agit.

Prouver qui l'on est : l'identité numérique des professionnels

Dans la santé, il ne suffit pas de savoir **qui** consulte un dossier : il faut en être **sûr**. Les services numériques de santé utilisent donc des moyens d'identification plus solides qu'un simple mot de passe.

Moyen · Principe · Usage

Carte de professionnel de santé (CPS) — *Principe :* Carte à puce personnelle et code secret ; *Usage :* Signer, accéder aux services en ligne, lire la carte Vitale

e-CPS — *Principe :* Version de la CPS sur le téléphone, dans une application, protégée par un code ; *Usage :* Se connecter aux services de santé sans lecteur de carte

Pro Santé Connect — *Principe :* Service d'identification qui permet d'utiliser la CPS ou l'e-CPS pour se connecter à de nombreux services de santé ; *Usage :* Une seule identification forte pour plusieurs outils

Compte et mot de passe, avec double authentification — *Principe :* Mot de passe et second facteur (code, application) ; *Usage :* Outils internes, messagerie, logiciels sans connexion par CPS

Définition – Identification, authentification, habilitation

- **Identification** : dire qui l'on est (un identifiant, un nom).
- **Authentification** : le **prouver** (mot de passe, carte, code, empreinte).
- **Habilitation** : ce que la personne a le **droit** de faire une fois connectée (consulter, modifier, administrer).

Un bon système d'information vérifie les trois : une personne bien authentifiée ne doit accéder qu'aux dossiers dont elle a besoin.

Astuce – Les diététiciens et la CPS

Les diététiciens sont des professionnels de santé enregistrés au répertoire partagé des professionnels de santé (RPPS) ; ils peuvent obtenir une carte de professionnel de santé ou une e-CPS. Vérifiez les modalités à jour sur le site de l'Agence du numérique en santé (*esante.gouv.fr*, consulté en octobre 2026).

À vous de jouer – Exercice d'application 21.3

Une stagiaire de BTS demande la carte CPS de sa tutrice « pour gagner du temps » le matin. Expliquez en trois phrases pourquoi c'est refusé, et ce que la structure doit prévoir pour la stagiaire.

Corrigé

La CPS **prouve l'identité** de la tutrice : toute action faite avec elle lui est attribuée, y compris une erreur ou un accès injustifié. Prêter sa carte, c'est comme prêter sa signature : c'est interdit et cela détruit la traçabilité. La structure crée pour la stagiaire un **compte personnel**, avec des droits limités à ses missions et une date de fin, et la tutrice valide son travail.

Les référentiels propres à la santé : la PGSSI-S

Le secteur de la santé dispose de son propre corpus de règles de sécurité, élaboré par l'Agence du numérique en santé : la **politique générale de sécurité des systèmes d'information de santé** (PGSSI-S). Il complète les guides généraux de l'ANSSI.

Partie du corpus · Contenu · Pour qui

Principes fondateurs — *Contenu :* Les grandes règles de sécurité pour tous les acteurs de santé ; *Pour qui :* Directions, responsables

Référentiels — *Contenu :* Règles d'identification des patients et des professionnels, d'authentification, d'imputabilité (savoir qui a fait quoi) ; *Pour qui :* Éditeurs de logiciels, établissements

Guides pratiques — *Contenu :* Mémentos de sécurité, guides pour les petites structures, règles de sauvegarde, de gestion des habilitations ; *Pour qui :* Professionnels, petites structures

Attention – Référentiel ou loi ?

Un **référentiel** est un ensemble de règles de bonnes pratiques ; certaines parties deviennent **opposables** (obligatoires) quand un texte le prévoit, par exemple pour les éditeurs de logiciels qui veulent être référencés. Dans une copie, dites « la PGSSI-S recommande » ou « la PGSSI-S rend obligatoire pour… », selon ce que vous avez vérifié,

et datez votre consultation.

À vous de jouer – Exercice d'application 21.4

Associez chaque besoin à la ressource la plus adaptée (ANSSI, PGSSI-S, *cybermalveillance.gouv.fr*, CNIL) : a) un guide général pour sécuriser le parc informatique d'une association ; b) une règle sur l'authentification d'un professionnel dans un logiciel de santé ; c) une aide immédiate après une attaque dans un cabinet libéral ; d) la notification d'une violation de données.

Corrigé

a) **ANSSI** (guide d'hygiène informatique) ou fiches de *cybermalveillance.gouv.fr*. b) **PGSSI-S** (référentiel d'authentification des acteurs de santé). c) **cybermalveillance.gouv.fr** (diagnostic, prestataires de proximité) et 17Cyber. d) **CNIL**, dans les 72 heures si la violation présente un risque.

Le programme CaRE : renforcer les établissements

Après plusieurs attaques par rançongiciel contre des hôpitaux (Dax et Villefranche-sur-Saône en février 2021, centre hospitalier Sud Francilien à Corbeil-Essonnes en août 2022), le ministère chargé de la santé a présenté en décembre 2023 le programme **CaRE** (« Cybersécurité accélération et Résilience des Établissements »). Environ 750 millions d'euros ont été annoncés sur plusieurs années.

Axe · Objectif · Exemple de mesure

Gouvernance et résilience — *Objectif :* Que la direction pilote la sécurité et prépare la continuité ; *Exemple de mesure :* Plan de continuité, exercices de crise

Ressources et mutualisation — *Objectif :* Partager les compétences entre établissements ; *Exemple de mesure :* Experts mutualisés dans les groupements

Sensibilisation — *Objectif :* Former tous les professionnels ; *Exemple de mesure :* Campagnes et exercices d'hameçonnage simulé

Sécurité opérationnelle — *Objectif :* Corriger les failles les plus fréquentes ; *Exemple de mesure :* Sauvegardes, annuaire des comptes, exposition sur Internet

Exemple – Ce que CaRE change pour un service diététique

Le service est invité à participer aux **exercices de crise** de l'établissement (que fait la cuisine si le logiciel tombe ?), à suivre la **sensibilisation** et à vérifier que ses données (régimes, bilans) sont sauvegardées et restaurables. La diététicienne a donc un rôle direct : décrire les informations vitales pour les repas et la procédure papier.

À vous de jouer – Exercice d'application 21.5

Citez les quatre axes du programme CaRE et proposez, pour chacun, une action à laquelle peut participer le service de restauration d'un hôpital.

Corrigé

Gouvernance et résilience : écrire la procédure de mode dégradé des repas. **Ressources et mutualisation** : partager une fiche réflexe avec les autres cuisines du groupement. **Sensibilisation** : participer au quart d'heure sécurité et à l'exercice simulé. **Sécurité opérationnelle** : vérifier avec le service informatique que la liste des régimes est sauvegardée et que les postes de la cuisine sont à jour.

Des obligations qui dépendent de la structure

Toutes les structures où travaille un diététicien doivent protéger les données qu'elles traitent. Mais les obligations précises varient selon leur nature et leur taille.

Structure · Obligations principales · Interlocuteurs

Établissement de santé (hôpital, clinique) — *Obligations principales :* RGPD (sécurité, notification des violations) ; hébergement certifié HDS pour les données confiées à un tiers ; signalement des incidents graves de sécurité des systèmes d'information (voir chapitre 20) ; *Interlocuteurs :* DPO, responsable de la sécurité, CERT Santé, ARS, CNIL

Établissement ou service médico-social (EHPAD, SSIAD) — *Obligations principales :* RGPD ; hébergement HDS ; signalement des incidents graves selon les règles en vigueur ; *Interlocuteurs :* Direction, DPO, prestataire, ARS, CNIL

Cuisine centrale, restauration collective — *Obligations principales :* RGPD dès qu'elle traite des régimes ou des allergies nominatifs ; continuité de la production ; *Interlocuteurs :* Direction, DPO de la collectivité ou de l'entreprise

Association de prévention — *Obligations principales :* RGPD ; sécurité adaptée au risque ; *Interlocuteurs :* Référent bénévole ou salarié, *cybermalveillance.gouv.fr*

Diététicien libéral — *Obligations principales :* RGPD (il est lui-même responsable du traitement) ; hébergement HDS s'il confie ses dossiers à un prestataire ; secret professionnel ; *Interlocuteurs :* Prestataires, CNIL, *cybermalveillance.gouv.fr*

À retenir – Une obligation de moyens adaptés

Le RGPD n'impose pas une liste d'outils : il demande des mesures **appropriées au risque** (article 32), qui tiennent compte de la nature des données, de l'état de l'art et du coût. Une diététicienne libérale n'a pas besoin d'un centre de sécurité, mais elle doit chiffrer son ordinateur, sauvegarder ses dossiers et utiliser des mots de passe solides.

À vous de jouer – Exercice d'application 21.6

En décembre 2020, la CNIL a sanctionné deux médecins libéraux dont les images médicales de patients étaient accessibles librement sur Internet, faute de protection de leur matériel. Expliquez pourquoi un professionnel seul peut être sanctionné, et citez trois mesures qui auraient évité cette situation.

Corrigé

Le professionnel libéral est **responsable du traitement** des données de ses patients : c'est à lui de garantir une sécurité adaptée (article 32 du RGPD), même sans service informatique. Mesures : **paramétrer** correctement le matériel connecté à Internet (pas d'accès ouvert, mot de passe changé) ; **chiffrer** les données ; faire **vérifier** l'installation par un prestataire et suivre les mises à jour. Il aurait aussi dû notifier la violation à la CNIL.

Se former tout au long de sa carrière

Les menaces changent vite : de nouvelles arnaques apparaissent chaque mois, les outils évoluent, les textes aussi. Le référentiel cite la **formation professionnelle continue** parmi les moyens de la cybersécurité. Un diététicien en poste ou installé en libéral doit donc entretenir ses connaissances.

Ressource · Ce qu'elle propose · Pour qui

SecNumacadémie (ANSSI, depuis 2017) — *Ce qu'elle propose :* Un cours en ligne gratuit d'initiation à la cybersécurité, avec attestation ; *Pour qui :* Tout professionnel

cybermalveillance.gouv.fr — *Ce qu'elle propose :* Fiches pratiques, kit de sensibilisation (vidéos, affiches, quiz), alertes sur les arnaques du moment ; *Pour qui :* Professionnels, associations, grand public

CNIL, cours en ligne « L'atelier RGPD » (depuis 2019) — *Ce qu'elle propose :* Les bases de la protection des données ; *Pour qui :* Responsables de petites structures, référents

Agence du numérique en santé — *Ce qu'elle propose :* Guides de la PGSSI-S, informations sur l'e-CPS, alertes du CERT Santé ; *Pour qui :* Professionnels et structures de santé

Formations de la structure et des groupements régionaux (GRADeS) — *Ce qu'elle propose :* Sensibilisation, exercices de crise, programme CaRE ; *Pour qui :* Salariés des établissements

Astuce – Une veille simple

Pour rester à jour sans y passer des heures : s'abonner aux alertes de *cybermalveillance.gouv.fr*, lire une fois par trimestre les nouveautés de la CNIL, et noter dans son tableau de veille (chapitre 19) les changements de textes (par exemple la transposition de NIS 2).

À vous de jouer – Exercice d'application 21.7

Une diététicienne libérale dispose de 4 heures par an pour se former à la cybersécurité. Proposez un programme réaliste et dites comment elle peut le prouver.

Corrigé

2 heures pour suivre les premiers modules de SecNumacadémie, en conservant l'**attestation**. **1 heure** pour lire les fiches de *cybermalveillance.gouv.fr* sur l'hameçonnage, les mots de passe et les sauvegardes, puis appliquer une mesure à son cabinet. **1 heure** pour un test de restauration de ses sauvegardes et une mise à jour de sa procédure d'incident. Elle garde une trace datée (attestation, notes) dans son dossier de formation continue.

Quel texte sanctionne quoi ?

Trois familles de textes protègent les données et les systèmes. Les confondre est une erreur fréquente à l'oral.

Texte · Ce qu'il protège · Exemple de sanction prévue

Code pénal, article 323-1 — *Ce qu'il protège :* Le système d'information contre l'accès ou le maintien frauduleux ; *Exemple de sanction prévue :* Jusqu'à 3 ans d'emprisonnement et 100 000 € d'amende

Code pénal, article 226-13 — *Ce qu'il protège :* Le secret professionnel ; *Exemple de sanction prévue :* Jusqu'à 1 an d'emprisonnement et 15 000 € d'amende

Code de la santé publique, article L1110-4 — *Ce qu'il protège :* Le droit du patient au respect de sa vie privée et au secret des informations qui le concernent ; *Exemple de sanction prévue :* Renvoie aux peines du code pénal

RGPD, article 83 — *Ce qu'il protège :* Les données personnelles ; *Exemple de sanction prévue :* Amende administrative jusqu'à 20 millions d'euros ou 4 % du chiffre d'affaires annuel mondial

Attention – Victime et responsable à la fois

Une structure attaquée est **victime** d'une infraction (article 323-1). Elle peut pourtant être **sanctionnée** par la CNIL si elle n'avait pas pris les mesures de sécurité attendues. Les deux situations ne s'excluent pas.

À vous de jouer – Exercice d'application 21.8

Pour chaque situation, citez le texte concerné : a) un ancien salarié se connecte au logiciel de restauration avec un compte resté actif ; b) une diététicienne raconte au téléphone, devant la salle d'attente, le régime d'un patient en le nommant ; c) un cabinet ne chiffre pas ses sauvegardes, qui sont volées ; d) une personne pirate la messagerie d'un centre de santé.

Corrigé

a) **Article 323-1 du code pénal** (maintien ou accès frauduleux), et le RGPD pour la structure qui n'a pas désactivé le compte. b) **Secret professionnel** : article L1110-4 du code de la santé publique et article 226-13 du code pénal. c) **RGPD** (obligation de sécurité, article 32) : la CNIL peut sanctionner la structure ; le voleur relève du code pénal. d) **Article 323-1** pour le pirate ; la structure devra évaluer la violation de données et, si besoin, la notifier à la CNIL.

À vous de jouer – Exercice d'application 21.9

Associez chaque situation à l'outil le plus adapté (carte CPS, e-CPS, Pro Santé Connect) et justifiez : a) une diététicienne hospitalière ouvre le logiciel de soins sur un poste fixe équipé d'un lecteur de carte ; b) une diététicienne libérale consulte un service en ligne depuis sa tablette, sans lecteur ; c) un éditeur veut permettre aux

professionnels de se connecter à son site avec leur identité professionnelle reconnue, sans créer de nouveau mot de passe.

Corrigé

a) **Carte CPS** : le poste a un lecteur, la carte et son code prouvent l'identité. b) **e-CPS** : la version sur téléphone de la carte, utilisable sans lecteur. c) **Pro Santé Connect** : le service d'identification qui permet de se connecter à un site partenaire avec la CPS ou l'e-CPS. Dans les trois cas, le code reste **personnel** : le prêter revient à donner son identité professionnelle.

À vous de jouer – Exercice d'application 21.10

Une patiente vous montre cinq liens reçus par message. Dites, pour chacun, s'il mène au site officiel ou s'il est suspect, et expliquez comment lire une adresse : a) https://www.ameli.fr/assure ; b) https://ameli.fr-remboursement.info/assure ; c) https://www.monespacesante.fr ; d) https://monespacesante-verification.com ; e) https://www.cybermalveillance.gouv.fr. (Les adresses b et d sont inventées pour l'exercice.)

Corrigé

Officiels : **a**, **c**, **e**. Suspects : **b** et **d**. Pour lire une adresse, on cherche le **nom de domaine** : ce qui se trouve juste avant le premier « / » après « https:// », en lisant les deux derniers éléments séparés par un point. En b, le domaine est « fr-remboursement.info » : le mot « ameli » placé au début ne prouve rien. En d, le domaine est « monespacesante-verification.com », qui n'est pas celui du service. Le cadenas et le « https » montrent seulement que la connexion est chiffrée, pas que le site est honnête.

Point d'étape – Je teste mes acquis – Les acteurs et les mots de la sécurité

Répondez sans regarder le cours, puis corrigez-vous. Comptez 1 point par réponse juste.

1. En quelle année l'ANSSI a-t-elle été créée ?
2. Que signifient les lettres D, I et C ?
3. Quelle est la différence entre une menace et une vulnérabilité ?
4. Qu'est-ce qu'une violation de données au sens du RGPD ?
5. Quelle est la différence entre authentification et habilitation ?
6. Que permet l'e-CPS ?
7. Que signifie l'acronyme PGSSI-S ?
8. Qu'est-ce que le programme CaRE, et quand a-t-il été présenté ?

Corrigé – Point d'étape – Les acteurs et les mots de la sécurité

1. En 2009 (décret du 7 juillet 2009).
2. Disponibilité, intégrité, confidentialité.
3. La menace est ce qui peut nuire (attaquant, panne) ; la vulnérabilité est la faiblesse qu'elle exploite.
4. Un incident qui entraîne la destruction, la perte, la modification, la divulgation ou l'accès non autorisé à des données personnelles.
5. L'authentification prouve l'identité ; l'habilitation fixe ce que la personne a le droit de faire.
6. Se connecter aux services numériques de santé avec son téléphone, comme avec la carte CPS.
7. Politique générale de sécurité des systèmes d'information de santé.
8. Un programme de renforcement de la cybersécurité des établissements de santé et médico-sociaux, présenté en décembre 2023.

21.3.2 L'environnement numérique de travail sécurisé

Module · Référentiel : C3.6, C3.5 · CNED : Essentiels M1 S7 §4 (p. 27) ; Hygiène M1 S4 §5

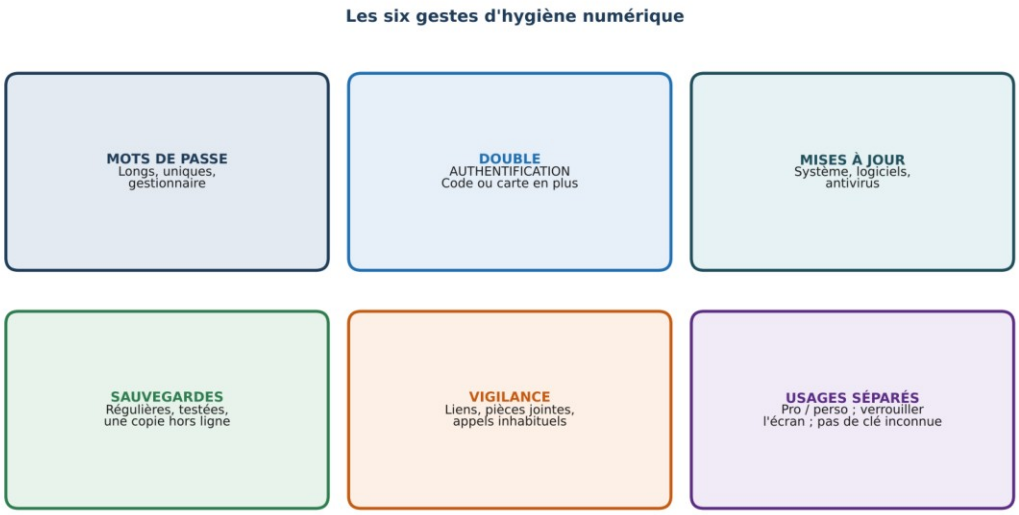


Figure 21.1 – Les six gestes d'hygiène numérique

Comprendre le schéma – Figure 21.1

1. Mots de passe longs (une phrase de passe de plusieurs mots est facile à retenir et difficile à deviner), **uniques** pour chaque compte, conservés dans un **gestionnaire de mots de passe**.

2. Double authentification (ou authentification multifacteur) : un code reçu, une application ou une carte en plus du mot de passe ; dans le secteur de la santé, la carte de professionnel de santé ou l'e-CPS.

3. Mises à jour régulières du système, des logiciels et de l'antivirus : elles corrigent des failles.

4. Sauvegardes régulières, testées, dont une copie hors ligne.

5. Vigilance face aux liens, aux pièces jointes et aux demandes inhabituelles.

6. Séparation des usages personnels et professionnels ; verrouillage de l'écran à chaque absence ; aucune clé USB inconnue.

Élément · Bonnes pratiques

Poste de travail — *Bonnes pratiques :* Session personnelle protégée ; verrouillage automatique ; pas d'installation de logiciels non autorisés ; écran non visible du public

Comptes — *Bonnes pratiques :* Un compte par personne (pas de compte partagé) ; droits limités au nécessaire ; suppression des comptes des stagiaires et des personnes parties

Mots de passe — *Bonnes pratiques :* Jamais notés sur un papier ni partagés ; changés en cas de doute ; gestionnaire de mots de passe

Messagerie — *Bonnes pratiques :* Messagerie professionnelle ; messagerie sécurisée de santé pour les données de santé ; copie cachée pour les envois groupés ; vérification de l'adresse de l'expéditeur

Stockage — *Bonnes pratiques :* Espace partagé de la structure, sauvegardé ; pas de stockage de données professionnelles sur un service grand public personnel ; chiffrement des supports amovibles

Mobilité — *Bonnes pratiques :* Réseaux Wi-Fi publics évités pour les données sensibles ; téléphone professionnel verrouillé ; matériel jamais laissé sans surveillance

Visioconférence — *Bonnes pratiques :* Outil validé, lien réservé aux participants, salle d'attente (chapitre 14)

Les mots de passe : comprendre leur solidité

Un mot de passe protège l'accès à des dossiers de patients, à une messagerie, à un compte bancaire. Sa solidité dépend surtout de sa **longueur** et de son **imprévisibilité**, beaucoup plus que de quelques caractères spéciaux.

Définition – Attaque par force brute et attaque par dictionnaire

- **Force brute** : l'attaquant essaie toutes les combinaisons possibles. Le temps nécessaire dépend du nombre de combinaisons.
- **Dictionnaire** : l'attaquant essaie d'abord des mots courants, des prénoms, des dates, des mots de passe déjà volés et leurs variantes (« Soleil2026! »). Un mot de passe « construit » à partir d'informations connues tombe en quelques secondes, quelle que soit sa longueur apparente.

Le nombre de combinaisons se calcule ainsi : **(nombre de caractères possibles) puissance (longueur)**. Chaque caractère ajouté multiplie ce nombre.

Exemple – Calcul détaillé : un caractère de plus, une phrase de passe

On suppose qu'un attaquant a volé une base de mots de passe protégés et teste 10 puissance 10 (dix milliards) combinaisons par seconde (hypothèse).

- **10 lettres minuscules** : 26 puissance 10 ≈ 1,41 × 10 puissance 14 combinaisons ; temps : 1,41 × 10 puissance 14 / 10 puissance 10 ≈ 14 117 secondes, soit environ **3 h 55 min**.
- **11 lettres minuscules** : 26 puissance 11 ≈ 3,67 × 10 puissance 15 ; temps ≈ 367 034 secondes, soit environ **4,2 jours** : **26 fois plus**, pour un seul caractère.
- **Phrase de passe de 4 mots** tirés au hasard dans une liste de 7 776 mots : 7 776 puissance 4 ≈ 3,66 × 10

puissance 15 ; environ **4,2 jours** aussi.

- **Phrase de passe de 6 mots** : 7 776 puissance 6 ≈ 2,21 × 10 puissance 23 ; environ 2,21 × 10 puissance 13 secondes, soit **700 000 ans**.

Conclusion : allonger est plus efficace que compliquer, et une phrase de passe de plusieurs mots **choisis au hasard** est à la fois solide et facile à retenir.

À retenir – Les repères de la CNIL (2022)

La recommandation de la CNIL relative aux mots de passe (délibération n° 2022-100 du 21 juillet 2022) donne des exemples de mots de passe suffisants **lorsqu'ils sont utilisés seuls** : 12 caractères mêlant majuscules, minuscules, chiffres et caractères spéciaux, ou 14 caractères mêlant majuscules, minuscules et chiffres, ou une phrase de passe d'au moins 7 mots. Les exigences peuvent être plus faibles si le service limite les essais (blocage après plusieurs échecs) ou s'il demande un second facteur.

À vous de jouer – Exercice d'application 21.11

Avec l'hypothèse de 10 puissance 10 essais par seconde, calculez le temps de recherche d'un code de 8 chiffres et d'un mot de passe de 12 lettres minuscules. Lequel conseillez-vous pour une messagerie professionnelle, et pourquoi aucun des deux n'est idéal ?

Corrigé

8 chiffres : 10 puissance 8 combinaisons ; 10 puissance 8 / 10 puissance 10 = **0,01 seconde**. **12 minuscules** : 26 puissance 12 ≈ 9,54 × 10 puissance 16 ; temps ≈ 9,54 × 10 puissance 6 secondes, soit environ **110 jours**. Le second est bien plus solide, mais 110 jours restent accessibles à un attaquant déterminé, et s'il s'agit de mots courants, une attaque par dictionnaire est bien plus rapide. Il vaut mieux une **phrase de passe** d'au moins 7 mots ou un mot de passe aléatoire créé par un gestionnaire, **et** la double authentification.

La double authentification : la protection la plus efficace

La plupart des comptes piratés le sont avec un mot de passe **volé** (hameçonnage, fuite d'un site, réutilisation). La double authentification bloque ces connexions : sans le second facteur, le mot de passe ne suffit plus.

Facteur · Exemples · Point faible
Ce que je sais — *Exemples :* Mot de passe, code personnel ; *Point faible :* Peut être volé ou deviné
Ce que je possède — *Exemples :* Carte CPS, téléphone avec une application, clé de sécurité ; *Point faible :* Peut être perdu ; le SMS peut être détourné
Ce que je suis — *Exemples :* Empreinte digitale, visage ; *Point faible :* Ne peut pas être changé s'il est copié ; souvent utilisé seulement pour déverrouiller un appareil

Attention – Deux mots de passe ne font pas une double authentification

Un mot de passe suivi d'une question secrète (« nom de votre premier animal ») utilise **deux fois le même type de facteur** (ce que je sais). Ce n'est pas une double authentification, et la réponse se trouve souvent sur les réseaux sociaux.

Attention – La fatigue des notifications

Certains attaquants, qui connaissent déjà le mot de passe, envoient des dizaines de demandes de validation sur le téléphone de la victime, en espérant qu'elle finira par accepter. Règle simple : **je ne valide jamais une demande de connexion que je n'ai pas lancée** ; si je reçois des demandes non sollicitées, mon mot de passe est connu : je le change et je préviens le référent.

À vous de jouer – Exercice d'application 21.12

Un soir, une diététicienne reçoit sur son téléphone six demandes successives « Approuvez-vous cette connexion à votre messagerie ? ». Elle n'est pas devant son ordinateur. Que se passe-t-il, et que doit-elle faire ?

Corrigé

Quelqu'un connaît son **mot de passe** et essaie de se connecter ; seule la double authentification l'en empêche. Elle **refuse** toutes les demandes, **change** son mot de passe depuis un appareil sûr (un mot de passe nouveau, jamais utilisé ailleurs), vérifie s'il était réutilisé sur d'autres sites et le change aussi, puis **prévient** le référent ou le service informatique, qui vérifie les connexions récentes.

Le gestionnaire de mots de passe

Une professionnelle utilise souvent plus de vingt comptes : messagerie, logiciel métier, formation, fournisseurs, réseaux sociaux de la structure. Retenir vingt mots de passe longs et différents est impossible ; c'est pourquoi beaucoup réutilisent le même. Le **gestionnaire de mots de passe** résout ce problème.

Définition – Gestionnaire de mots de passe

Logiciel qui **crée**, **conserve** (dans un coffre chiffré) et **remplit** les mots de passe. L'utilisateur ne retient qu'un **mot de passe maître**, très solide, protégé par une double authentification. Les gestionnaires professionnels permettent de partager un accès avec un collègue sans révéler le mot de passe, et de retirer cet accès à son départ.

Avantage · Précaution

Un mot de passe long et différent pour chaque service — *Précaution :* Mot de passe maître très solide (phrase de passe), jamais noté ni partagé

Remplissage seulement sur le vrai site : il ne propose rien sur une fausse page — *Précaution :* Double authentification sur le coffre

Alerte si un mot de passe est faible, réutilisé ou divulgué — *Précaution :* Procédure de récupération prévue (oubli, départ)

Partage contrôlé des comptes communs de la structure — *Précaution :* Choix d'un outil reconnu, mis à jour

Exemple – Calcul détaillé : le coût pour une équipe

Une équipe de 14 personnes choisit un gestionnaire professionnel à 3 € par utilisateur et par mois (prix fictif) : 3 × 14 × 12 = **504 € par an**, soit 504 / 14 = **36 € par personne et par an**. À comparer au coût d'une seule messagerie piratée : temps de l'informaticien, messages piégés envoyés aux partenaires, éventuelle notification à la CNIL.

À vous de jouer – Exercice d'application 21.13

Une collègue dit : « Mettre tous mes mots de passe dans un seul coffre, c'est mettre tous mes œufs dans le même panier ! » Répondez-lui en trois arguments.

Corrigé

1. Aujourd'hui, ses œufs sont **déjà** dans le même panier : si elle réutilise un mot de passe, une seule fuite ouvre tous ses comptes. 2. Le coffre est **chiffré** et protégé par un mot de passe maître solide **et** une double authentification : il est bien plus difficile à forcer qu'un mot de passe réutilisé. 3. Le gestionnaire ne remplit pas les identifiants sur une **fausse page**, ce qui protège aussi de l'hameçonnage.

Les mises à jour et la fin de vie des logiciels

Les logiciels contiennent des **failles** : des erreurs de conception que les attaquants peuvent exploiter. Les éditeurs publient des **mises à jour de sécurité** pour les corriger. Dès qu'une faille est rendue publique, des programmes automatiques cherchent sur Internet les appareils qui ne sont pas encore corrigés.

Définition – Fin de support

Date à partir de laquelle l'éditeur ne publie plus de mises à jour de sécurité pour un logiciel ou un système d'exploitation. Après cette date, chaque nouvelle faille découverte reste **ouverte pour toujours** sur les appareils concernés.

Appareil souvent oublié · Pourquoi il est vulnérable · Mesure

Poste relié à un appareil de mesure (sondes de température, balance de cuisine connectée) — *Pourquoi il est vulnérable :* Logiciel du fabricant qui n'est plus mis à jour ; *Mesure :* Isoler le poste du réseau, n'en faire aucun autre usage

Box Internet, imprimante, borne Wi-Fi — *Pourquoi il est vulnérable :* Mot de passe d'administration par défaut, jamais mis à jour ; *Mesure :* Changer le mot de passe, activer les mises à jour

Téléphone professionnel ancien — *Pourquoi il est vulnérable :* Plus de mises à jour du système ; *Mesure :* Le remplacer ou le limiter aux appels

Extension du navigateur, lecteur de documents — *Pourquoi il est vulnérable :* Mises à jour manuelles oubliées ; *Mesure :* Mises à jour automatiques

Méthode pas à pas – Organiser les mises à jour dans un service

1. Inventaire : la liste des postes et appareils, avec leur système et la date de fin de support.

2. Automatisation : mises à jour automatiques partout où c'est possible.

3. Créneau fixe : un redémarrage programmé (par exemple chaque mardi en fin de journée) pour ne pas gêner le travail.

4. Contrôle : chaque mois, le prestataire ou le référent vérifie les postes en retard.

5. Anticipation : le remplacement des appareils en fin de support est prévu au budget.

À vous de jouer – Exercice d'application 21.14

Le chef de cuisine refuse les mises à jour du poste de production : « La dernière fois, l'imprimante d'étiquettes n'a plus fonctionné. » Proposez une solution qui tient compte de son problème sans laisser le poste vulnérable.

Corrigé

On prend son problème au sérieux : le prestataire **teste** d'abord la mise à jour sur un autre poste avec la même imprimante, puis l'installe à un **moment calme** (après le service), en vérifiant les étiquettes avant de repartir. On demande au fournisseur de l'imprimante un pilote à jour. Pendant ce temps, le poste reste réservé à la production, sans messagerie ni navigation. Refuser toutes les mises à jour n'est pas une option : la faille non corrigée est une porte ouverte.

Les comptes et les droits : le moindre privilège

Chaque compte ouvert est une porte. Plus il y a de comptes inutiles et de droits trop larges, plus un attaquant (ou une erreur) peut faire de dégâts.

Définition – Principe du moindre privilège

Chaque personne n'a accès qu'aux informations et aux fonctions **nécessaires à son travail**, et seulement **pendant la durée** de sa mission. Un cuisinier consulte les régimes et textures, mais pas le dossier nutritionnel ; un stagiaire a un compte personnel limité et désactivé à la fin du stage.

Moment · Ce qu'il faut faire
Arrivée d'une personne — *Ce qu'il faut faire :* Créer un compte **nominatif**, avec les droits de son poste, après validation du responsable
Changement de poste — *Ce qu'il faut faire :* Retirer les droits devenus inutiles, puis donner les nouveaux
Départ (salarié, stagiaire, intérimaire) — *Ce qu'il faut faire :* **Désactiver** les comptes le dernier jour ; récupérer badges, clés, matériel ; changer les mots de passe partagés qu'il connaissait
Chaque année — *Ce qu'il faut faire :* Revue des comptes et des droits avec chaque responsable de service

Attention – Le compte administrateur

Un compte **administrateur** peut tout installer et tout modifier sur un poste. S'il sert au travail quotidien (lire ses messages, naviguer), un simple clic sur une pièce jointe piégée donne tous les droits au programme malveillant. On utilise un compte **utilisateur** au quotidien et un compte administrateur seulement pour les interventions techniques.

Exemple – Calcul détaillé : la revue annuelle des comptes

Lors de la revue annuelle, un service de soins à domicile (fictif) compte **64 comptes actifs** dans son logiciel ; **11** appartiennent à des personnes parties (anciens salariés, stagiaires, remplaçants). Part de comptes à désactiver : 11 / 64 × 100 ≈ **17,2 %**, soit plus d'un compte sur six ouvert sans raison. Chacun pouvait servir à un accès injustifié, impossible à repérer.

À vous de jouer – Exercice d'application 21.15

Rédigez la liste de contrôle « départ d'un stagiaire » d'un service diététique (au moins cinq points).

Corrigé

1. **Désactiver** le compte du logiciel de soins ou de restauration le dernier jour. 2. Désactiver le compte de messagerie (ou le transférer au tuteur). 3. **Récupérer** les fichiers de travail utiles et les ranger dans l'espace du service ; vérifier qu'aucune copie ne reste sur une clé ou un ordinateur personnel. 4. Récupérer le badge et les clés. 5. **Changer** les codes connus du stagiaire (code de porte, mots de passe partagés s'il en existe encore). 6. Noter la date dans le registre des accès.

La messagerie et le partage de fichiers

La messagerie est la première porte d'entrée des attaques et la première cause d'erreurs d'envoi. Elle mérite des règles simples.

Règle · Pourquoi
Une messagerie professionnelle, jamais une adresse personnelle pour le travail — *Pourquoi :* Contrôle de la structure, sauvegarde, sécurité
La messagerie sécurisée de santé pour les données de santé entre professionnels (voir chapitre 20) — *Pourquoi :* Expéditeurs et destinataires identifiés, échanges chiffrés
Vérifier le destinataire avant d'envoyer, surtout avec la complétion automatique — *Pourquoi :* Une erreur d'envoi est une violation de données
Copie cachée pour un envoi groupé à des patients ou des usagers — *Pourquoi :* La liste des destinataires révèle souvent une information de santé (« groupe diabète »)
Un lien de partage protégé (personnes nommées, date d'expiration), jamais « toute personne disposant du lien » — *Pourquoi :* Un lien public circule sans contrôle
Pas de transfert automatique vers une adresse personnelle — *Pourquoi :* Les messages professionnels sortent de la structure

Exemple – L'erreur de la copie visible

Une diététicienne envoie l'invitation d'un atelier « Vivre avec son diabète » à 38 patients, adresses visibles dans le champ « À ». Chaque destinataire apprend que les 37 autres sont diabétiques : c'est une **divulgation de données de santé**. Il fallait la **copie cachée**, ou mieux un outil d'envoi groupé. La structure inscrit l'incident au registre et l'analyse avec le DPO ; une notification à la CNIL peut être nécessaire.

À vous de jouer – Exercice d'application 21.16

Une association partage avec ses bénévoles un tableur des familles accompagnées (nom, adresse, allergies des enfants) par un lien « toute personne disposant du lien peut modifier ». Citez trois risques et trois mesures.

Corrigé

Risques : le lien est transféré à des personnes extérieures et le fichier devient accessible à n'importe qui (**confidentialité**) ; une personne modifie ou efface une allergie (**intégrité**, danger pour un enfant) ; on ne sait pas qui a fait quoi (**traçabilité**). **Mesures** : partage **nominatif** avec les seuls bénévoles concernés, droits en lecture pour la plupart ; colonnes réduites au nécessaire (minimisation) ; historique des modifications activé et lien public supprimé ; hébergement adapté si des données de santé sont conservées.

À vous de jouer – Exercice d'application 21.17

Une diététicienne doit envoyer un bilan par courriel à un médecin qui n'a pas de messagerie sécurisée de santé. Elle place le fichier dans une archive chiffrée. Avec l'hypothèse de 10 puissance 10 essais par seconde, calculez le temps maximal pour trouver le mot de passe : a) 8 lettres minuscules ; b) 10 caractères parmi minuscules et chiffres ; c) 12 caractères parmi minuscules, majuscules et chiffres. Puis dites comment transmettre ce mot de passe.

Corrigé

a) 26 puissance 8 ≈ 2,1 × 10 puissance 11 combinaisons ; 2,1 × 10 puissance 11 / 10 puissance 10 ≈ **21 secondes**. b) 36 puissance 10 ≈ 3,7 × 10 puissance 15 ; soit environ 365 600 secondes, **4,2 jours**. c) 62 puissance 12 ≈ 3,2 × 10 puissance 21 ; soit environ 3,2 × 10 puissance 11 secondes, plus de **10 000 ans**. Seul le cas c) protège vraiment le fichier. Le mot de passe se transmet par **un autre canal** (SMS, téléphone), jamais dans le même courriel ni dans un courriel suivant. La meilleure solution reste de proposer au médecin la messagerie sécurisée de santé.

À vous de jouer – Exercice d'application 21.18

Une diététicienne invite 140 patients à un atelier « Cuisine et diabète ». Elle met toutes les adresses dans le champ « À ». a) Combien de fois une adresse est-elle montrée à une autre personne ? b) Quelle information de santé est révélée ? c) Quelle règle aurait évité le problème ?

Corrigé

a) Chaque patient voit les 139 autres adresses : 140 × 139 = **19 460** affichages d'une adresse à un tiers. b) Le titre de l'atelier révèle que chaque destinataire est **suivi pour un diabète** : c'est une donnée de santé. Il s'agit d'une violation de données personnelles, à inscrire au registre et à évaluer pour une notification à la CNIL. c) Les envois groupés se font en **copie cachée** (Cci) ou, mieux, avec un outil d'envoi individuel ; l'objet reste neutre (« Invitation à un atelier »).

À vous de jouer – Exercice d'application 21.19

Voici le message d'absence d'une diététicienne : « Je suis en congé au Portugal du 3 au 24 août. Pour les urgences, appelez-moi au 06 xx xx xx xx. Ma remplaçante, Julie Martin, a accès à tous mes dossiers avec mon mot de passe. » Relevez trois erreurs et réécrivez le message.

Corrigé

Erreurs : 1. Le **lieu et la durée** du voyage renseignent un cambrioleur ou un escroc (« je suis votre diététicienne, je suis bloquée au Portugal… »). 2. Le **numéro personnel** est diffusé à toute personne qui écrit, y compris aux pirates. 3. Le **mot de passe partagé** : la remplaçante doit avoir son propre compte. Réécriture : « Je suis absente jusqu'au 24 août inclus. Pour un rendez-vous ou une question, contactez le secrétariat au 04 xx xx xx xx. En cas d'urgence médicale, appelez le 15. »

Le chiffrement des appareils et des supports

Un ordinateur portable volé, une clé USB perdue, un téléphone oublié dans un train : sans chiffrement, toutes les données sont lisibles par la personne qui les trouve.

Définition – Chiffrement

Transformation des données par un procédé mathématique qui les rend **illisibles** sans la clé (un mot de passe, un code, une puce). Le **chiffrement du disque** protège tout le contenu d'un ordinateur éteint ; le chiffrement d'une clé USB protège les fichiers qu'elle contient. Les systèmes récents des ordinateurs et des téléphones proposent ce chiffrement sans coût supplémentaire.

À retenir – Le chiffrement change la gravité

Le vol d'un ordinateur **non chiffré** contenant des dossiers de patients est une violation de données à haut risque : notification à la CNIL et souvent information des patients. Si l'ordinateur est **chiffré** avec une clé solide qui n'a pas été volée avec lui, les données sont inintelligibles : le RGPD (article 34) prévoit que l'information des personnes n'est alors pas nécessaire. Le chiffrement ne rend pas le vol impossible, il en **réduit la gravité**.

À vous de jouer – Exercice d'application 21.20

Le portable d'une diététicienne est volé dans sa voiture. Comparez les conséquences dans deux cas : disque chiffré avec un code connu d'elle seule ; disque non chiffré, session ouverte sans mot de passe.

Corrigé

Chiffré : les données sont illisibles ; c'est une violation à inscrire au registre (perte du matériel) ; le risque pour les patients est faible, la notification peut ne pas être nécessaire après analyse avec le DPO ; on porte plainte et on change les mots de passe enregistrés. **Non chiffré** : le voleur lit tous les dossiers ; violation à **haut risque** : notification à la CNIL dans les 72 heures, **information** des patients, plainte, changement de tous les mots de passe ; atteinte grave à la confiance des patients.

Antivirus, pare-feu et filtrage

Le référentiel demande de mettre en œuvre la **prévention contre les virus et les actes malveillants**. Les gestes humains sont essentiels, mais des outils techniques arrêtent beaucoup d'attaques automatiques.

Définition – Logiciel malveillant

Programme conçu pour nuire : **virus** (qui se propage en infectant d'autres fichiers), **ver** (qui se propage seul par le réseau), **cheval de Troie** (qui se cache dans un programme d'apparence utile), **logiciel espion** (qui vole des informations), **rançongiciel** (qui chiffre les données). On les attrape surtout par une pièce jointe, un lien, un téléchargement ou un support amovible.

Outil · Rôle · Bonne pratique

Antivirus (ou solution de détection) — *Rôle :* Repère et bloque les programmes malveillants connus ou les comportements suspects ; *Bonne pratique :* Toujours actif et à jour ; ne jamais le désactiver « pour aller plus vite »

Pare-feu — *Rôle :* Filtre les connexions entrantes et sortantes de l'ordinateur ou du réseau ; *Bonne pratique :* Activé sur chaque poste et sur la box ; réglé par le prestataire

Filtrage de la messagerie — *Rôle :* Écarte une partie des messages piégés et des pièces jointes dangereuses ; *Bonne pratique :* Signaler les messages suspects pour améliorer le filtre

Blocage des macros — *Rôle :* Empêche les documents bureautiques de lancer des programmes ; *Bonne pratique :* Ne jamais « activer le contenu » d'un document reçu sans raison

Analyse des supports amovibles — *Rôle :* Contrôle une clé USB avant son ouverture ; *Bonne pratique :* Aucune clé inconnue, même analysée

Attention – L'antivirus ne suffit pas

Un antivirus ne reconnaît pas tout, en particulier les attaques nouvelles ou ciblées, et il ne protège pas d'une personne qui donne son mot de passe sur une fausse page. Il fait partie d'un ensemble : mises à jour, sauvegardes, double authentification, vigilance.

À vous de jouer – Exercice d'application 21.21

Un message de l'antivirus s'affiche : « Menace détectée et mise en quarantaine » après l'ouverture d'une pièce jointe par une secrétaire. Elle se demande si elle doit prévenir quelqu'un, puisque l'antivirus « a réglé le problème ». Que lui répondez-vous ?

Corrigé

Oui, elle prévient le **référent** ou le service informatique. La quarantaine montre que l'antivirus a bloqué **un** élément, mais d'autres ont pu passer ; le même message a peut-être été reçu par d'autres collègues, qu'il faut avertir ; il faut vérifier l'expéditeur (peut-être un partenaire piraté). Elle ne rouvre pas le message et ne le transfère pas. Prévenir n'est jamais une faute : c'est ce qui permet de réagir vite.

Se connecter aux plateformes en sécurité

Le diététicien utilise de nombreuses plateformes : logiciel de soins, Mon espace santé côté professionnel, espaces de formation, sites de commande, outils de visioconférence. Le référentiel cite les **bonnes pratiques de connexion à des plateformes** et la **gestion de l'identité numérique**.

Bonne pratique · Pourquoi

Taper soi-même l'adresse du site ou utiliser un favori, plutôt qu'un lien reçu — *Pourquoi :* Évite les fausses pages de connexion

Vérifier l'adresse dans la barre du navigateur avant de saisir un mot de passe — *Pourquoi :* Une fausse page imite le logo, pas l'adresse exacte

Se déconnecter à la fin, surtout sur un poste partagé — *Pourquoi :* Le suivant ne doit pas reprendre la session

Ne pas enregistrer le mot de passe dans le navigateur d'un poste partagé — *Pourquoi :* Toute personne qui utilise le poste pourrait se connecter

Activer la double authentification quand elle est proposée — *Pourquoi :* Protège en cas de mot de passe volé

Utiliser une adresse professionnelle pour les comptes professionnels — *Pourquoi :* Le compte reste lié à la fonction, pas à la vie privée

Séparer identité professionnelle et identité personnelle sur les réseaux sociaux — *Pourquoi :* Limite les informations utilisables par un attaquant (ingénierie sociale) et protège la réputation professionnelle (chapitre 15)

À vous de jouer – Exercice d'application 21.22

Dans un centre social, le même ordinateur sert à l'accueil, aux animatrices et à la diététicienne qui vient le mardi. Listez cinq règles de connexion à afficher à côté du poste.

Corrigé

1. « J'ouvre **ma propre session** ; je ne travaille jamais dans celle d'un autre. » 2. « Je **me déconnecte** des plateformes et je ferme ma session en partant. » 3. « Je **n'enregistre jamais** mon mot de passe dans le navigateur. » 4. « Je tape l'adresse des sites moi-même ou j'utilise les favoris du centre. » 5. « Je ne laisse **aucun document** de patient ou d'usager sur le bureau ni dans les téléchargements. »

À vous de jouer – Exercice d'application 21.23

Dans le bureau diététique d'un hôpital, un poste est partagé par trois diététiciennes. Classez chaque pratique en « correcte » ou « à corriger » : a) chacune ouvre sa session avec sa carte CPS ; b) le navigateur enregistre les mots de passe de la messagerie ; c) le poste se verrouille après 5 minutes ; d) les bilans sont enregistrés sur le bureau de l'ordinateur ; e) une clé USB personnelle sert à ramener des documents à la maison ; f) on retire sa carte en quittant la pièce.

Corrigé

Correctes : **a**, **c**, **f**. À corriger : **b** (les autres utilisatrices du poste peuvent ouvrir la messagerie : on utilise un gestionnaire de mots de passe personnel) ; **d** (le bureau n'est ni sauvegardé ni protégé : on enregistre dans le dossier du patient ou sur l'espace réseau du service) ; **e** (une clé personnelle peut être perdue, infectée et n'est pas chiffrée : on passe par les outils fournis par l'établissement).

Point d'étape – Je teste mes acquis – L'environnement de travail

Répondez sans regarder le cours, puis corrigez-vous. Comptez 1 point par réponse juste.

1. Comment calcule-t-on le nombre de combinaisons d'un mot de passe ?

2. Pourquoi une phrase de passe de plusieurs mots est-elle conseillée ?
3. Citez les trois catégories de facteurs d'authentification.
4. Mot de passe et question secrète : est-ce une double authentification ?
5. Que retient-on avec un gestionnaire de mots de passe ?
6. Qu'est-ce que la fin de support d'un logiciel ?
7. Que signifie le principe du moindre privilège ?
8. Pourquoi ne faut-il pas travailler avec un compte administrateur ?
9. Que change le chiffrement en cas de vol d'un ordinateur ?

Corrigé – Point d'étape – L'environnement de travail

1. Nombre de caractères possibles puissance la longueur.
2. Elle est longue, donc très difficile à trouver, et facile à retenir.
3. Ce que je sais, ce que je possède, ce que je suis.
4. Non : ce sont deux facteurs de la même catégorie.
5. Un seul mot de passe maître, très solide.
6. La date après laquelle l'éditeur ne publie plus de mises à jour de sécurité.
7. Chacun n'a accès qu'à ce dont il a besoin pour son travail, le temps nécessaire.
8. Un programme malveillant ouvert par erreur obtiendrait tous les droits sur le poste.
9. Les données sont illisibles : la gravité de la violation diminue fortement.

Les sauvegardes

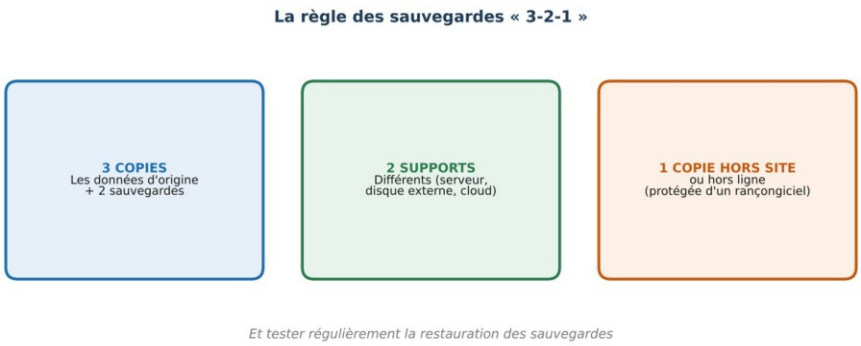


Figure 21.2 – La règle des sauvegardes « 3-2-1 »

Comprendre le schéma – Figure 21.2

1. Trois copies des données : l'original et deux sauvegardes.
2. Sur **deux supports** différents (serveur, disque externe, service de stockage en ligne professionnel).
3. Dont **une copie hors site ou hors ligne**, que ne pourrait pas atteindre un rançongiciel.
4. Une sauvegarde n'a de valeur que si l'on a **testé** sa restauration.

Exemple – Calcul détaillé : une perte de données selon la fréquence des sauvegardes

Une structure saisit en moyenne 40 fiches d'activité par jour ouvré (5 jours par semaine). Un rançongiciel chiffre ses données un jeudi soir, juste avant la sauvegarde du jour.

- Sauvegarde **hebdomadaire** le vendredi soir : la dernière sauvegarde date du vendredi précédent ; données perdues : lundi à jeudi, soit 4 jours × 40 = **160 fiches** à ressaisir.
- Sauvegarde **quotidienne** chaque soir : dernière sauvegarde le mercredi soir ; perte : jeudi, soit **40 fiches**.
- Réduction de la perte : (160 − 40) / 160 × 100 = **75 %**.
- À condition que la sauvegarde soit **hors ligne** : sinon,

le rançongiciel peut l'avoir chiffrée elle aussi.

Les types de sauvegarde

Toutes les sauvegardes ne se ressemblent pas. Pour choisir avec le prestataire, il faut connaître trois types, qui diffèrent par la place qu'ils occupent et par le temps nécessaire pour restaurer.

Type · Ce qui est copié · Pour restaurer · Avantage · Inconvénient

Complète — *Ce qui est copié :* Toutes les données, à chaque fois ; *Pour restaurer :* La dernière sauvegarde complète ; *Avantage :* Restauration simple ; *Inconvénient :* Longue et volumineuse

Incrémentale — *Ce qui est copié :* Ce qui a changé depuis la **dernière sauvegarde**, quelle qu'elle soit ; *Pour restaurer :* La complète **et toutes** les incrémentales suivantes, dans l'ordre ; *Avantage :* Rapide, peu de place ; *Inconvénient :* Restauration plus longue ; une seule copie abîmée bloque la chaîne

Différentielle — *Ce qui est copié :* Ce qui a changé depuis la **dernière complète** ; *Pour restaurer :* La complète **et la dernière** différentielle ; *Avantage :* Restauration en deux étapes ; *Inconvénient :* Grossit chaque jour jusqu'à la complète suivante

Exemple – Calcul détaillé : la place occupée en une semaine

Un service fait une sauvegarde **complète** de 40 Go le dimanche ; chaque jour du lundi au samedi, environ 1,5 Go de données changent (hypothèse : ce ne sont pas les mêmes données d'un jour à l'autre).

- **Incrémentale** du lundi au samedi : 6 × 1,5 = 9 Go ; total de la semaine : 40 + 9 = **49 Go** ; sur 4 semaines conservées : **196 Go**.
- **Différentielle** : lundi 1,5 Go ; mardi 3 Go ; mercredi 4,5 Go ; jeudi 6 Go ; vendredi 7,5 Go ; samedi 9 Go ; total : 31,5 Go ; semaine : 40 + 31,5 = **71,5 Go** ; sur 4 semaines : **286 Go**.
- Pour restaurer le samedi soir : en incrémental, il faut la complète et **6** sauvegardes ; en différentiel, la complète et **1** seule.

À vous de jouer – Exercice d'application 21.24

Une sauvegarde complète a lieu le dimanche, puis des incrémentales chaque soir. Le jeudi matin, le serveur tombe en panne. Quelles sauvegardes faut-il pour restaurer, et que se passe-t-il si celle du mardi est illisible ?

Corrigé

Il faut la complète du **dimanche**, puis les incrémentales du **lundi**, du **mardi** et du **mercredi**, dans l'ordre. Si celle du mardi est illisible, on ne peut restaurer de façon fiable que jusqu'au **lundi soir** : les modifications de mardi et de mercredi sont perdues ou incomplètes. D'où l'intérêt de **vérifier** les sauvegardes et de faire une complète régulièrement.

Combien peut-on perdre, combien de temps peut-on attendre ?

Avant de choisir une organisation de sauvegarde, la structure doit répondre à deux questions, qui partent des **besoins des personnes** et non de la technique.

Définition – Perte maximale admissible et durée maximale d'interruption

- **Perte de données maximale admissible** (en anglais *RPO*) : la quantité de travail que l'on accepte de perdre, exprimée en temps. Si l'on sauvegarde chaque nuit, on peut perdre jusqu'à une journée.
- **Durée maximale d'interruption admissible** (en anglais *RTO*) : le temps pendant lequel l'activité peut s'arrêter avant que les conséquences deviennent graves. Pour une cuisine hospitalière, la liste des régimes doit être disponible avant le début de la production du matin.

Exemple – Calcul détaillé : régler la fréquence des sauvegardes

Dans un hôpital (fictif), les diététiciennes et les soignants saisissent en moyenne **35 modifications** de régime ou de texture par jour, entre 8 h et 20 h, soit 35 / 12 ≈ 2,9 modifications par heure.

- Sauvegarde **une fois par nuit** : au pire, une attaque juste avant la sauvegarde fait perdre une journée, soit **35 modifications**. Chacune oubliée peut donner un repas inadapté.
- Sauvegarde **toutes les 2 heures** pendant l'activité : au pire, 2 × 2,9 ≈ **6 modifications** perdues.
- Si la direction fixe une perte maximale admissible de **2 heures**, la sauvegarde nocturne ne suffit pas. En complément, la liste papier des modifications du jour, tenue par la diététicienne, permet de ressaisir ce qui manque.

À retenir – Partir des personnes

Les deux durées se fixent avec les **métiers** : la diététicienne sait combien de temps la cuisine peut fonctionner sans la liste des régimes, et quelles informations sont vitales. L'informaticien propose ensuite les moyens techniques et leur coût.

À vous de jouer – Exercice d'application 21.25

Un service de portage de repas (fictif) livre 260 repas par jour ; les tournées partent à 9 h et la production commence à 6 h. Proposez une durée maximale d'interruption pour le logiciel des tournées et justifiez-la. Que faut-il prévoir si la restauration prend plus de temps ?

Corrigé

Les régimes et les adresses doivent être connus **avant 6 h** pour produire, et les tournées avant 9 h : si le logiciel

tombe la nuit, il faudrait le retrouver en quelques heures. Une durée maximale de **3 heures** environ est réaliste, mais difficile à garantir. Il faut donc un **mode dégradé** : une liste papier ou un export chiffré des bénéficiaires, régimes et tournées, mis à jour chaque semaine et à chaque changement, qui permet de produire et de livrer même si le logiciel reste indisponible plusieurs jours.

Tester la restauration et protéger les sauvegardes

Beaucoup de structures découvrent le jour de l'attaque que leurs sauvegardes sont incomplètes, illisibles ou chiffrées elles aussi. Une sauvegarde n'a de valeur que si on sait la **restaurer**.

Méthode pas à pas – Un test de restauration en cinq étapes

1. Choisir un fichier ou un dossier réel (par exemple les fiches techniques d'un mois donné).

2. Restaurer à partir de la sauvegarde, dans un emplacement de test.

3. Vérifier que le contenu est complet et lisible, et noter la date de la sauvegarde utilisée.

4. Chronométrer : combien de temps a pris la restauration ? Le résultat est comparé à la durée maximale d'interruption.

5. Consigner le test (date, résultat, problème) et recommencer régulièrement (par exemple chaque trimestre).

Protection des sauvegardes · Pourquoi

Une copie déconnectée ou non modifiable — *Pourquoi :* Le rançongiciel ne peut pas la chiffrer

Une copie hors site (autre bâtiment, hébergeur) — *Pourquoi :* Protège contre l'incendie, le dégât des eaux, le vol

Des sauvegardes chiffrées — *Pourquoi :* Une sauvegarde volée ne révèle pas les données

Des comptes de sauvegarde séparés des comptes habituels — *Pourquoi :* Un compte piraté ne permet pas d'effacer les sauvegardes

Une durée de conservation suffisante — *Pourquoi :* Une attaque peut rester cachée plusieurs semaines : il faut pouvoir revenir avant l'intrusion

À vous de jouer – Exercice d'application 21.26

Le contrat d'un éditeur de logiciel indique : « Sauvegardes quotidiennes conservées 7 jours sur notre infrastructure. » Expliquez deux faiblesses de cette clause et proposez une nouvelle rédaction.

Corrigé

1. **Sur la même infrastructure** : une attaque ou un incident qui touche l'éditeur peut toucher aussi les sauvegardes. 2. **7 jours** : si les attaquants sont restés cachés plus d'une semaine, toutes les sauvegardes contiennent déjà leur intrusion. Nouvelle rédaction : « Des sauvegardes quotidiennes sont réalisées, dont une copie chiffrée hors ligne ou non modifiable sur une infrastructure distincte ; elles sont conservées au moins 30 jours et une restauration est testée chaque trimestre ; le résultat est communiqué au client. »

À vous de jouer – Exercice d'application 21.27

Le serveur d'une cuisine centrale fait une sauvegarde complète de 40 Go le dimanche, puis une incrémentale de 1,5 Go chaque soir du lundi au samedi. On garde 5 semaines de sauvegardes, en deux copies (sur place et hors site). a) Calculez le volume d'une semaine. b) Calculez le volume total stocké. c) Pourquoi garder 5 semaines plutôt qu'une ?

Corrigé

a) 40 + 6 × 1,5 = **49 Go** par semaine. b) 49 × 5 = 245 Go par copie ; × 2 copies = **490 Go**. c) Une attaque peut rester cachée plusieurs semaines : avec une seule semaine de recul, toutes les sauvegardes pourraient contenir l'intrusion. Cinq semaines permettent de revenir à un état sain.

À vous de jouer – Exercice d'application 21.28

Un service diététique saisit les régimes de 7 h à 19 h. Deux solutions sont proposées : A) une sauvegarde chaque nuit à 23 h ; B) une sauvegarde toutes les 2 heures, de 9 h à 19 h. Quelle est la perte maximale dans chaque cas si le serveur tombe à 18 h 50 ? Laquelle choisir si l'équipe accepte au plus une demi-journée de ressaisie ?

Corrigé

A) Dernière sauvegarde la veille à 23 h : on perd toute la journée, de 7 h à 18 h 50, soit **11 h 50** de saisies. B) Dernière sauvegarde à 17 h : on perd de 17 h à 18 h 50, soit **1 h 50**. Une demi-journée de travail correspond à environ 6 heures : seule la solution **B** respecte la perte maximale admissible fixée par l'équipe.

À vous de jouer – Exercice d'application 21.29

Sur le poste d'un service diététique, quatre mises à jour attendent : système d'exploitation (faille connue utilisée par des attaquants), navigateur, logiciel de calcul des menus, pilote de l'imprimante. Classez-les par priorité et justifiez.

Corrigé

1. **Système d'exploitation** : une faille déjà exploitée par des attaquants est le risque le plus urgent. 2. **Navigateur** : c'est la porte d'entrée la plus exposée (sites, liens, pièces jointes ouvertes en ligne). 3. **Logiciel de calcul des menus** : on l'installe après

accord de l'éditeur et un test, pour ne pas bloquer la production. 4. **Pilote de l'imprimante** : utile, mais moins exposé. Toutes les mises à jour de sécurité finissent par être installées : le classement donne l'ordre, pas le droit d'en oublier.

Point d'étape – Je teste mes acquis – Les sauvegardes

Répondez sans regarder le cours, puis corrigez-vous. Comptez 1 point par réponse juste.

1. Que signifie la règle 3-2-1 ?
2. Quelle différence entre une sauvegarde incrémentale et une différentielle ?
3. Qu'est-ce que la perte de données maximale admissible ?
4. Qu'est-ce que la durée maximale d'interruption admissible ?
5. Qui doit participer à la fixation de ces deux durées ?
6. Pourquoi faut-il conserver les sauvegardes plusieurs semaines ?
7. Pourquoi faut-il chronométrer un test de restauration ?

Corrigé – Point d'étape – Les sauvegardes

1. Trois copies, sur deux supports différents, dont une hors ligne ou hors site.
2. L'incrémentale copie ce qui a changé depuis la dernière sauvegarde ; la différentielle, depuis la dernière complète.
3. La quantité de travail que l'on accepte de perdre, exprimée en temps.
4. Le temps pendant lequel l'activité peut s'arrêter sans conséquence grave.
5. Les métiers (dont la diététicienne) et l'informatique, avec la direction.
6. Une attaque peut rester cachée longtemps : il faut pouvoir revenir à un état antérieur à l'intrusion.
7. Pour vérifier que la restauration tient dans la durée maximale d'interruption.

21.3.3 Les actions malveillantes et leur prévention

Module · Référentiel : C3.6 · CNED : pas de passage correspondant (voir 21.2.2)



Figure 21.3 – Les principales actions malveillantes

Comprendre le schéma – Figure 21.3

1. Hameçonnage (*phishing*) : message frauduleux (courriel, SMS, réseau social) imitant un organisme connu pour faire cliquer sur un lien, ouvrir une pièce jointe piégée ou saisir des identifiants.

2. Rançongiciel : logiciel malveillant qui chiffre les données et bloque les systèmes, puis exige une rançon ; il entre souvent par un hameçonnage ou une faille non corrigée.

3. Usurpation d'identité : se faire passer pour une personne (un directeur, un fournisseur, un patient) ou une organisation, par exemple pour obtenir un virement.

4. Ingénierie sociale : manipulation psychologique (urgence, autorité, flatterie, peur) pour obtenir un accès, une information ou une action.

Menace · Signes d'alerte · Prévention

Hameçonnage — *Signes d'alerte :* Adresse d'expéditeur étrange, fautes, urgence, menace, lien dont l'adresse ne correspond pas à l'organisme, demande d'identifiants ; *Prévention :* Ne pas cliquer ; vérifier par un autre canal ; signaler au référent informatique ; double authentification

Rançongiciel — *Signes d'alerte :* Fichiers illisibles, extensions modifiées, message de rançon ; *Prévention :* Mises à jour, sauvegardes hors ligne, droits limités, vigilance sur les pièces jointes

Usurpation (« fraude au président », faux fournisseur) — *Signes d'alerte :* Demande inhabituelle et urgente de virement ou de changement de coordonnées bancaires, confidentialité exigée ; *Prévention :* Procédure de double validation ; rappel de l'interlocuteur à un numéro connu

Faux support technique — *Signes d'alerte :* Fenêtre bloquante, appel prétendant venir du service informatique ; *Prévention :* Ne jamais donner l'accès à distance ni son mot de passe ; contacter le vrai service

Ingénierie sociale — *Signes d'alerte :* Interlocuteur pressant, flatteur ou menaçant, demande d'information sur l'organisation ; *Prévention :* Ne rien communiquer sans vérifier l'identité ; en parler

Attention – La santé, une cible

Les établissements de santé détiennent des données sensibles et ne peuvent pas interrompre leur activité : ils sont des cibles fréquentes. Plusieurs hôpitaux français ont été paralysés par des rançongiciels ces dernières années (par exemple le centre hospitalier sud francilien en 2022), avec déprogrammation d'activités et retour au papier. Les petites structures (associations, centres sociaux, cabinets) sont aussi visées, souvent par hameçonnage.

Exemple – Analyser un courriel suspect

Courriel reçu (fictif) : expéditeur « service-paiement@caf-remboursement-info.com » ; objet : « URGENT : votre compte sera suspendu sous 24 h » ; texte : « Cliquez ici pour mettre à jour vos coordonnées bancaires » ; nombreuses fautes.

- **Indices** : adresse d'expéditeur sans rapport avec le site officiel ; urgence et menace ; demande de coordonnées bancaires ; fautes.
- **Conduite** : ne pas cliquer, ne pas répondre ; signaler au référent informatique ; supprimer ; si des usagers reçoivent le même message, les informer (affiche) et les orienter vers les fiches de *cybermalveillance.gouv.fr*.

Comment se déroule une attaque par rançongiciel

Un rançongiciel n'apparaît pas par hasard un matin. L'attaque suit presque toujours les mêmes étapes, parfois sur plusieurs semaines. Connaître ces étapes permet de comprendre **où** chaque mesure agit.

Étape · Ce que fait l'attaquant · Ce qui peut l'arrêter

1. Entrée — *Ce que fait l'attaquant :* Vole un mot de passe par hameçonnage, exploite une faille non corrigée ou un accès à distance mal protégé ; *Ce qui peut l'arrêter :* Vigilance, double authentification, mises à jour

2. Installation — *Ce que fait l'attaquant :* Installe des outils pour revenir quand il veut ; *Ce qui peut l'arrêter :* Antivirus et détection, comptes sans droits d'administration

3. Exploration — *Ce que fait l'attaquant :* Cherche les serveurs, les sauvegardes, les comptes d'administrateur ; *Ce qui peut l'arrêter :* Droits limités, surveillance des connexions inhabituelles

4. Vol de données — *Ce que fait l'attaquant :* Copie des fichiers vers l'extérieur pour faire chanter la victime ; *Ce qui peut l'arrêter :* Chiffrement des données, alertes sur les transferts massifs

5. Chiffrement — *Ce que fait l'attaquant :* Chiffre les serveurs et les sauvegardes accessibles, souvent la nuit ou le week-end ; *Ce qui peut l'arrêter :* Sauvegardes déconnectées ou non modifiables

6. Chantage — *Ce que fait l'attaquant :* Demande une rançon, menace de publier les données ; *Ce qui peut l'arrêter :* Plan de continuité, plainte, refus de payer

Définition – Double extorsion

Technique où l'attaquant **chiffre** les données (première pression : l'activité est bloquée) **et** menace de **publier** les données volées (seconde pression). Même avec de bonnes sauvegardes, la victime subit donc une atteinte à la confidentialité : la violation de données doit être analysée et, le plus souvent, notifiée.

À vous de jouer – Exercice d'application 21.30

Un rançongiciel chiffre le serveur d'une clinique un dimanche à 3 h ; l'analyse montre que l'attaquant est entré 23 jours plus tôt par le compte d'une secrétaire. Expliquez pourquoi l'attaque a lieu un dimanche et pourquoi les sauvegardes conservées 15 jours ne suffisent pas.

Corrigé

Le dimanche à 3 h, **peu de personnes** surveillent le système : le chiffrement a le temps de s'étendre avant d'être découvert. L'attaquant était présent depuis **23 jours** : toutes les sauvegardes des 15 derniers jours contiennent déjà ses outils ; les restaurer sans précaution réinstalle l'intrusion. Il faut des sauvegardes plus anciennes (antérieures au 23e jour), une analyse pour retirer les outils de l'attaquant et le changement de tous les mots de passe.

Les nouvelles formes d'hameçonnage

L'hameçonnage ne passe plus seulement par courriel. Les attaquants utilisent tous les canaux où les personnes font confiance et réagissent vite.

Forme · Canal · Exemple

Hameçonnage par SMS — *Canal :* Téléphone portable ; *Exemple :* « Votre colis est bloqué, réglez 1,99 € » ; « Ameli : un remboursement vous attend »

Hameçonnage vocal — *Canal :* Appel téléphonique, parfois avec un faux numéro affiché ; *Exemple :* Faux conseiller bancaire, faux service informatique

Hameçonnage par code QR — *Canal :* Code QR collé sur une affiche, un parcmètre, un courrier ; *Exemple :* Un faux code QR remplace le vrai et mène à une fausse page de paiement

Hameçonnage ciblé — *Canal :* Courriel personnalisé avec le nom, la fonction, un vrai fournisseur ; *Exemple :* « Bonjour Madame la diététicienne, suite à notre échange sur les compléments… »

Faux messages de collègues — *Canal :* Boîte d'un collègue piratée ; *Exemple :* Lien vers un « document partagé » qui demande le mot de passe

Attention – Les outils d'intelligence artificielle rendent les faux plus crédibles

Les messages frauduleux ne contiennent plus forcément

de fautes : les outils de génération de texte permettent aux attaquants d'écrire un français correct et adapté au métier de la cible. Les fautes restent un indice, mais leur **absence** ne prouve rien. Le meilleur indice reste la **demande inhabituelle** (identifiants, paiement, urgence).

À vous de jouer – Exercice d'application 21.31

Une affiche dans la salle d'attente d'un cabinet invite à scanner un code QR « pour payer votre consultation en ligne ». Un patient vous dit que le site demande ses coordonnées bancaires complètes et son numéro de sécurité sociale. Que faites-vous ?

Corrigé

On conseille au patient de **ne rien saisir** et, s'il a déjà donné ses coordonnées bancaires, d'appeler sa banque pour faire opposition. On **vérifie** l'affiche : un faux code QR a sans doute été collé sur le vrai, ou l'affiche n'a jamais été posée par le cabinet. On la **retire**, on prévient les autres professionnels et les patients du jour, on signale le faux site (17Cyber, *cybermalveillance.gouv.fr*) et on porte plainte. À l'avenir : code QR protégé sous vitre, vérifié régulièrement, adresse écrite en clair à côté.

La fraude au virement : faux fournisseur et faux dirigeant

Les fraudes au virement ne nécessitent aucune compétence technique : elles exploitent la confiance et les procédures floues. Elles touchent les associations, les cuisines, les cabinets, qui paient régulièrement des fournisseurs.

Variante · Scénario · Le signe qui doit alerter

Faux fournisseur — *Scénario :* « Nous changeons de banque, voici notre nouveau RIB. » ; *Le signe qui doit alerter :* Un changement de coordonnées bancaires annoncé par message

Faux dirigeant — *Scénario :* « Je suis en réunion, faites ce virement urgent et confidentiel. » ; *Le signe qui doit alerter :* Urgence, confidentialité, impossibilité de joindre la personne

Fausse facture — *Scénario :* Une facture imitée, parfois d'un vrai fournisseur, avec un autre RIB ; *Le signe qui doit alerter :* Un RIB différent de celui du dossier fournisseur

Compte de messagerie piraté — *Scénario :* Le vrai fournisseur, piraté, écrit depuis sa vraie adresse ; *Le signe qui doit alerter :* La demande elle-même : changement de RIB, urgence

Méthode pas à pas – La règle des trois vérifications avant un paiement inhabituel

1. Le canal : je ne valide jamais un changement de RIB ou un paiement urgent sur la seule foi d'un message, même venant d'une adresse connue.

2. Le rappel : j'appelle la personne ou le fournisseur au **numéro connu** (dossier fournisseur, annuaire interne), jamais au numéro donné dans le message.

3. La double validation : au-dessus d'un montant fixé, deux personnes signent ; personne ne contourne la règle, pas même la direction.

À vous de jouer – Exercice d'application 21.32

Le fournisseur de fruits et légumes d'une cuisine écrit depuis son adresse habituelle : « Nouveau RIB à utiliser dès la facture de ce mois. » Le gestionnaire dit : « C'est sa vraie adresse, donc c'est sûr. » Répondez-lui.

Corrigé

La vraie adresse ne prouve rien : la messagerie du fournisseur a pu être **piratée**, et l'attaquant écrit alors depuis son adresse réelle, souvent en répondant à de vrais échanges. Ce qui doit alerter, c'est la **demande** : un changement de RIB. On appelle le fournisseur au **numéro du dossier**, on demande une confirmation écrite sur papier à en-tête, et on applique la double validation avant tout paiement sur le nouveau compte.

L'ingénierie sociale au téléphone et à l'accueil

L'ingénierie sociale exploite des réactions humaines normales : l'envie d'aider, le respect de l'autorité, la peur de mal faire, la pression du temps. Elle vise souvent l'**accueil**, le **secrétariat** et les **nouveaux arrivants**.

Levier · Phrase typique · Bonne réaction

Urgence — *Phrase typique :* « Vite, c'est grave, je n'ai pas le temps. » ; *Bonne réaction :* Ralentir : une vraie urgence se vérifie aussi

Autorité — *Phrase typique :* « Je suis le médecin du service, donnez-moi ce dossier. » ; *Bonne réaction :* Vérifier l'identité par un moyen connu

Sympathie — *Phrase typique :* « Vous êtes la seule à pouvoir m'aider. » ; *Bonne réaction :* Appliquer la règle, gentiment

Peur — *Phrase typique :* « Votre poste est infecté, je dois prendre la main à distance. » ; *Bonne réaction :* Raccrocher et appeler le vrai service informatique

Familiarité — *Phrase typique :* Utilise des noms de collègues, du jargon du service ; *Bonne réaction :* Ce qui se trouve sur Internet n'est pas une preuve

Exemple – Le faux technicien

Un « technicien de l'opérateur » appelle l'accueil d'un EHPAD : « Nous avons détecté un problème sur votre ligne, pouvez-vous me donner le nom de votre logiciel de soins et l'identifiant de votre box ? » Ces informations semblent anodines, mais elles servent à préparer une attaque ciblée. La bonne réponse : « Je ne donne pas d'information technique par téléphone. Je transmets votre demande au responsable, qui rappellera votre service client au numéro officiel. »

À vous de jouer – Exercice d'application 21.33

Rédigez trois règles courtes à afficher derrière le comptoir de l'accueil d'une maison de santé pour résister à

l'ingénierie sociale.

Corrigé

1. « **Aucune information** sur un patient (présence, rendez-vous, adresse, santé) n'est donnée par téléphone à une personne non vérifiée. » 2. « **Aucun accès** à un poste et aucun mot de passe ne sont donnés à un interlocuteur qui appelle : je raccroche et je rappelle le service au numéro connu. » 3. « **Dans le doute**, je dis : je vérifie et je vous rappelle, et je préviens le responsable. Personne ne me reprochera d'avoir vérifié. »

Les arnaques qui visent les patients et les usagers

Les personnes accompagnées par un diététicien sont elles aussi visées : personnes âgées isolées, patients atteints de maladies chroniques, parents inquiets, personnes qui veulent perdre du poids. Les arnaques exploitent leurs **espoirs** et leurs **difficultés**.

Arnaque · Ce qu'elle promet · Danger

Fausse cure miracle — *Ce qu'elle promet :* « Remplace votre traitement », « guérit le diabète naturellement » ; *Danger :* Arrêt d'un traitement, complications graves

Faux produit minceur — *Ce qu'elle promet :* Perte de poids rapide, faux experts en blouse, offre d'essai à 1 € ; *Danger :* Abonnement caché, perte de poids dangereuse, dénutrition chez la personne âgée

Faux remboursement — *Ce qu'elle promet :* « Ameli », « mutuelle », « CAF » : un remboursement en attente ; *Danger :* Vol de coordonnées bancaires et d'identité

Fausse livraison de matériel médical — *Ce qu'elle promet :* Capteurs, bandelettes, lecteurs « gratuits » ; *Danger :* Vol de données, frais cachés

Faux professionnel — *Ce qu'elle promet :* Faux compte au nom d'un diététicien, consultations payées d'avance ; *Danger :* Perte d'argent, conseils dangereux

Méthode pas à pas – Aider un patient sans le culpabiliser

1. Écouter : la personne a souvent honte ; on la remercie d'en parler.

2. Évaluer le danger pour la santé : traitement arrêté, produit ingéré, perte de poids ? On oriente vers le médecin si besoin.

3. Limiter les dégâts : opposition bancaire, changement de mot de passe, résiliation par écrit, droit de rétractation de 14 jours pour un achat à distance (code de la consommation, article L221-18).

4. Orienter : *cybermalveillance.gouv.fr*, 17Cyber, plainte, association de consommateurs.

5. Prévenir : trois signes d'arnaque à retenir, et la règle « je ne change jamais un traitement sans mon médecin ».

À vous de jouer – Exercice d'application 21.34

Un patient diabétique de 68 ans vous montre une publicité pour une « tisane qui remplace la metformine », vendue 59 € avec une vidéo d'un « professeur ». Il a déjà commandé. Rédigez les quatre messages essentiels de votre réponse.

Corrigé

1. « Merci de m'en parler, ces publicités sont faites pour tromper tout le monde. » 2. « Ne **modifiez pas** votre traitement : arrêter la metformine peut déséquilibrer votre diabète ; parlez-en à votre médecin avant de prendre ce produit. » 3. « Vérifiez votre compte bancaire ; pour un achat sur Internet, vous avez **14 jours** pour vous rétracter ; si on vous a prélevé plus que prévu, appelez votre banque. » 4. « Vous pouvez signaler ce site sur *cybermalveillance.gouv.fr* ou 17Cyber ; et si une offre promet de remplacer un médicament, c'est toujours une arnaque. »

Les menaces qui ne sont pas des attaques

La cybersécurité ne protège pas seulement contre les pirates. Une grande partie des incidents vient d'**erreurs**, de **pannes** ou d'**accidents**, et ils ont les mêmes conséquences : données perdues, divulguées ou inaccessibles.

Menace non malveillante · Exemple · Mesure

Erreur d'envoi — *Exemple :* Un bilan envoyé au mauvais destinataire ; *Mesure :* Vérification du destinataire, messagerie sécurisée, délai d'envoi

Erreur de manipulation — *Exemple :* Un fichier des menus écrasé par une ancienne version ; *Mesure :* Sauvegardes, historique des versions

Perte de matériel — *Exemple :* Clé USB oubliée dans un train ; *Mesure :* Chiffrement, pas de copie inutile

Panne matérielle — *Exemple :* Disque du serveur hors d'usage ; *Mesure :* Sauvegardes, matériel surveillé et renouvelé

Panne d'un prestataire — *Exemple :* Logiciel en ligne indisponible une journée ; *Mesure :* Contrat (délai de rétablissement), mode dégradé

Sinistre — *Exemple :* Dégât des eaux dans le local du serveur, incendie ; *Mesure :* Copie hors site, local adapté

Coupure d'électricité ou de réseau — *Exemple :* Box en panne, travaux ; *Mesure :* Liste papier, connexion de secours

À retenir – Une même réponse

Qu'il s'agisse d'une attaque ou d'une panne, les protections sont souvent les **mêmes** : sauvegardes testées, mode dégradé, droits limités, procédures claires. Un plan qui ne pense qu'aux pirates oublie la moitié des risques.

À vous de jouer – Exercice d'application 21.35

Classez les incidents suivants en « malveillant » ou « non malveillant », et proposez une mesure commune aux deux catégories : a) inondation du sous-sol où se trouve le serveur ; b) rançongiciel ; c) erreur de destinataire ; d) faux technicien au téléphone ; e) disque dur en panne.

Corrigé

Malveillants : b, d. **Non malveillants** : a, c, e. Mesure commune : des **sauvegardes** testées, dont une copie **hors site et déconnectée**, et un **mode dégradé** écrit qui permet de continuer l'activité (pour a, b et e) ; une **sensibilisation** qui apprend à vérifier avant d'agir (pour c et d).

Quand l'attaque passe par un prestataire

Une structure peut être parfaitement protégée et subir une attaque **par un prestataire** : éditeur de logiciel en ligne, société de maintenance, fournisseur de messagerie. On parle d'attaque par la **chaîne d'approvisionnement**.

Situation	Conséquence pour la structure
L'éditeur du logiciel de restauration subit un rançongiciel	*Conséquence pour la structure :* Le logiciel est indisponible ; les données des patients ont pu être copiées chez l'éditeur
Le prestataire de maintenance a un accès à distance mal protégé	*Conséquence pour la structure :* L'attaquant entre chez le client par cet accès
Une mise à jour d'un logiciel est piégée chez l'éditeur	*Conséquence pour la structure :* Tous les clients installent le programme malveillant en croyant se protéger
Le fournisseur de messagerie est piraté	*Conséquence pour la structure :* Messages lus, faux messages envoyés au nom de la structure

À retenir – La structure reste responsable

Le prestataire qui traite des données personnelles pour la structure est un **sous-traitant** (RGPD, article 28). La structure, **responsable du traitement**, doit le choisir avec soin, encadrer le contrat (sécurité, délai d'information en cas d'incident, sauvegardes, réversibilité) et notifier elle-même la violation à la CNIL. « C'est la faute du prestataire » n'est jamais une réponse suffisante pour les personnes concernées.

À vous de jouer – Exercice d'application 21.36

Le prestataire informatique d'une association se connecte à distance à ses postes avec un identifiant « admin » et le mot de passe « Assoc2024 », identique pour tous ses clients. Quels risques ? Quelles exigences poser ?

Corrigé

Risques : un attaquant qui obtient ce mot de passe (fuite chez un autre client, devinette facile) entre chez **tous** les clients du prestataire avec des droits d'administrateur ; aucune traçabilité de qui intervient. **Exigences** : un compte **nominatif** par technicien, un mot de passe unique par client, la **double authentification** pour tout accès à distance, un accès ouvert seulement pendant l'intervention et tracé ; ces exigences sont écrites dans le **contrat**.

Ce que dit la loi contre les attaquants, et l'assurance

Les attaques informatiques sont des **délits**. Porter plainte n'est pas un geste inutile : cela permet les enquêtes, aide à recouper les attaques et conditionne parfois l'indemnisation.

Texte	Contenu
Code pénal, article 323-1	*Contenu :* Accéder ou se maintenir frauduleusement dans un système de traitement automatisé de données est puni de 3 ans d'emprisonnement et de 100 000 € d'amende ; les peines augmentent si des données sont supprimées ou modifiées
Code pénal, articles 323-2 et 323-3	*Contenu :* Entraver le fonctionnement d'un système, introduire, modifier ou supprimer frauduleusement des données sont aussi des délits
Loi n° 2023-22 du 24 janvier 2023 (dite LOPMI), article 5	*Contenu :* Une assurance qui couvre les pertes liées à une cyberattaque ne verse l'indemnisation que si la victime a **porté plainte dans les 72 heures** après avoir eu connaissance de l'attaque (article L12-10-1 du code des assurances, en vigueur depuis avril 2023)

Attention – Deux délais de 72 heures différents

Ne confondez pas : la **notification à la CNIL** (RGPD, article 33) concerne les violations de données personnelles et se fait dans les 72 heures après que le responsable du traitement en a eu connaissance ; la **plainte dans les 72 heures** (loi de 2023) conditionne l'indemnisation par l'assurance. Une même attaque peut demander les deux.

À vous de jouer – Exercice d'application 21.37

Une association découvre un rançongiciel le samedi 8 h. Elle est assurée contre les cyberattaques ; des fichiers d'adhérents avec leurs allergies sont touchés. Calculez les deux heures limites à respecter et dites qui fait chaque démarche.

Corrigé

Samedi 8 h + 72 heures = **mardi 8 h** pour les deux démarches. **Plainte** : par le représentant de l'association (président ou directeur), auprès de la police ou de la gendarmerie (avec l'appui de 17Cyber), avant mardi 8 h pour préserver l'indemnisation. **Notification à la CNIL** : par l'association, responsable du traitement, avant mardi 8 h, car des données de santé (allergies) sont touchées ; elle peut être complétée ensuite. Il faut aussi prévenir l'assureur selon le contrat.

À vous de jouer – Exercice d'application 21.38

Sur le téléphone professionnel d'une diététicienne de soins à domicile arrive ce SMS : « Votre colis n'a pas pu être livré. Frais de réexpédition 1,99 €. Réglez ici : http://livraison-suivi-fr.info/r ». Relevez trois indices et indiquez la conduite à tenir.

Corrigé

Indices : 1. Un **petit montant** pour faire baisser la garde (le but est de voler la carte bancaire). 2. Un **lien** vers un site inconnu, sans rapport avec un transporteur. 3. Aucun nom, aucun numéro de suivi, aucun expéditeur identifié. Conduite : ne pas cliquer ; transférer le message au **33700** (service de signalement des SMS indésirables) ; supprimer le message ; si la carte a été saisie, faire opposition tout de suite auprès de la banque et prévenir le référent.

À vous de jouer – Exercice d'application 21.39

L'agente d'accueil d'une maison de santé reçoit un appel : « Bonjour, ici le support de votre logiciel. Nous avons détecté un virus sur votre poste. Installez le programme que je vous envoie pour que je prenne la main à distance. » Expliquez la technique utilisée et rédigez la réponse de l'agente.

Corrigé

C'est une **arnaque au faux support technique**, une forme d'ingénierie sociale : l'appelant crée la peur (« un virus ») et l'urgence pour obtenir l'accès au poste. Une fois connecté, il peut voler des données, installer un rançongiciel ou demander un paiement. Réponse : « Je ne peux rien installer. Je vais rappeler moi-même notre prestataire au numéro du contrat. » L'agente raccroche, note l'heure et le numéro dans la main courante, et prévient le référent.

À vous de jouer – Exercice d'application 21.40

Nommez le type d'action malveillante : a) tous les fichiers du serveur portent une nouvelle extension et une note demande un paiement ; b) un courriel imite la page de connexion de la messagerie ; c) un faux directeur demande un virement urgent et confidentiel ; d) le site internet du centre est saturé et ne répond plus ; e) une clé USB trouvée sur le parking installe un programme espion ; f) un message cible nommément la diététicienne avec des détails sur son service.

Corrigé

a) **Rançongiciel**. b) **Hameçonnage** (vol d'identifiants). c) **Fraude au président** (fraude au virement). d) **Attaque par déni de service**. e) **Logiciel malveillant** introduit par un support amovible piégé. f) **Hameçonnage ciblé**, préparé à partir d'informations publiques (site, réseaux sociaux).

À vous de jouer – Exercice d'application 21.41

Une structure reçoit 1 200 courriels piégés en une semaine. Le filtrage en écarte 96 %. Parmi les messages qui arrivent dans les boîtes, 3 % sont ouverts et entraînent un clic. a) Combien de messages piégés arrivent ? b) Combien de clics sont attendus ? c) Que montre ce calcul ?

Corrigé

a) 1 200 × (100 − 96) / 100 = **48** messages. b) 48 × 3 / 100 ≈ **1,4** clic, soit 1 à 2 clics par semaine. c) Même un très bon filtre laisse passer des messages : la protection technique ne suffit pas. Il faut aussi former les personnes et prévoir la réaction (signalement rapide, double authentification qui limite les dégâts d'un mot de passe volé).

À vous de jouer – Exercice d'application 21.42

La comptable d'une association reçoit un appel. La voix ressemble parfaitement à celle du président : « Je suis en réunion, je ne peux pas parler longtemps. Fais tout de suite un virement de 8 400 € pour bloquer le contrat du traiteur. » Quelle technique peut être utilisée ? Que doit faire la comptable ?

Corrigé

Une voix peut aujourd'hui être **imitée par un logiciel** à partir de quelques enregistrements publics (vidéos, interviews) : c'est une forme d'**hypertrucage** au service de la fraude au président. Les signes d'alerte restent les mêmes : urgence, impossibilité de vérifier, demande de paiement inhabituelle. La comptable ne fait rien pendant l'appel ; elle **raccroche** et **rappelle** le président au numéro qu'elle connaît ; elle applique la procédure de double validation des virements ; elle signale l'appel au référent. Une voix ou une image ne suffit plus à prouver l'identité.

À vous de jouer – Exercice d'application 21.43

Rédigez la procédure, en quatre étapes, qu'une cuisine centrale applique quand un fournisseur demande de changer ses coordonnées bancaires.

Corrigé

1. **Ne rien modifier** à partir du message reçu, même s'il vient de l'adresse habituelle du fournisseur. 2. **Appeler** le fournisseur au numéro déjà connu (contrat, ancienne facture), jamais à celui indiqué dans le message, et faire confirmer le changement par une personne identifiée. 3. Faire **valider** la modification par une deuxième personne (principe des quatre yeux) et garder la trace de l'appel. 4. Pour le premier virement vers le nouveau compte, **vérifier** avec le fournisseur qu'il l'a bien reçu. En cas de doute, prévenir la banque et le référent.

Point d'étape – Je teste mes acquis – Textes, messagerie et menaces courantes

Répondez sans regarder le cours, puis corrigez-vous.

Comptez 1 point par réponse juste.

1. Quel article du code pénal punit l'accès frauduleux à un système d'information ?
2. Quel article du code pénal protège le secret professionnel ?
3. Pourquoi une structure victime d'une attaque peut-elle aussi être sanctionnée ?
4. Comment envoyer une invitation à 140 patients sans révéler leurs adresses ?
5. Par quel canal transmettre le mot de passe d'une archive chiffrée ?
6. À quel numéro signaler un SMS frauduleux ?
7. Pourquoi ne pas éteindre un poste qui affiche une demande de rançon ?

Corrigé – Point d'étape – Textes, messagerie et menaces courantes

1. L'article 323-1.
2. L'article 226-13.
3. Parce qu'elle a une obligation de sécurité (RGPD) : si elle n'a pas pris les mesures attendues, la CNIL peut la sanctionner.
4. En copie cachée (Cci) ou avec un outil d'envoi individuel, et avec un objet neutre.
5. Par un autre canal que le courriel (SMS, téléphone).
6. Au 33700.
7. Pour garder les traces utiles à l'enquête ; on l'isole du réseau à la place.

Point d'étape – Je teste mes acquis – Les actions malveillantes

Répondez sans regarder le cours, puis corrigez-vous. Comptez 1 point par réponse juste.

1. Citez les six étapes d'une attaque par rançongiciel.
2. Qu'est-ce que la double extorsion ?
3. Citez trois canaux d'hameçonnage autres que le courriel.
4. Un message sans faute peut-il être piégé ?
5. Quelle est la règle des trois vérifications avant un paiement inhabituel ?
6. Citez trois leviers de l'ingénierie sociale.
7. Une panne est-elle un sujet de cybersécurité ?
8. Le prestataire est piraté : qui notifie la CNIL ?
9. Que risque, au maximum, une personne qui accède frauduleusement à un système d'information ?
10. Quel délai la loi de 2023 fixe-t-elle pour porter plainte afin d'être indemnisé par l'assurance ?

Corrigé – Point d'étape – Les actions malveillantes

1. Entrée, installation, exploration, vol de données, chiffrement, chantage.
2. L'attaquant chiffre les données et menace de publier celles qu'il a volées.
3. SMS, appel téléphonique, code QR (et réseaux sociaux, messagerie d'un collègue piratée).
4. Oui : les outils de génération de texte permettent d'écrire sans faute.
5. Ne pas se fier au seul message, rappeler au numéro connu, double validation.
6. Urgence, autorité, sympathie, peur, familiarité.
7. Oui : elle atteint la disponibilité des données et demande les mêmes protections.
8. La structure cliente, responsable du traitement.
9. 3 ans d'emprisonnement et 100 000 € d'amende (article 323-1 du code pénal).
10. 72 heures après avoir eu connaissance de l'attaque.

21.3.4 Réagir face à un incident et le signaler

Module · Référentiel : C3.6 · CNED : pas de passage correspondant (voir 21.2.2)

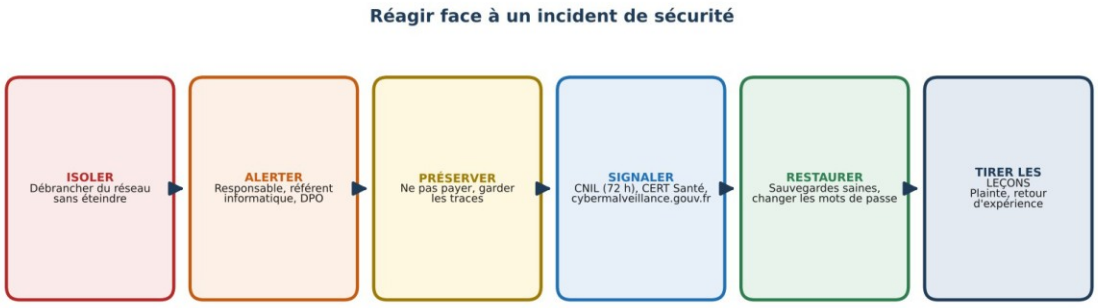


Figure 21.4 – Réagir face à un incident de sécurité

Comprendre le schéma – Figure 21.4

1. Isoler : débrancher l'appareil du réseau (câble, Wi-Fi) sans l'éteindre, pour limiter la propagation et préserver les traces.

2. Alerter immédiatement le responsable, le référent informatique et le délégué à la protection des données.

3. Préserver : ne pas payer de rançon (aucune garantie, financement des criminels), garder les messages et les traces.

4. Signaler : à la CNIL dans les 72 heures en cas de violation de données personnelles présentant un risque ; au CERT Santé pour les structures de santé ; demander l'aide de *cybermalveillance.gouv.fr*.

5. Restaurer à partir de sauvegardes saines ; changer les mots de passe.

6. Tirer les leçons : porter plainte, faire un retour d'expérience, améliorer les mesures.

Interlocuteur · Quand le solliciter

Responsable et référent informatique — *Quand le solliciter :* Toujours, immédiatement

Délégué à la protection des données — *Quand le solliciter :* Si des données personnelles sont concernées

CNIL — *Quand le solliciter :* Violation de données présentant un risque : notification sous 72 heures

CERT Santé (ANS) — *Quand le solliciter :* Incident de sécurité dans une structure de santé ; signalement obligatoire des incidents graves pour les établissements concernés

cybermalveillance.gouv.fr — *Quand le solliciter :* Diagnostic, conseils, mise en relation avec des prestataires ; pour tous

Police, gendarmerie — *Quand le solliciter :* Dépôt de plainte

La main courante de l'incident

Pendant un incident, tout va vite et chacun agit de son côté. Une **main courante** (un journal tenu en continu) permet de garder une trace fiable : elle sert pour les décisions, les déclarations, la plainte, l'assurance et le retour d'expérience.

Définition – Main courante

Document daté où l'on note, **au fil de l'eau**, chaque fait, chaque décision et chaque action, avec l'**heure** et le **nom** de la personne. On la tient sur papier si l'informatique est touchée.

Heure · Fait, décision ou action · Qui

6 h 10 — *Fait, décision ou action :* Le poste de production affiche un message de rançon ; *Qui :* Agent du matin

6 h 12 — *Fait, décision ou action :* Poste débranché du réseau, non éteint ; photo de l'écran ; *Qui :* Agent du matin

6 h 15 — *Fait, décision ou action :* Appel du cadre d'astreinte ; *Qui :* Cheffe de cuisine

6 h 30 — *Fait, décision ou action :* Déclenchement du mode dégradé : classeur papier des régimes ; *Qui :* Cadre d'astreinte

7 h 05 — *Fait, décision ou action :* Prestataire joint, analyse à distance impossible, déplacement à 8 h ; *Qui :* Cadre d'astreinte

9 h 20 — *Fait, décision ou action :* Le serveur est aussi chiffré ; le DPO est prévenu ; *Qui :* Direction

À vous de jouer – Exercice d'application 21.44

Citez quatre usages de la main courante après l'incident, et expliquez pourquoi on la tient sur papier.

Corrigé

Usages : établir l'heure à laquelle la structure a **eu connaissance** de la violation (point de départ des 72 heures) ; fournir les faits pour la **plainte** et l'**assurance** ; remplir la **notification** à la CNIL et le registre des violations ; nourrir le **retour d'expérience** (délais, décisions, difficultés). Sur **papier**, parce que les ordinateurs et la messagerie peuvent être touchés ou surveillés par l'attaquant.

Les déclarations : qui, quand, comment

Un incident peut entraîner plusieurs déclarations, à des destinataires différents, avec des délais différents. Les confondre ou les oublier aggrave la situation.

Destinataire · Quand · Qui déclare · Délai

CNIL — *Quand :* Violation de données personnelles présentant un risque pour les personnes ; *Qui déclare :* Le responsable du traitement (la structure), avec son DPO ; *Délai :* 72 heures après en avoir eu connaissance ; notification complétée ensuite si besoin

Personnes concernées — *Quand :* Risque élevé pour leurs droits et libertés ; *Qui déclare :* Le responsable du traitement ; *Délai :* Dans les meilleurs délais

Registre interne — *Quand :* Toute violation, même sans risque ; *Qui déclare :* La structure ; *Délai :* Dès l'analyse

CERT Santé et ARS — *Quand :* Incident grave de sécurité dans un établissement de santé ou médico-social concerné (chapitre 20) ; *Qui déclare :* L'établissement ; *Délai :* Selon le dispositif de signalement en vigueur

Police, gendarmerie — *Quand :* Toute attaque (délit) ; *Qui déclare :* La structure ; *Délai :* Le plus tôt possible ; 72 heures pour l'assurance

Assureur — *Quand :* Si un contrat couvre le risque cyber ; *Qui déclare :* La structure ; *Délai :* Selon le contrat

Exemple – Calcul détaillé : un incident sur un week-end

Une diététicienne remarque le **vendredi à 18 h 40** que sa messagerie a envoyé des centaines de messages piégés ; elle prévient sa direction à 18 h 50. L'analyse du lundi montre que des comptes rendus de patients ont été transférés à une adresse inconnue.

- La structure a eu connaissance d'un incident **vendredi à 18 h 50** ; la violation de données (comptes rendus transférés) est **établie** lundi. On retient prudemment le vendredi : 18 h 50 + 72 h = **lundi 18 h 50**.
- Le week-end **ne suspend pas** le délai. Si l'analyse n'est pas terminée, on notifie dans le délai avec ce que l'on sait, et on complète.

À vous de jouer – Exercice d'application 21.45

Un EHPAD apprend le mercredi à 11 h, par son éditeur, que les dossiers de 92 résidents ont été copiés lors d'une attaque chez l'éditeur le dimanche précédent. Qui notifie la CNIL, avant quelle heure, et faut-il informer les résidents ?

Corrigé

L'**EHPAD**, responsable du traitement, notifie la CNIL **avant samedi 11 h** (72 heures après avoir eu connaissance de la violation, mercredi 11 h). Les dossiers de résidents contiennent des **données de santé** de personnes vulnérables, copiées par des attaquants : le **risque est élevé**, les résidents (et leurs représentants) doivent être **informés** simplement et rapidement. L'EHPAD demande aussi à l'éditeur le détail des données touchées et vérifie si le contrat a été respecté.

Continuer l'activité : le mode dégradé

Quand l'informatique tombe, les patients doivent toujours manger, recevoir leurs soins et être suivis. Le **plan de continuité** prévoit comment travailler sans les outils habituels.

Définition – Plan de continuité et plan de reprise

- **Plan de continuité d'activité** (PCA) : l'organisation qui permet de **maintenir** les activités essentielles pendant l'incident, en mode dégradé.
- **Plan de reprise d'activité** (PRA) : l'organisation qui permet de **rétablir** les outils et les données, puis de revenir au fonctionnement normal.

Activité · Information vitale · Moyen dégradé

Production des repas — *Information vitale :* Régimes, textures, allergies, nombre de repas par service ; *Moyen dégradé :* Liste papier ou export chiffré, mis à jour à fréquence fixe ; bons papier

Livraison à domicile — *Information vitale :* Adresses, jours, régimes, consignes d'accès ; *Moyen dégradé :* Feuilles de tournée imprimées, protégées

Consultations — *Information vitale :* Rendez-vous du jour et de la semaine, coordonnées des patients ; *Moyen dégradé :* Agenda exporté chaque semaine ; liste des patients prioritaires

Suivi nutritionnel — *Information vitale :* Derniers bilans des patients à risque ; *Moyen dégradé :* Synthèse papier des patients prioritaires

Attention – La liste de secours est aussi un risque

Une liste papier contient des données de santé : elle est réduite au **nécessaire** (pas de code d'accès au domicile sur une liste qui circule), rangée **sous clé**, datée, et l'ancienne version est **détruite** quand la nouvelle arrive. Le mode dégradé ne doit pas créer une nouvelle fuite.

À vous de jouer – Exercice d'application 21.46

Pour le service diététique d'un hôpital, rédigez la liste des documents à préparer à l'avance pour le mode dégradé et leur fréquence de mise à jour.

Corrigé

1. **Liste des patients par service** avec régime, texture, allergies et repas interdits : **chaque jour** à heure fixe (ou export automatique chiffré). 2. **Bons de commande** papier pré-imprimés : stock vérifié chaque mois. 3. **Fiche réflexe** du mode dégradé et numéros utiles : à chaque changement, au moins une fois par an. 4. **Liste des patients prioritaires** du suivi nutritionnel (dénutrition sévère, nutrition artificielle) : **chaque semaine**. 5. Étiquettes de couleur pour les plateaux adaptés : stock vérifié chaque mois.

Communiquer pendant la crise

Une attaque provoque des inquiétudes : patients, familles, équipes, partenaires, journalistes. Une communication mal préparée peut aggraver la situation (rumeurs, faux messages qui profitent de la confusion).

Public · Message essentiel · Canal

Équipes — *Message essentiel :* Ce qui se passe, ce qu'il faut faire et ne pas faire, qui est le contact ; *Canal :* Réunion, téléphone, affichage (pas la messagerie touchée)

Patients et familles — *Message essentiel :* Ce qui change pour eux (rendez-vous, repas), ce qui a pu être touché, à qui s'adresser ; *Canal :* Courrier, téléphone, affichage, site de la structure

Partenaires — *Message essentiel :* Ne pas ouvrir de message suspect venant de la structure ; canal provisoire ; *Canal :* Téléphone, messagerie sécurisée

Médias — *Message essentiel :* Déclaration courte et exacte, par une seule personne ; *Canal :* Direction ou service de communication

À retenir – Les règles d'un bon message de crise

Un **seul** porte-parole ; des **faits** vérifiés, sans minimiser ni dramatiser ; ce que la structure **fait** ; ce que les personnes **doivent faire** ; un contact ; une prochaine information annoncée. On prévient aussi que des escrocs peuvent profiter de la situation : « nous ne vous demanderons jamais vos coordonnées bancaires par message ».

À vous de jouer – Exercice d'application 21.47

Rédigez l'affichette (6 lignes au plus) posée à l'accueil d'un centre de santé victime d'un rançongiciel, pour les patients.

Corrigé

« **Information aux patients.** Notre centre subit une panne informatique liée à une attaque. Les consultations sont maintenues ; certains rendez-vous peuvent être décalés : nous vous appelons si c'est le cas. Nous ne vous demanderons **jamais** vos coordonnées bancaires ou votre numéro de sécurité sociale par SMS ou courriel : ne répondez pas à ces messages. Pour toute question : accueil ou [numéro]. Merci de votre compréhension. »

Ne pas payer, puis apprendre

Face à un rançongiciel, la tentation de payer est forte, surtout quand des patients attendent. Les autorités recommandent de **ne pas payer**.

Argument · Explication
Aucune garantie — *Explication :* Les attaquants ne donnent pas toujours la clé, et elle ne fonctionne pas toujours
Les données copiées restent chez eux — *Explication :* Payer n'efface pas la copie ; ils peuvent la revendre ou revenir
Financement du crime — *Explication :* La rançon finance d'autres attaques, y compris contre d'autres hôpitaux
Cible désignée — *Explication :* Une structure qui paie est souvent attaquée de nouveau

Méthode pas à pas – Un retour d'expérience utile

1. Réunir les personnes concernées, dans les semaines qui suivent, avec la main courante.

2. Reconstituer la chronologie et calculer les délais (détection, alerte, confinement, reprise).

3. Chercher les causes : outils, organisation, formation, contrat, sans désigner de coupable.

4. Décider des actions, chacune avec un responsable et une date.

5. Vérifier quelques mois plus tard que les actions sont faites, et mettre à jour les procédures.

À vous de jouer – Exercice d'application 21.48

Lors du retour d'expérience d'une messagerie piratée, le directeur propose : « On retire l'accès à la messagerie à la personne qui a cliqué. » Répondez-lui.

Corrigé

Sanctionner la personne qui a cliqué **n'empêchera pas** le prochain clic : n'importe qui peut se faire piéger par un message bien construit. Surtout, cela découragera les autres de **signaler** rapidement leurs erreurs, alors que la rapidité du signalement limite les dégâts. Il vaut mieux corriger les **causes** : double authentification, alerte sur les envois massifs, sensibilisation de toute l'équipe, et remercier la personne qui aide à comprendre l'incident.

À vous de jouer – Exercice d'application 21.49

Remettez dans l'ordre les actions d'une diététicienne qui découvre que son poste affiche une demande de rançon : a) prévenir le référent ou le prestataire ; b) débrancher le câble réseau et couper le Wi-Fi, sans éteindre ; c) noter l'heure de la découverte et ce qui est affiché ; d) ne pas payer et ne pas contacter les attaquants ; e) participer au retour d'expérience.

Corrigé

Ordre : **b** (isoler pour éviter la propagation), **c** (noter l'heure et prendre une photo de l'écran : c'est le début de la main courante), **a** (alerter), **d** (ne rien négocier soi-même : la décision appartient à la direction, avec les autorités), **e** (après l'incident). On n'éteint pas le poste : des traces utiles à l'enquête peuvent être perdues.

À vous de jouer – Exercice d'application 21.50

Calculez la date et l'heure limites de notification à la CNIL (72 heures après la prise de connaissance) : a) découverte le lundi 9 mars 2026 à 9 h 15 ; b) le vendredi 13 mars 2026 à 17 h 30 ; c) le mercredi 30 décembre 2026 à 22 h. Que faire si toutes les informations ne sont pas encore connues ?

Corrigé

a) **Jeudi 12 mars 2026 à 9 h 15**. b) **Lundi 16 mars 2026 à 17 h 30** : le délai court aussi pendant le week-end. c) **Samedi 2 janvier 2027 à 22 h** : les jours fériés ne suspendent pas le délai. Si tout n'est pas connu, on fait une **notification initiale** dans le délai, puis on la complète ensuite : le RGPD permet de fournir les informations par étapes.

Point d'étape – Je teste mes acquis – Réagir et continuer

Répondez sans regarder le cours, puis corrigez-vous. Comptez 1 point par réponse juste.

1. Qu'est-ce qu'une main courante, et pourquoi la tenir sur papier ?
2. À partir de quand court le délai de 72 heures pour la CNIL ?
3. Le week-end suspend-il ce délai ?
4. Quelle violation est inscrite au registre interne ?
5. Quelle différence entre plan de continuité et plan de reprise ?
6. Citez deux précautions pour une liste papier de secours.
7. Citez trois règles d'un bon message de crise.
8. Pourquoi ne faut-il pas payer la rançon ?
9. Pourquoi un retour d'expérience ne cherche-t-il pas de coupable ?

Corrigé – Point d'étape – Réagir et continuer

1. Un journal daté des faits, décisions et actions ; sur papier car l'informatique peut être touchée.
2. Au moment où le responsable du traitement a connaissance de la violation.
3. Non.
4. Toutes, même celles qui ne présentent pas de risque.
5. La continuité maintient l'activité en mode dégradé ; la reprise rétablit les outils et les données.
6. Réduite au nécessaire, rangée sous clé, datée, ancienne version détruite.
7. Un seul porte-parole, des faits vérifiés, ce que les personnes doivent faire, un contact.
8. Aucune garantie, les données copiées restent chez les attaquants, cela finance le crime et désigne une cible.
9. Pour que chacun signale vite ses erreurs et que l'on corrige les vraies causes.

Sensibiliser l'équipe

Méthode pas à pas – Une action de sensibilisation en 30 minutes

1. Accroche : un exemple réel et proche (courriel d'hameçonnage reçu par la structure, anonymisé).

2. Jeu : « vrai ou suspect ? » sur cinq messages.

3. Six gestes (figure 21.1) remis sur une fiche plastifiée.

4. Conduite à tenir en cas de doute : qui appeler, quoi ne pas faire.

5. Évaluation : quiz court, puis exercice d'hameçonnage simulé quelques semaines plus tard (avec l'accord de la direction).

Construire un plan de sensibilisation

Une séance isolée ne suffit pas. Les comportements changent quand la sensibilisation est **répétée**, **concrète** et **mesurée**. Le diététicien, habitué à l'éducation pour la santé, dispose déjà des bons outils : partir des représentations, fixer des objectifs, varier les méthodes, évaluer.

Méthode pas à pas – Un plan de sensibilisation sur un an

1. Constat : incidents de l'année, observation des pratiques (mots de passe affichés, sessions ouvertes), mesure de départ (exercice simulé, questionnaire).

2. Objectifs : des comportements observables, chiffrés et datés (« dans six mois, 50 % des agents signalent le faux message de l'exercice »).

3. Publics : chaque public a ses risques (accueil : appels ; cuisine : fournisseurs ; direction : fraude au virement ; soignants : messagerie).

4. Actions : séances courtes, affiches, exemples réels anonymisés, exercices, rappels.

5. Calendrier : une action par trimestre au moins, pour entretenir l'attention.

6. Évaluation : les mêmes indicateurs qu'au départ, présentés sans nom.

Méthode · Durée · Intérêt · Limite

Quart d'heure sécurité, debout, à la prise de poste — *Durée :* 10 à 15 min ; *Intérêt :* Touche tout le monde, y compris les équipes en horaires décalés ; *Limite :* Peu de temps pour les questions

Séance de 30 minutes avec un jeu « vrai ou suspect ? » — *Durée :* 30 min ; *Intérêt :* Active, mémorisable ; *Limite :* Difficile à organiser pour tous

Affiche ou fiche plastifiée — *Durée :* Permanente ; *Intérêt :* Rappel au bon endroit (près des postes) ; *Limite :* S'use, n'est plus lue après quelques semaines

Exercice d'hameçonnage simulé — *Durée :* Quelques secondes pour l'agent ; *Intérêt :* Mesure les comportements réels ; *Limite :* Doit être encadré (voir ci-dessous)

Module en ligne — *Durée :* 20 à 45 min ; *Intérêt :* Suivi individuel ; *Limite :* Peu adapté aux agents peu à l'aise avec l'écrit

À vous de jouer – Exercice d'application 21.51

Pour l'équipe d'un service de portage de repas (12 livreurs, 3 agents administratifs, 1 diététicienne), proposez trois actions de sensibilisation adaptées, avec leur calendrier.

Corrigé

1. **Trimestre 1** : quart d'heure sécurité à la prise de poste des livreurs : « Je ne donne jamais d'information sur un bénéficiaire par téléphone ; les feuilles de tournée ne restent pas visibles dans le véhicule. » 2. **Trimestre 2** : séance de 30 minutes pour les agents administratifs et la diététicienne : faux messages de fournisseurs et fraude au RIB, avec la procédure de rappel. 3. **Trimestre 3** : exercice d'hameçonnage simulé pour les personnes qui ont une messagerie, après information, puis retour collectif sans nom. Une affiche près du poste partagé rappelle les gestes toute l'année.

L'exercice d'hameçonnage simulé : un outil à encadrer

Envoyer un faux message à l'équipe pour mesurer ses réactions est efficace, mais touche à la **confiance** et aux **droits des salariés**. Il doit être préparé avec soin.

Condition · Pourquoi

Décision de la direction, avis du DPO, information des représentants du personnel — *Pourquoi :* Le traitement des réactions des agents est un traitement de données personnelles ; il doit être transparent

Information préalable de l'équipe (« des exercices auront lieu cette année ») sans annoncer la date — *Pourquoi :* Loyauté envers les salariés, sans fausser la mesure

Message réaliste mais non cruel — *Pourquoi :* Pas de faux licenciement, de fausse prime, de faux décès : on ne joue pas avec les émotions fortes

Aucun mot de passe enregistré — *Pourquoi :* La page d'exercice ne doit pas collecter les identifiants saisis

Page pédagogique immédiate — *Pourquoi :* La personne qui clique apprend tout de suite les signes qu'elle n'a pas vus

Résultats anonymes et aucune sanction — *Pourquoi :* L'objectif est d'apprendre et de mesurer un progrès collectif

Attention – Un exercice mal conduit détruit la confiance

Si les agents se sentent piégés et jugés, ils cesseront de signaler leurs erreurs, ce qui est le contraire du but recherché. Un bon exercice se termine toujours par un **retour collectif** positif : « 12 personnes ont signalé le message, bravo ; voici les trois indices à repérer. »

À vous de jouer – Exercice d'application 21.52

Un directeur veut envoyer un faux message « Prime exceptionnelle de fin d'année : cliquez pour la recevoir » et afficher ensuite la liste des personnes qui ont cliqué. Donnez trois raisons de refuser, et proposez un autre scénario.

Corrigé

1. Le message joue sur une **attente forte** (une prime) : il crée de la déception et de la colère, et nuit au climat social. 2. Afficher les noms est une **sanction publique**, contraire au but (apprendre) et à la protection des données des agents. 3. Les agents ne signaleront plus leurs erreurs par peur d'être exposés. **Autre scénario** : un faux message de livraison de fournitures ou de partage de document, suivi d'une page pédagogique et d'un retour collectif sans nom.

Mesurer les progrès avec prudence

Les indicateurs d'un exercice simulé portent souvent sur de petits effectifs. Il faut savoir calculer, mais aussi savoir ne pas trop conclure.

Exemple – Calcul détaillé : deux exercices dans un centre de 60 agents

Premier exercice : **19 clics** sur 60 agents ; second, six mois plus tard : **7 clics** sur 60. Signalements : 6 puis 21.

- Taux de clic : 19 / 60 = **31,7 %**, puis 7 / 60 = **11,7 %** ; taux de signalement : 6 / 60 = **10,0 %**, puis 21 / 60 = **35,0 %**.
- Conditions de l'intervalle de confiance : n = 60 ≥ 30 ; premier exercice : 19 et 41 ≥ 5 ; second : 7 et 53 ≥ 5 : vérifiées.
- IC à 95 % du premier taux : 0,317 ± 1,96 × √(0,317 × 0,683 / 60) ≈ 0,317 ± 0,118, soit **[19,9 % ; 43,4 %]**.
- IC à 95 % du second : 0,117 ± 1,96 × √(0,117 × 0,883 / 60) ≈ 0,117 ± 0,081, soit **[3,5 % ; 19,8 %]**.
- Les deux intervalles ne se chevauchent pas, de très peu : la baisse est **probablement réelle**. Mais avec 60 personnes, les intervalles sont larges (plus ou moins 8 à 12 points) : on parle d'une **tendance encourageante**, à confirmer.

Attention – Ce que les chiffres ne disent pas

Un taux de clic dépend beaucoup du **message choisi** : un message facile à repérer donne un bon résultat sans que l'équipe ait progressé. On compare donc des messages de difficulté comparable, et on suit plusieurs indicateurs (clic, saisie, signalement, délai du premier signalement).

À vous de jouer – Exercice d'application 21.53

Dans un service de 60 agents, un exercice donne 15 clics. Calculez le taux de clic et son intervalle de confiance à 95 %, après avoir vérifié les conditions. Peut-on dire que ce service fait mieux que le premier exercice de l'exemple (19 clics sur 60) ?

Corrigé

Taux : 15 / 60 = **25,0 %**. Conditions : n = 60 ≥ 30, n × p = 15 ≥ 5, n × (1 – p) = 45 ≥ 5. Marge : 1,96 × √(0,25 × 0,75 / 60) ≈ 0,110 ; IC ≈ **[14,0 % ; 36,0 %]**. Cet intervalle **chevauche largement** celui du premier exercice ([19,9 % ; 43,4 %]) : on ne peut pas conclure que ce service fait mieux ; la différence (6,7 points) peut être due au hasard ou au message choisi.

Adapter la sensibilisation aux métiers

Les risques ne sont pas les mêmes à l'accueil, en cuisine ou au bureau de la direction. Une sensibilisation efficace parle **le langage du métier** et part de **situations vécues**.

Public · Risques principaux · Message clé · Format adapté
Accueil, secrétariat — *Risques principaux :* Appels d'ingénierie sociale, faux patients, faux techniciens ; *Message clé :* « Aucune information par téléphone sans vérification » ; *Format adapté :* Jeu de rôle d'un appel
Cuisine, magasin — *Risques principaux :* Faux fournisseurs, fausses factures, clés USB, postes partagés ; *Message clé :* « Un changement de RIB ou de commande se vérifie par téléphone » ; *Format adapté :* Quart d'heure debout, affiche plastifiée
Soignants, diététiciennes — *Risques principaux :* Messagerie piratée, erreurs d'envoi, comptes partagés ; *Message clé :* « Je vérifie le destinataire ; je n'utilise que mon compte » ; *Format adapté :* Exemple réel anonymisé
Direction, comptabilité — *Risques principaux :* Fraude au faux dirigeant, rançongiciel ; *Message clé :* « Aucune exception à la double validation » ; *Format adapté :* Étude de cas, exercice de crise
Intervenants à domicile — *Risques principaux :* Téléphone perdu, feuilles de tournée, Wi-Fi des usagers ; *Message clé :* « Mon téléphone est verrouillé, mes feuilles ne restent pas visibles » ; *Format adapté :* Fiche de poche

Astuce – Utiliser les méthodes de l'éducation pour la santé

Les principes que vous appliquez dans un atelier nutritionnel valent aussi ici : partir de ce que les personnes savent et vivent, éviter la peur et la culpabilisation, proposer des gestes simples et réalisables, valoriser les réussites, évaluer. Une équipe qui comprend **pourquoi** un geste protège les patients l'adopte plus volontiers qu'une règle imposée.

À vous de jouer – Exercice d'application 21.54

Une partie des agents de cuisine d'une cuisine centrale lit difficilement le français. Proposez trois adaptations de la sensibilisation.

Corrigé

1. Des **pictogrammes** et des photos plutôt que du texte (une clé USB barrée, un téléphone avec « j'appelle »). 2. Des **démonstrations** et des mises en situation à l'oral, avec un agent relais qui parle aussi la langue de collègues si besoin. 3. Une affiche **traduite** ou bilingue, et une vérification de la compréhension par une question simple à chacun (« que fais-tu si… ? »), sans le mettre en difficulté devant le groupe.

Sensibiliser les usagers et les patients

Le diététicien peut aussi aider les personnes qu'il accompagne à se protéger. Les arnaques en ligne touchent particulièrement les personnes âgées, isolées ou fragilisées par la maladie, et elles ont des conséquences sur la santé (abandon de traitement, dénutrition, stress).

Moment	Action possible
Atelier d'éducation thérapeutique	*Action possible :* Une séquence « vraies et fausses promesses de santé » avec des exemples de publicités
Consultation	*Action possible :* Une question simple : « Avez-vous acheté des produits ou suivi des conseils trouvés sur Internet ? »
Salle d'attente	*Action possible :* Une affiche « Trois signes d'une arnaque » et les numéros utiles
Atelier cuisine avec des seniors	*Action possible :* Un temps de 20 minutes « Vrai bon plan ou arnaque ? »
Lettre d'information de la structure	*Action possible :* Un rappel : « Nous ne vous demanderons jamais vos coordonnées bancaires par SMS »

À retenir – Trois signes à transmettre aux usagers

1. **L'urgence** (« plus que 2 heures », « votre compte sera bloqué »). 2. **La demande** d'argent, de coordonnées bancaires, de code, de numéro de sécurité sociale. 3. **La promesse trop belle** (guérison, perte de poids rapide, cadeau). Et une règle : **je vérifie en appelant moi-même** le numéro que je connais, et j'en parle à un proche ou à un professionnel.

À vous de jouer – Exercice d'application 21.55

Rédigez le texte d'une affiche (5 lignes au plus) pour la salle d'attente d'un cabinet de diététique, sur les arnaques aux produits minceur.

Corrigé

« **Perdre 8 kg en un mois ? C'est une arnaque.** Méfiez-vous des publicités avec un faux expert, une offre à 1 € et un compte à rebours. Aucun produit ne fait maigrir sans risque. Avant d'acheter ou de changer votre traitement, parlez-en à votre diététicien ou à votre médecin. Victime ? Appelez votre banque et signalez sur 17Cyber ou *cybermalveillance.gouv.fr*. »

À vous de jouer – Exercice d'application 21.56

Une stagiaire de BTS veut évaluer l'effet d'une sensibilisation dans un service de 75 agents. Trois exercices de faux hameçonnage ont lieu à trois mois d'intervalle. Clics : 18, puis 11, puis 6. Signalements : 5, puis 19, puis 34. Calculez les taux et commentez.

Corrigé

Taux de clic : 18 / 75 = **24,0 %** ; 11 / 75 ≈ **14,7 %** ; 6 / 75 = **8,0 %**. Taux de signalement : 5 / 75 ≈ **6,7 %** ; 19 / 75 ≈ **25,3 %** ; 34 / 75 ≈ **45,3 %**. Les clics baissent et les signalements augmentent : l'équipe ne se contente pas d'éviter le piège, elle **alerte**, ce qui permet de réagir vite. Limites : 75 agents, c'est un petit effectif (un ou deux agents de plus changent le taux de plus d'un point) ; les messages des trois exercices n'avaient peut-être pas la même difficulté.

À vous de jouer – Exercice d'application 21.57

Rédigez un quiz de cinq questions fermées (vrai ou faux) à poser en fin de « quart d'heure sécurité » à des agents de restauration, avec les réponses.

Corrigé

1. « Un message qui vient de l'adresse habituelle d'un fournisseur est forcément sûr. » **Faux** : sa messagerie peut être piratée. 2. « Je peux prêter mon badge ou mon code à un collègue pour la journée. » **Faux** : tout ce qu'il fera sera enregistré à mon nom. 3. « Si l'écran affiche un message bizarre, je débranche le câble réseau et je préviens. » **Vrai**. 4. « Un changement de RIB demandé par courriel se vérifie par téléphone, au numéro connu. » **Vrai**. 5. « Si j'ai cliqué par erreur, mieux vaut ne rien dire. » **Faux** : plus on signale tôt, moins les dégâts sont grands, et on ne sera pas sanctionné pour une erreur signalée.

Point d'étape – Je teste mes acquis – Sensibiliser

Répondez sans regarder le cours, puis corrigez-vous. Comptez 1 point par réponse juste.

1. Citez les six étapes d'un plan de sensibilisation.
2. Pourquoi une séance unique ne suffit-elle pas ?
3. Citez quatre conditions d'un exercice d'hameçonnage simulé acceptable.
4. Pourquoi ne faut-il pas sanctionner les personnes qui cliquent ?
5. Quelle formule donne l'intervalle de confiance à 95 % d'une proportion ?
6. Pourquoi faut-il comparer des messages de difficulté comparable ?
7. Quel message clé pour une équipe de cuisine ?
8. Citez trois signes d'arnaque à transmettre aux usagers.

Corrigé – Point d'étape – Sensibiliser

1. Constat, objectifs, publics, actions, calendrier, évaluation.
2. L'attention baisse en quelques semaines : il faut répéter et varier.
3. Décision et information préalables (direction, DPO, représentants, équipe), message non cruel, aucun mot de passe enregistré, page pédagogique, résultats anonymes sans sanction.
4. Elles cesseraient de signaler leurs erreurs, ce qui

retarde la réaction.

5. $p \pm 1{,}96 \times \sqrt{(p \times (1-p) / n)}$, si $n \geq 30$, $n \times p \geq 5$ et $n \times (1-p) \geq 5$.
6. Le taux de clic dépend beaucoup du message choisi.
7. Un changement de RIB ou de commande se vérifie par téléphone (ou : aucune clé USB inconnue).
8. L'urgence, la demande d'argent ou de données, la promesse trop belle.

21.3.5 Fil rouge : un environnement de travail sûr pour le projet des Tilleuls

Module · Référentiel et guide : voir 21.2.1 · CNED : pas de passage correspondant (voir 21.2.2)

Fil rouge – centre social des tilleuls – Les mesures d'Inès

- Une **session personnelle** sur l'ordinateur du centre, supprimée à la fin du stage ; verrouillage de l'écran à chaque absence (l'ordinateur est à l'accueil).
- Les fichiers du projet (inscriptions, questionnaires, fiches techniques) dans l'**espace partagé sauvegardé** du centre, et non sur sa clé USB ou son stockage personnel.
- Une **phrase de passe** unique et la double authentification sur sa messagerie de stage.
- Un courriel suspect « de la CAF » reçu par l'accueil pendant son stage : Inès l'a signalé à la directrice, qui a prévenu l'équipe ; une affiche « Attention aux faux messages » a été posée à l'accueil pour les usagers.

21.4 Approfondissements

21.4.1 Les objets connectés et les applications

Balances, montres ou applications connectées collectent des données parfois sensibles ; elles doivent être paramétrées (comptes, partages), mises à jour et choisies avec précaution (hébergement, éditeur).

Les objets connectés en santé : utiles et exposés

Balances, podomètres, montres, capteurs de glycémie, piluliers connectés : ces objets aident à suivre une maladie ou à motiver une personne. Mais ils collectent des données de santé en continu, les envoient sur Internet et sont souvent mal protégés.

Risque · Exemple · Mesure

Collecte excessive — *Exemple :* Une montre enregistre la position GPS en permanence alors que seul le nombre de pas est utile ; *Mesure :* Désactiver les fonctions inutiles (minimisation)

Mot de passe par défaut — *Exemple :* « 0000 » identique pour tous les appareils ; *Mesure :* Changer le mot de passe à l'installation

Absence de mises à jour — *Exemple :* Le fabricant arrête le support après deux ans ; *Mesure :* Choisir un fabricant qui garantit les mises à jour

Hébergement inconnu — *Exemple :* Données envoyées « dans le cloud », hors Union européenne ; *Mesure :* Vérifier l'hébergement, la certification HDS si l'objet est utilisé dans une prise en charge

Réutilisation commerciale — *Exemple :* Application gratuite « financée par des partenaires » ; *Mesure :* Lire la politique de confidentialité ; refuser le partage publicitaire

Dépendance et anxiété — *Exemple :* Pesée plusieurs fois par jour, obsession des chiffres ; *Mesure :* Définir avec la personne un usage raisonné

Exemple – Calcul détaillé : un capteur de glycémie en continu

Un capteur de glycémie en continu enregistre une mesure toutes les 5 minutes : 12 mesures par heure × 24 heures = **288 mesures par jour**, soit 288 × 30 = **8 640** par mois et 288 × 365 = **105 120** par an. Ces données, très utiles au patient et à l'équipe soignante, décrivent aussi ses repas, son sommeil et son activité. Leur partage (avec le médecin, avec la diététicienne, avec une application tierce) doit être **choisi** par le patient et passer par des outils sûrs.

À vous de jouer – Exercice d'application 21.58

Une patiente suivie pour une obésité veut connecter sa balance à une application gratuite qui « partage vos progrès avec la communauté ». Que lui conseillez-vous ?

Corrigé

Lui expliquer que son poids est une **donnée de santé** et que le partage avec une « communauté » le rend visible par des inconnus, de façon parfois définitive. Lui conseiller de **désactiver** le partage public, de lire qui héberge les données et ce que l'application en fait, de changer le mot de passe de la balance, et de garder les chiffres pour elle et son équipe de soins. Lui proposer aussi une **fréquence de pesée** raisonnable (par exemple une fois par semaine) pour éviter que la balance devienne une source d'anxiété.

Recommander une application : les questions à se poser

Les patients demandent souvent : « Quelle application me conseillez-vous ? » Le diététicien qui recommande une application engage sa crédibilité. Il vérifie au moins la **fiabilité du contenu** et la **protection des données**.

Question · Ce que l'on cherche · Signal d'alerte

Qui l'édite ? — *Ce que l'on cherche :* Un éditeur identifié, une adresse, des professionnels de santé associés ; *Signal d'alerte :* Aucune mention légale

D'où viennent les données nutritionnelles ? — *Ce que l'on cherche :* Une table de référence citée (Ciqual) ; *Signal d'alerte :* Valeurs non sourcées, « calories » sans origine

Quelles données sont demandées ? — *Ce que l'on cherche :* Le strict nécessaire ; *Signal d'alerte :* Accès aux contacts, à la localisation, au micro sans raison

Où sont-elles hébergées, et partagées avec qui ? — *Ce que l'on cherche :* Hébergement dans l'Union européenne, pas de revente ; *Signal d'alerte :* Partage avec des « partenaires » publicitaires

Peut-on supprimer son compte et ses données ? — *Ce que l'on cherche :* Une fonction simple de suppression et d'export ; *Signal d'alerte :* Aucune procédure

Le contenu est-il adapté ? — *Ce que l'on cherche :* Pas de régime restrictif imposé, pas de promesse ; *Signal d'alerte :* Objectifs de perte de poids rapides, défis, classements

Attention – Application de bien-être ou dispositif médical

Une application qui donne une recommandation **pour un patient** (dose, traitement, diagnostic) peut être un **dispositif médical** soumis à des règles particulières (chapitre 20). Une application de suivi alimentaire générale ne l'est pas. Dans le doute, on vérifie le marquage et l'usage prévu par le fabricant.

À vous de jouer – Exercice d'application 21.59

Construisez une grille de six critères notés sur 2 points pour comparer deux applications de suivi alimentaire avant de les recommander dans un programme d'éducation thérapeutique.

Corrigé

Exemple : 1. **Éditeur identifié** (0 : inconnu ; 1 : identifié ; 2 : identifié avec des professionnels de santé). 2. **Source des données** nutritionnelles (0 : aucune ; 2 : Ciqual citée). 3. **Données demandées** (0 : excessives ; 2 : strict nécessaire). 4. **Hébergement et partage** (0 : inconnu ou revente ; 2 : Union européenne, sans partage commercial). 5. **Suppression** du compte et des données (0 : impossible ; 2 : simple). 6. **Contenu** (0 : promesses, classements ; 2 : conseils équilibrés, sans objectif imposé). Total sur 12 ; on ne recommande pas une application qui a 0 à l'un des critères 3, 4 ou 6.

À vous de jouer – Exercice d'application 21.60

Une application gratuite de suivi alimentaire demande, à l'installation, l'accès : a) à l'appareil photo ; b) à la localisation précise en permanence ; c) aux contacts ; d) au micro ; e) aux données de pas du téléphone. Pour une patiente qui veut photographier ses repas et suivre son activité, dites quelles autorisations accepter et lesquelles refuser.

Corrigé

Accepter : **a** (photos des repas : c'est l'usage prévu) et **e** (pas : utile au suivi de l'activité). Refuser : **b** (la localisation permanente révèle le domicile, le travail, les habitudes ; elle n'est pas utile à un journal alimentaire), **c** (les contacts appartiennent à d'autres personnes), **d** (aucune fonction de l'application ne justifie le micro). Règle générale : une autorisation se justifie par une fonction que l'on utilise ; sinon on la refuse, et on vérifie de nouveau les réglages après chaque mise à jour.

À vous de jouer – Exercice d'application 21.61

Un patient suivi pour un diabète veut vous envoyer chaque semaine des captures d'écran de son lecteur de glycémie par une messagerie grand public de son téléphone. Que lui répondez-vous ? Proposez deux solutions.

Corrigé

On le remercie de son implication, puis on explique que ces données de santé seraient stockées sur des serveurs non maîtrisés, dans le téléphone de la diététicienne, et parfois dans des sauvegardes automatiques. Solutions : 1. Utiliser la **messagerie de Mon espace santé**, dans laquelle un professionnel peut écrire au patient depuis sa messagerie sécurisée de santé. 2. Utiliser la **plateforme de partage** proposée par le fabricant du lecteur ou par l'équipe de diabétologie, si la diététicienne y a un accès professionnel. À défaut, le patient apporte son carnet ou son lecteur en consultation.

À vous de jouer – Exercice d'application 21.62

Une salle de sport partenaire d'un programme de prévention de l'obésité propose de prêter des bracelets connectés aux participants. Listez quatre questions à poser avant d'accepter.

Corrigé

1. **Où vont les données** (serveurs, pays) et qui y a accès (la salle, le fabricant, des partenaires commerciaux) ? 2. **Que deviennent les données** à la fin du programme : sont-elles supprimées ? 3. Les participants peuvent-ils **refuser** sans être exclus du programme, et ont-ils été informés clairement ? 4. Comment le bracelet est-il **remis à zéro** entre deux participants, pour que le suivant ne voie pas les données du précédent ? On peut ajouter : le compte est-il créé avec un pseudonyme ? La mise à jour du bracelet est-elle assurée ?

21.4.2 Le télétravail

Matériel fourni par la structure, connexion sécurisée (réseau privé virtuel), pas d'impression de documents sensibles à domicile, attention aux écrans visibles et aux conversations entendues.

Le travail à distance et en déplacement

Le diététicien travaille souvent hors de son bureau : télétravail, visites à domicile, interventions dans des écoles ou des structures partenaires, consultations dans plusieurs lieux. Chaque situation expose les données à de nouveaux risques.

Situation · Risque · Bonne pratique

Télétravail à domicile — *Risque :* Ordinateur familial partagé, enfants, documents imprimés ; *Bonne pratique :* Matériel professionnel réservé au travail, session verrouillée, pas d'impression de dossiers à domicile

Wi-Fi public (gare, café, hôtel) — *Risque :* Réseau non protégé, faux réseau portant le nom du lieu ; *Bonne pratique :* Partage de connexion de son téléphone, ou accès sécurisé fourni par la structure (réseau privé virtuel)

Train, salle d'attente — *Risque :* Écran visible, conversation entendue ; *Bonne pratique :* Filtre de confidentialité, pas de nom de patient à voix haute

Visite à domicile — *Risque :* Feuilles de tournée oubliées, téléphone perdu ; *Bonne pratique :* Documents dans une pochette fermée, téléphone verrouillé et chiffré

Voiture — *Risque :* Vol du matériel laissé à l'intérieur ; *Bonne pratique :* Ne jamais laisser le matériel seul ; à défaut, coffre fermé, hors de la vue, avant d'arriver

Intervention chez un partenaire — *Risque :* Clé USB branchée sur un poste inconnu ; *Bonne pratique :* Présentation envoyée à l'avance ou ouverte depuis un espace sécurisé

Définition – Réseau privé virtuel (VPN)

Connexion **chiffrée** entre l'appareil et le réseau de la structure, à travers Internet. Elle permet de travailler à distance comme si l'on était au bureau, sans que les échanges puissent être lus sur le réseau utilisé (Wi-Fi public, box familiale).

À vous de jouer – Exercice d'application 21.63

Rédigez cinq règles d'une charte de télétravail pour les diététiciennes d'un réseau de santé.

Corrigé

1. « Je travaille uniquement sur le **matériel professionnel** fourni, chiffré et mis à jour ; personne d'autre ne l'utilise. » 2. « Je me connecte aux outils du réseau par l'**accès sécurisé** et la double authentification ; jamais par un Wi-Fi public sans protection. » 3. « Je **verrouille** ma session dès que je m'éloigne, même chez moi. » 4. « Je **n'imprime pas** de dossier à domicile et je ne copie aucun dossier sur un support personnel. » 5. « Je passe mes appels concernant des patients **à l'abri des oreilles** ; en cas de perte ou de vol, je préviens immédiatement le référent. »

Le téléphone professionnel

Le téléphone est devenu un outil de travail complet : messagerie, agenda, photos, applications de santé, e-CPS. Perdu ou volé, il ouvre la porte à beaucoup de données.

Règle · Pourquoi

Code de verrouillage (6 chiffres au moins, ou biométrie) et verrouillage automatique — *Pourquoi :* Un téléphone trouvé ne doit pas s'ouvrir

Chiffrement activé (par défaut sur les téléphones récents protégés par un code) — *Pourquoi :* Les données restent illisibles

Mises à jour du système et des applications — *Pourquoi :* Les failles des téléphones sont aussi exploitées

Applications installées seulement depuis les magasins officiels — *Pourquoi :* Les applications piégées circulent hors des magasins

Pas de photo de dossier, de plateau nominatif ou de liste de régimes dans la galerie personnelle — *Pourquoi :* Les photos se synchronisent souvent vers un stockage personnel

Fonction de localisation et d'effacement à distance activée — *Pourquoi :* En cas de perte, on peut effacer le téléphone

Messagerie grand public évitée pour les données de santé — *Pourquoi :* Groupes non maîtrisés, sauvegardes hors de contrôle

À vous de jouer – Exercice d'application 21.64

Une diététicienne a perdu son téléphone professionnel (verrouillé par un code à 4 chiffres « 1234 ») dans un bus. Il contient sa messagerie, l'application e-CPS et des photos de menus adaptés de patients. Que doit-elle faire, dans l'ordre ?

Corrigé

1. **Prévenir** immédiatement le référent ou le service informatique. 2. **Effacer à distance** le téléphone (et le localiser si possible). 3. **Changer** le mot de passe de la messagerie et faire révoquer ou réinitialiser l'e-CPS selon la procédure de l'Agence du numérique en santé. 4. Faire **bloquer la ligne** par l'opérateur. 5. Avec le DPO, **analyser** la violation : le code « 1234 » est très faible, les photos de patients ont pu être consultées : inscription au registre et notification à la CNIL si le risque est réel. 6. **Porter plainte** ou déclarer la perte. Pour l'avenir : code plus long, pas de photos nominatives dans le téléphone.

À vous de jouer – Exercice d'application 21.65

Dans le train, une diététicienne en télétravail veut relire des bilans sur son ordinateur professionnel. Le Wi-Fi gratuit du train est disponible. Listez quatre précautions.

Corrigé

1. Se connecter par le **partage de connexion** de son téléphone professionnel ou, si le Wi-Fi public est utilisé, toujours par le **VPN** de la structure. 2. Poser un **filtre de confidentialité** sur l'écran et s'asseoir dos à une paroi : un voisin peut lire. 3. Ne pas téléphoner à un patient ou parler d'un dossier à voix haute. 4. **Verrouiller** le poste à chaque déplacement, même de quelques secondes, et ne jamais laisser l'ordinateur sans surveillance. Si le travail n'est pas urgent, le plus sûr est de le faire au bureau ou à domicile.

À vous de jouer – Exercice d'application 21.66

Une diététicienne réalise des consultations à distance depuis son domicile. Rédigez cinq règles pour qu'elles restent confidentielles et sécurisées.

Corrigé

1. Utiliser un **outil de vidéotransmission** sécurisé, choisi selon les recommandations de l'Agence du numérique en santé, jamais un outil grand public non autorisé. 2. Envoyer un **lien unique** pour chaque rendez-vous et activer la salle d'attente. 3. Travailler dans une **pièce fermée**, sans autre personne, avec un casque. 4. Ne pas **enregistrer** la séance ; noter le compte rendu dans le dossier du patient. 5. **Vérifier l'identité** du patient au début, et lui demander s'il est seul ou s'il accepte la présence d'un proche.

21.4.3 La sécurité dans les petites structures

Sans service informatique, une association peut s'appuyer sur les guides de l'ANSSI et de *cybermalveillance.gouv.fr*, désigner un référent, faire un diagnostic simple et prévoir un plan de continuité (que faire si l'ordinateur est inutilisable ? liste papier des inscrits, contacts des partenaires).

La sécurité d'une diététicienne libérale, pas à pas

Une diététicienne libérale est seule responsable du traitement des données de ses patients. Elle n'a pas de service informatique, mais elle peut atteindre un bon niveau de sécurité avec des mesures simples, peu coûteuses, mises en place progressivement.

Méthode pas à pas – Un plan en trois temps

Cette semaine (sans coût) : double authentification sur la messagerie et le logiciel ; mises à jour automatiques ; verrouillage de la session après quelques minutes ; chiffrement de l'ordinateur portable et du téléphone.

Ce mois-ci : gestionnaire de mots de passe ; un mot de passe différent par service ; sauvegardes selon la règle 3-2-1, avec un disque débranché et une copie externalisée chiffrée ; premier test de restauration.

Cette année : logiciel de suivi hébergé chez un hébergeur certifié HDS ; registre des traitements ; procédure écrite en cas d'incident (qui appeler, 72 heures) ; formation courte ; vérification annuelle de l'ensemble.

Exemple – Calcul détaillé : le coût annuel de la sécurité

Coûts fictifs : gestionnaire de mots de passe 3 € par mois ; sauvegarde externalisée chiffrée 8 € par mois ; deux disques externes à 70 € renouvelés tous les 3 ans ; logiciel hébergé HDS 30 € par mois.

- Gestionnaire : 3 × 12 = 36 € ; sauvegarde : 8 × 12 = 96 € ; disques : 2 × 70 / 3 ≈ 46,67 € ; logiciel : 30 × 12 = 360 €.
- Total : **538,67 € par an**. Pour 900 consultations par an, cela représente 538,67 / 900 ≈ **0,60 € par consultation**.

À vous de jouer – Exercice d'application 21.67

Une diététicienne libérale réalise 1 200 consultations par an. Elle choisit un logiciel HDS à 25 € par mois, un gestionnaire à 3 € par mois et une sauvegarde externalisée à 6 € par mois. Calculez le coût annuel et le coût par consultation.

Corrigé

Logiciel : 25 × 12 = 300 € ; gestionnaire : 3 × 12 = 36 € ; sauvegarde : 6 × 12 = 72 €. Total : **408 € par an**, soit 408 / 1 200 = **0,34 € par consultation**.

Les associations et les petites structures

Une association de prévention, un centre social, une épicerie solidaire traitent souvent des données sensibles (situations sociales, allergies, santé) avec des moyens très limités et des bénévoles qui changent. Quelques choix d'organisation font une grande différence.

Difficulté · Réponse simple

Pas de service informatique — *Réponse simple :* Un **référent** désigné (salarié ou bénévole), un prestataire de proximité trouvé grâce à *cybermalveillance.gouv.fr*

Bénévoles nombreux et changeants — *Réponse simple :* Comptes nominatifs, droits limités, procédure d'arrivée et de départ

Ordinateurs personnels des bénévoles — *Réponse simple :* Outils en ligne de l'association avec double authentification ; aucune copie de fichier sur un ordinateur personnel

Fichiers partagés par lien public — *Réponse simple :* Partage nominatif, tableur réduit au nécessaire

Pas de budget — *Réponse simple :* Mesures gratuites d'abord (mises à jour, double authentification, sauvegarde sur un disque débranché)

Pas de plan en cas de panne — *Réponse simple :* Liste papier des inscrits et des contacts des partenaires, rangée et mise à jour

Exemple – L'autodiagnostic en dix questions

cybermalveillance.gouv.fr et l'ANSSI proposent des questionnaires simples pour faire le point. Une association peut se poser dix questions : Qui est notre référent ? Nos mises à jour sont-elles automatiques ? Avons-nous des comptes partagés ? La double authentification est-elle activée ? Où sont nos sauvegardes, et les avons-nous testées ? Nos ordinateurs portables sont-ils chiffrés ? Qui a accès à quels fichiers ? Que faisons-nous en cas d'attaque ? Nos bénévoles ont-ils été sensibilisés ? Notre prestataire est-il encadré par un contrat ? Chaque « non » devient une action.

À vous de jouer – Exercice d'application 21.68

Une épicerie solidaire tient le fichier de ses 180 bénéficiaires (situation familiale, revenus, allergies) sur l'ordinateur personnel de sa présidente. Proposez quatre mesures prioritaires.

Corrigé

1. **Déplacer** le fichier vers un outil de l'association (espace en ligne professionnel avec double authentification), et le supprimer de l'ordinateur personnel. 2. **Réduire** le fichier au nécessaire (minimisation : les revenus détaillés sont-ils utiles une fois l'accès validé ?). 3. **Sauvegarder** selon la règle 3-2-1, avec une copie déconnectée. 4. **Limiter l'accès** aux bénévoles qui en ont besoin, avec des comptes nominatifs, et désigner un référent. On peut aussi demander un diagnostic à un prestataire référencé par *cybermalveillance.gouv.fr*.

Coter les risques simplement

Les petites structures n'ont pas besoin d'une méthode lourde pour choisir leurs priorités. Une cotation simple suffit souvent : pour chaque scénario, on estime la **vraisemblance** et la **gravité**, puis on traite d'abord les risques les plus élevés.

Note · Vraisemblance · Gravité

1 — *Vraisemblance :* Très peu probable ; *Gravité :* Conséquences minimes, vite réparées

2 — *Vraisemblance :* Possible ; *Gravité :* Gêne réelle, réparable

3 — *Vraisemblance :* Probable ; *Gravité :* Conséquences importantes pour les personnes ou l'activité

4 — *Vraisemblance :* Très probable, déjà arrivé ; *Gravité :* Conséquences graves ou durables (santé, données de santé divulguées)

Niveau de risque = vraisemblance × gravité, de 1 à 16. Repères : 1 à 3 faible ; 4 à 7 modéré ; 8 à 11 élevé ; 12 à 16 critique.

Exemple – Calcul détaillé : trois scénarios dans une association

- Hameçonnage de la messagerie du président : vraisemblance 3, gravité 3 : **9** (élevé). Avec la double authentification, la vraisemblance passe à 1 : **3** (faible).
- Perte de l'ordinateur portable de la trésorière, non chiffré : 2 × 3 = **6** (modéré). Avec le chiffrement, la gravité passe à 1 : **2**.
- Panne du disque qui contient le fichier des adhérents, sans sauvegarde : 2 × 4 = **8** (élevé). Avec une sauvegarde 3-2-1 testée, la gravité passe à 1 : **2**.
- Somme des niveaux : 9 + 6 + 8 = 23 avant ; 3 + 2 + 2 = 7 après, soit une baisse de (23 − 7) / 23 × 100 ≈ **69,6 %** (indicateur grossier, utile pour montrer l'effet d'un plan).

À vous de jouer – Exercice d'application 21.69

Une mesure réduit-elle la vraisemblance ou la gravité ? a) chiffrer les portables ; b) former l'équipe à l'hameçonnage ; c) sauvegarde déconnectée ; d) mises à jour automatiques ; e) liste papier de secours.

Corrigé

a) **Gravité** (le vol reste possible, mais les données sont illisibles). b) **Vraisemblance**. c) **Gravité** (on peut restaurer). d) **Vraisemblance** (moins de failles exploitables). e) **Gravité** (l'activité continue pendant la panne).

Le matériel en fin de vie

Un ordinateur, un téléphone, une imprimante multifonction ou une clé USB qui quittent la structure (don, revente, recyclage, retour au loueur) emportent souvent des données. La suppression des fichiers ou le formatage rapide ne les effacent pas vraiment.

Méthode pas à pas – Avant qu'un appareil quitte la structure

1. Récupérer les données utiles et vérifier qu'elles sont bien sauvegardées ailleurs.

2. Déconnecter l'appareil des comptes (messagerie, logiciel, e-CPS, licences) et le retirer de l'inventaire.

3. Effacer de façon sûre avec un outil d'effacement reconnu, ou réinitialiser complètement un téléphone chiffré.

4. Détruire le disque s'il ne peut pas être effacé (appareil en panne), par un prestataire qui délivre un certificat.

5. Tracer : une attestation par appareil (numéro de série, date, méthode, nom de la personne).

Attention – Les appareils oubliés

Les **photocopieurs et imprimantes multifonctions** ont souvent un disque qui garde une copie des documents numérisés ou imprimés ; les **téléphones** contiennent messages et photos ; les **clés USB** et **cartes mémoire** des balances ou appareils photo aussi. Ils suivent la même procédure.

À vous de jouer – Exercice d'application 21.70

Un service de restauration rend au loueur son photocopieur multifonction, qui a servi à numériser les fiches de régimes des patients pendant quatre ans. Que faut-il demander ?

Corrigé

Demander au loueur l'**effacement sûr** ou la **destruction** du disque interne avant l'enlèvement, avec une **attestation** écrite (numéro de série, méthode, date). Vérifier que cette obligation figure dans le contrat de location (et l'y ajouter pour le prochain). En attendant, ne pas laisser partir l'appareil sans cette garantie : le disque contient des données de santé de nombreux patients.

À vous de jouer – Exercice d'application 21.71

Une diététicienne libérale (données fictives) équipe son cabinet : antivirus 60 € par an, sauvegarde en ligne 8 € par mois, gestionnaire de mots de passe 3 € par mois,

disque externe 90 € (compté sur un an). Elle réalise 1 200 consultations par an à 45 €. a) Calculez le coût annuel et le coût par consultation. b) Une attaque fermerait le cabinet 5 jours de 6 consultations et coûterait 800 € de remise en état : comparez.

Corrigé

a) 60 + 8 × 12 + 3 × 12 + 90 = 60 + 96 + 36 + 90 = **282 €** par an ; 282 / 1 200 ≈ **0,24 €** par consultation. b) Perte de recettes : 5 × 6 × 45 = 1 350 € ; avec la remise en état : 1 350 + 800 = **2 150 €**. Les mesures coûtent environ 13 % d'un seul incident, sans compter le temps perdu, la perte de confiance des patients et une éventuelle sanction. L'argument financier aide à convaincre, mais l'essentiel est la protection des patients.

À vous de jouer – Exercice d'application 21.72

Un assureur propose à un petit centre de santé un contrat « cyber ». Citez trois points à vérifier dans le contrat et une obligation à respecter après une attaque pour être indemnisé.

Corrigé

Points : 1. Ce qui est **couvert** (frais d'experts, restauration des données, perte d'exploitation, frais de notification, responsabilité envers les patients). 2. Les **conditions** demandées (sauvegardes déconnectées, double authentification, mises à jour) : si elles ne sont pas respectées, l'assureur peut refuser. 3. La **hotline** d'assistance et ses horaires. Obligation : depuis la loi du 24 janvier 2023 d'orientation et de programmation du ministère de l'Intérieur, l'indemnisation d'une atteinte à un système d'information est subordonnée au **dépôt de plainte** dans les **72 heures** après la connaissance de l'attaque.

Point d'étape – Je teste mes acquis – Objets connectés, télétravail et petites structures

Répondez sans regarder le cours, puis corrigez-vous. Comptez 1 point par réponse juste.

1. Quelle règle suivre pour accepter une autorisation demandée par une application ?
2. Pourquoi refuser la localisation permanente à une application de journal alimentaire ?
3. Citez deux précautions pour travailler dans un train.
4. Citez deux règles pour une consultation à distance.
5. Quelle condition la loi de 2023 fixe-t-elle pour être indemnisé par une assurance après une attaque ?
6. Comment calcule-t-on un score de risque simple ?
7. Pourquoi l'arrivée et le départ d'un professionnel sont-ils des moments à risque ?

Corrigé – Point d'étape – Objets connectés, télétravail et petites structures

1. L'accepter seulement si elle sert une fonction réellement utilisée.
2. Elle révèle le domicile, le travail et les habitudes, sans être utile au suivi alimentaire.
3. VPN ou partage de connexion ; filtre de confidentialité ; verrouillage à chaque déplacement ; pas d'échange à voix haute.
4. Un lien unique par rendez-vous avec salle d'attente ; pièce fermée et casque ; pas d'enregistrement ; vérification de l'identité.
5. Porter plainte dans les 72 heures après la connaissance de l'attaque.
6. Vraisemblance × gravité, chacune notée sur une échelle (par exemple de 1 à 4).
7. Comptes non créés, prêtés ou non désactivés : la traçabilité et la confidentialité sont menacées.

Point d'étape – Je teste mes acquis – Objets connectés, travail à distance, petites structures

Répondez sans regarder le cours, puis corrigez-vous. Comptez 1 point par réponse juste.

1. Citez trois risques d'un objet connecté de santé.
2. Combien de mesures par an enregistre un capteur qui mesure toutes les 5 minutes ?
3. Citez trois questions à poser avant de recommander une application.
4. Qu'est-ce qu'un réseau privé virtuel ?
5. Que faire en premier si l'on perd son téléphone professionnel ?
6. Citez trois mesures gratuites pour une diététicienne libérale.
7. Comment calcule-t-on un niveau de risque simple ?
8. Le chiffrement réduit-il la vraisemblance ou la gravité d'un vol ?
9. Pourquoi faut-il s'occuper du disque d'un photocopieur rendu au loueur ?

Corrigé – Point d'étape – Objets connectés, travail à distance, petites structures

1. Collecte excessive, mot de passe par défaut, absence de mises à jour (ou hébergement inconnu, réutilisation commerciale).
2. 12 × 24 × 365 = 105 120 mesures.
3. Qui l'édite ? D'où viennent les données nutritionnelles ? Où sont hébergées les données et sont-elles partagées ?
4. Une connexion chiffrée entre l'appareil et le réseau de la structure, à travers Internet.
5. Prévenir le référent et effacer le téléphone à distance.
6. Double authentification, mises à jour automatiques, chiffrement de l'ordinateur (ou verrouillage de la session).
7. Vraisemblance × gravité, chacune notée de 1 à 4.

8. La gravité.

9. Il garde une copie des documents numérisés, dont des données de santé.

21.5 Pour aller plus loin – niveau Licence 3

Pour aller plus loin – niveau L3 – Analyse de risques

Les méthodes d'analyse de risques (comme EBIOS Risk Manager, de l'ANSSI) identifient les biens à protéger, les menaces, les scénarios et les mesures, en fonction de la gravité et de la vraisemblance des événements redoutés.

Pour aller plus loin – niveau L3 – Cybersécurité et facteur humain

La plupart des attaques exploitent une erreur humaine ; la culture de sécurité (formation, signalement sans sanction des erreurs, exercices) est aussi importante que les outils techniques.

Pour aller plus loin – niveau L3 – La méthode EBIOS Risk Manager

Publiée par l'ANSSI en 2018, la méthode **EBIOS Risk Manager** (Expression des besoins et identification des objectifs de sécurité) aide une organisation à construire sa sécurité à partir de ses risques réels. Elle se déroule en **cinq ateliers** : 1) le socle de sécurité (les missions, les biens à protéger, les événements redoutés et les règles déjà appliquées) ; 2) les sources de risque (qui pourrait attaquer, et pourquoi : gain financier, idéologie, vengeance) ; 3) les scénarios stratégiques (par quel chemin, souvent un partenaire ou un prestataire) ; 4) les scénarios opérationnels (les modes opératoires techniques) ; 5) le traitement du risque (mesures, risques résiduels acceptés, plan de suivi).

Pour l'étudiant. Vous n'appliquerez pas EBIOS seul, mais un établissement peut vous demander de décrire les **missions** et les **biens essentiels** d'un service diététique (régimes, bilans, commandes) et les conséquences de leur perte : c'est l'apport du métier au premier atelier.

À vous de jouer – Exercice d'application 21.73

Pour le service de restauration d'un hôpital, listez trois biens essentiels et, pour chacun, un événement redouté et sa conséquence pour les patients.

Corrigé

1. **Liste des régimes, textures et allergies** : modification non autorisée : repas inadapté, réaction allergique, fausse route. 2. **Commandes de repas par service** : indisponibilité un matin : repas non servis ou servis en retard, patients diabétiques en hypoglycémie. 3. **Dossiers nutritionnels** : divulgation : atteinte au secret, perte de confiance, chantage possible.

Pour aller plus loin – niveau L3 – Le facteur humain et la culture juste

Les recherches sur la sécurité, venues de l'aviation et de la santé (gestion des risques associés aux soins), montrent qu'une organisation apprend mieux de ses erreurs quand elle distingue l'**erreur** (involontaire), la **prise de risque** (un raccourci devenu habituel) et l'**acte délibéré** : c'est la **culture juste**. L'erreur appelle un soutien et une amélioration du système, la prise de risque un accompagnement, et seul l'acte délibéré justifie une sanction. En cybersécurité, cela se traduit par le **signalement sans sanction** des clics et des erreurs d'envoi, des outils qui rendent le bon geste facile (gestionnaire de mots de passe, double authentification simple) et une attention aux causes d'organisation (charge de travail, urgence permanente, postes partagés).

Pour l'étudiant. Devant le jury, présentez un incident en cherchant ses **causes** plutôt qu'un fautif : c'est le signe d'une posture professionnelle mûre.

À vous de jouer – Exercice d'application 21.74

Classez selon la culture juste (erreur, prise de risque, acte délibéré) : a) une diététicienne clique sur un message très bien imité ; b) un cuisinier note le mot de passe partagé sur le réfrigérateur « comme tout le monde » ; c) un agent copie le fichier des patients pour le vendre.

Corrigé

a) **Erreur** : soutien, signalement valorisé, double authentification. b) **Prise de risque** devenue habitude collective : expliquer, supprimer le compte partagé, fournir un moyen de connexion simple. c) **Acte délibéré** : sanction disciplinaire et plainte, en plus de la notification de la violation.

Pour aller plus loin – niveau L3 – L'économie des rançongiciels

Les rançongiciels sont devenus une **industrie** : certains groupes développent le programme et le louent à des « affiliés » qui mènent les attaques, en partageant les rançons (modèle dit du rançongiciel en tant que service). D'autres revendent des accès déjà obtenus (comptes volés, failles). Cette organisation explique la multiplication des attaques contre des cibles moyennes ou petites, peu protégées. Les autorités de nombreux pays recommandent de **ne pas payer**, et les opérations de police internationales démantèlent régulièrement des infrastructures, sans faire disparaître le phénomène. Pour une structure de santé, la meilleure réponse économique

reste la **résilience** : sauvegardes restaurables, continuité préparée, détection rapide.

Pour l'étudiant. Ce modèle montre pourquoi une petite structure ne peut pas se dire « trop petite pour intéresser les attaquants » : les attaques sont souvent automatiques et opportunistes.

À vous de jouer – Exercice d'application 21.75

Pour un service diététique, on note chaque risque de 1 à 4 en vraisemblance (V) et en gravité (G), et on calcule V × G. Hameçonnage : V 4, G 3. Rançongiciel : V 3, G 4. Vol d'un portable : V 2, G 3. Erreur de destinataire : V 3, G 2. Incendie du local serveur : V 1, G 4. Classez les risques et commentez les égalités.

Corrigé

Scores : hameçonnage 4 × 3 = **12** ; rançongiciel 3 × 4 = **12** ; vol du portable 2 × 3 = **6** ; erreur de destinataire 3 × 2 = **6** ; incendie 1 × 4 = **4**. Les deux premiers sont prioritaires. À score égal, on traite souvent d'abord le risque le plus **grave** (le rançongiciel, qui arrête tout), mais les deux sont liés : l'hameçonnage est souvent la porte d'entrée du rançongiciel, donc la formation et la double authentification réduisent les deux. L'incendie a un score faible mais une gravité maximale : on ne l'ignore pas, la sauvegarde hors site le couvre.

À vous de jouer – Exercice d'application 21.76

Le référent sécurité d'une clinique suit trois indicateurs : 46 postes à jour sur 52 ; 31 comptes avec double authentification sur 40 ; 3 tests de restauration réussis sur 4 prévus dans l'année. Calculez les taux et proposez une priorité.

Corrigé

Postes à jour : 46 / 52 ≈ **88,5 %**. Double authentification : 31 / 40 = **77,5 %**. Tests de restauration : 3 / 4 = **75 %**. Priorité : les **9 comptes** sans double authentification, surtout s'ils ont accès aux données de santé ou à la messagerie : un mot de passe volé suffit alors pour entrer. Ensuite, comprendre pourquoi 6 postes ne sont pas à jour (anciens matériels ? logiciel qui bloque ?) et refaire le test de restauration manqué.

NIVEAU BTS – EXIGIBLE

21.6 Lien avec les compétences : situations professionnelles

Situation bc1 – Le cabinet libéral

La diététicienne libérale chiffre son ordinateur, utilise un logiciel métier avec hébergement certifié et sauvegarde ses dossiers ; elle échange avec les médecins par messagerie sécurisée.

Situation bc2 – La cuisine centrale

Un rançongiciel bloque le logiciel de commande : grâce à des sauvegardes hors ligne et à une procédure papier, les repas sont servis.

Situation bc3 – L'accueil du centre social

L'ordinateur de l'accueil, utilisé par plusieurs personnes, dispose de sessions personnelles et se verrouille automatiquement.

Méthode pas à pas – Présenter le volet cybersécurité d'un projet à l'oral de l'épreuve E5

1. Situer : quelles données le projet utilise (identité, poids, régime, photos) et quels outils (tablette, tableur, application, messagerie).

2. Évaluer : qu'est-ce qui pourrait arriver (perte, vol, envoi au mauvais destinataire, piratage) et avec quelles conséquences pour les personnes.

3. Protéger : trois ou quatre mesures concrètes, adaptées et peu coûteuses (comptes personnels, chiffrement, sauvegarde, données réduites au nécessaire).

4. Réagir : qui prévenir et quoi faire si un incident survient.

5. Justifier : relier chaque mesure à une règle (RGPD, secret professionnel, recommandations de l'ANSSI ou de *cybermalveillance.gouv.fr*).

À vous de jouer – Exercice d'application 21.77

Appliquez la méthode à ce projet : une étudiante organise six ateliers « Petit-déjeuner équilibré » dans une école ; elle recueille, avec l'accord des parents, le prénom, l'âge et un questionnaire de petit-déjeuner de 48 enfants, saisis dans un tableur sur son ordinateur.

Corrigé

Situer : données de mineurs (prénom, âge, habitudes alimentaires), tableur, ordinateur personnel. **Évaluer** : vol ou perte de l'ordinateur, partage du fichier par erreur, conservation trop longue. **Protéger** : remplacer les prénoms par un **numéro** dès la saisie (la liste de correspondance reste à l'école) ; ordinateur avec mot de passe solide et **disque chiffré** ; une sauvegarde chiffrée ; aucune photo d'enfant ; suppression du fichier après la soutenance. **Réagir** : en cas de perte, prévenir la tutrice et l'école, qui évaluent la violation. **Justifier** : principe de **minimisation** et obligation de sécurité du RGPD ; recommandations de *cybermalveillance.gouv.fr* sur les mots de passe et les sauvegardes.

Cas guidés : appliquer le chapitre à des situations professionnelles

Les cas guidés qui suivent appliquent le chapitre à des situations que vous pourrez rencontrer en stage ou en poste : une cuisine hospitalière, un cabinet libéral, un projet de prévention, un EHPAD, un service de soins à domicile, une cuisine centrale scolaire. Chaque cas est découpé en étapes. Essayez de répondre à chaque étape avant de lire la réponse commentée. Les structures, les personnes et les chiffres sont **fictifs** ; les textes cités sont réels et datés.

Cas guidé 1 : un rançongiciel un samedi matin dans la cuisine d'un hôpital

Ce cas guidé mobilise les objectifs de sécurité, le mode dégradé, les calculs d'impact, les déclarations et le retour d'expérience.

Document – La situation

Le centre hospitalier de la vallée du Lison (fictif) sert chaque jour **820 repas** aux patients, dont **303** avec un régime, une texture ou une allergie. Le **samedi à 4 h**, un rançongiciel chiffre le serveur qui héberge le logiciel de restauration. Les agents arrivent à 5 h 30 et ne peuvent plus imprimer les fiches de production. La liste papier des régimes est imprimée chaque jour à 14 h ; depuis celle du vendredi, **18 modifications** ont été saisies. Le logiciel revient le lundi soir. Deux diététiciennes, rappelées, ont travaillé chacune **5 heures** de plus le samedi et le dimanche ; coût horaire chargé **31 €**.

Étape 1 – Identifier ce qui est menacé

Réponse commentée – Étape 1

- **Disponibilité** : plus de fiches de production ni de commandes ; les repas doivent pourtant partir à l'heure.
- **Intégrité** : la liste papier de vendredi 14 h ne contient pas les 18 dernières modifications ; un patient pourrait recevoir un repas inadapté.
- **Confidentialité** : les attaquants ont peut-être copié les données du serveur (régimes, allergies, noms des patients) avant de les chiffrer ; il faut le vérifier.

Étape 2 – Calculer l'impact

Réponse commentée – Étape 2

- Part des repas adaptés : 303 / 820 × 100 ≈ **37,0 %**.
- Part des repas adaptés touchés par une modification récente : 18 / 303 × 100 ≈ **5,9 %** ; ce sont les plus à risque d'erreur.
- Heures supplémentaires : 2 diététiciennes × 5 h × 2 jours = **20 h** ; 20 × 31 € = **620 €**.
- Ce coût ne compte ni l'intervention du prestataire, ni les repas jetés, ni les conséquences d'une éventuelle erreur pour un patient.

Étape 3 – Organiser le mode dégradé

Réponse commentée – Étape 3

- La cheffe de cuisine déclenche la **fiche réflexe** et sort le classeur du mode dégradé : liste de vendredi 14 h, bons de production papier.
- Les diététiciennes appellent chaque service de soins pour **reprendre les 18 modifications** et les patients entrés depuis vendredi ; chaque correction est datée et signée sur la liste.
- Les plateaux adaptés sont **contrôlés à deux** (agent et diététicienne) et étiquetés.
- Une **main courante** papier note les faits, les heures et les décisions.

Étape 4 – Déclarer

Réponse commentée – Étape 4

- **Direction**, astreinte informatique, **DPO** : immédiatement.
- **CERT Santé** et ARS : signalement de l'incident grave de sécurité, selon le dispositif applicable aux établissements de santé (chapitre 20).
- **CNIL** : si l'analyse montre une perte de disponibilité durable ou une copie des données, notification dans les **72 heures** après que l'hôpital en a eu connaissance (au plus tard mardi vers 5 h 30 si l'on retient l'heure de découverte).
- **Plainte** : dans les 72 heures si l'hôpital veut être indemnisé par son assurance (loi du 24 janvier 2023).

Étape 5 – Tirer les leçons

Réponse commentée – Étape 5

- Ce qui a fonctionné : liste quotidienne imprimée, mobilisation des diététiciennes.
- Ce qui manquait : les modifications de l'après-midi et du soir (une **impression à 20 h** ou un **export automatique** chiffré la nuit réduirait l'écart) ; une procédure pour joindre rapidement les services le week-end.
- Actions : export automatique, numéro unique d'astreinte affiché en cuisine, exercice annuel « logiciel indisponible un samedi à 5 h 30 ».

Cas guidé 2 : la messagerie piratée d'une diététicienne libérale

Ce cas guidé mobilise l'hameçonnage, la réaction à un incident, la notification et la communication aux patients.

Document – La situation

Mme Fabre, diététicienne libérale (fictive), reçoit un lundi un message « Votre boîte de réception est pleine, validez votre compte ». Elle saisit son mot de passe. Le mardi, plusieurs patients l'appellent : ils ont reçu de sa part un message « Facture impayée » avec un lien. Sa boîte contient **640 contacts** (patients, médecins,

fournisseurs) et les comptes rendus envoyés depuis trois ans. Elle utilise le même mot de passe pour son logiciel de suivi des patients. La double authentification n'est pas activée.

Étape 1 – Comprendre ce qui s'est passé

Réponse commentée – Étape 1

- Un **hameçonnage** classique a permis de voler son mot de passe.
- L'attaquant utilise sa boîte pour envoyer des messages piégés à ses contacts, qui lui font confiance.
- Il a pu **lire** les comptes rendus envoyés (données de santé) et peut-être se connecter au **logiciel de suivi**, puisque le mot de passe est le même.

Étape 2 – Agir dans l'heure

Réponse commentée – Étape 2

- Changer le mot de passe de la messagerie **et** du logiciel de suivi, avec deux mots de passe différents, depuis un appareil sûr.
- Activer la **double authentification** partout où c'est possible.
- Vérifier la messagerie : règles de transfert ou de suppression ajoutées, messages envoyés ; fermer les sessions ouvertes.
- Prévenir ses contacts **par un autre canal** si possible (SMS groupé sans liste visible, message sur son site) : « Ne cliquez pas sur le message "Facture impayée" ».

Étape 3 – Décider des déclarations

Réponse commentée – Étape 3

- Mme Fabre est **responsable du traitement**. Un accès non autorisé à une boîte contenant des comptes rendus est une **violation de données de santé** ; le risque est réel.
- Elle notifie la **CNIL** dans les **72 heures** après avoir pris connaissance de l'incident (mardi), en complétant si besoin.
- Si l'analyse montre que des comptes rendus ont été consultés ou transférés, elle **informe** les patients concernés.
- Elle porte plainte et peut se faire aider par *cybermalveillance.gouv.fr* (prestataire de proximité).

Étape 4 – Éviter que cela recommence

Réponse commentée – Étape 4

- Double authentification et gestionnaire de mots de passe (un mot de passe par service).
- Comptes rendus envoyés par la **messagerie sécurisée de santé**, pas par une messagerie ordinaire ; boîte nettoyée des anciens envois.
- Formation courte (SecNumacadémie, fiches de *cybermalveillance.gouv.fr*).

Cas guidé 3 : le volet cybersécurité d'un projet de prévention au collège

Ce cas guidé mobilise la cybersécurité d'un projet d'intervention, comme au temps 1 de l'épreuve E5.

Document – La situation

En stage dans un centre de santé (fictif), vous préparez avec l'infirmière scolaire un projet « Petit-déjeuner et sommeil » pour 4 classes de 5e (environ **104 élèves**). Vous prévoyez : un questionnaire en ligne sur les habitudes, rempli en classe ; des ateliers ; des photos pour l'exposition de fin d'année ; un bilan pour le principal. Vous utiliserez l'ordinateur du centre et votre ordinateur personnel.

Étape 1 – Lister les données et leurs risques

Réponse commentée – Étape 1

- Questionnaire : habitudes alimentaires et de sommeil, qui peuvent révéler une situation familiale ou de santé ; il concerne des **mineurs**.
- Photos : **image** d'élèves mineurs.
- Bilan : résultats par classe, qui ne doivent permettre de reconnaître personne.
- Risques : questionnaire nominatif inutile, données sur un ordinateur personnel non protégé, photos diffusées sans accord.

Étape 2 – Choisir les outils et les règles

Réponse commentée – Étape 2

- Questionnaire **anonyme** (sans nom, sans date de naissance précise), créé avec l'outil validé par l'établissement ou le centre.
- Travail uniquement sur l'**ordinateur du centre**, avec une session personnelle ; aucune copie sur l'ordinateur personnel ou une clé non chiffrée.
- Photos : autorisation écrite des responsables légaux, cadrage sur les plats et les mains si possible, stockage dans l'espace du centre, suppression après l'exposition.
- Envoi du bilan au principal en résultats **agrégés** (aucune case de moins de 5 élèves).

Étape 3 – Prévoir l'incident

Réponse commentée – Étape 3

- Si un fichier est envoyé par erreur ou si un lien circule : prévenir tout de suite la tutrice et le référent du centre, noter l'heure, faire supprimer le fichier, analyser avec le DPO.
- Si le questionnaire en ligne est indisponible le jour J : version **papier** prête.

Étape 4 – Préparer la question du jury

Réponse commentée – Étape 4

Question possible : « Pourquoi ne pas avoir fait un questionnaire nominatif, pour suivre chaque élève ? » Réponse : « Le projet visait à décrire les habitudes d'un groupe et à animer des ateliers, pas à suivre chaque élève. Un questionnaire nominatif aurait collecté des données inutiles sur des mineurs. J'ai appliqué la minimisation, et l'anonymat a sans doute rendu les réponses plus sincères. »

Cas guidé 4 : les tablettes des familles dans un EHPAD

Ce cas guidé mobilise la sécurité des réseaux, les comptes, la messagerie et le droit des résidents.

Document – La situation

Un EHPAD de **86 résidents** (fictif) a reçu trois tablettes pour les appels vidéo avec les familles ; **31 familles** les utilisent. Les tablettes sont connectées au Wi-Fi unique de l'établissement, qui relie aussi les postes de soins. Elles ont un seul compte, dont le mot de passe est connu de tous les animateurs. Une animatrice a installé une application de partage de photos pour envoyer aux familles des photos des repas d'anniversaire. Le dernier rendez-vous vidéo s'est fait sur l'application personnelle d'une aide-soignante.

Étape 1 – Repérer les risques

Réponse commentée – Étape 1

- **Réseau unique** : une tablette compromise pourrait atteindre les postes de soins.
- **Compte partagé** : aucune traçabilité ; les conversations et photos restent accessibles à tous.
- **Application de partage** : photos de résidents (image, et parfois information de santé) sur un service non choisi par l'établissement.
- **Téléphone personnel** : les échanges et numéros des familles se retrouvent sur un appareil privé.

Étape 2 – Calculer l'usage

Réponse commentée – Étape 2

31 / 86 × 100 ≈ **36,0 %** des résidents ont une famille qui utilise les appels vidéo : l'outil est utile et doit être **conservé**, mais sécurisé.

Étape 3 – Proposer une organisation

Réponse commentée – Étape 3

- **Réseau séparé** pour les tablettes (et les visiteurs), isolé des postes de soins.
- Outil de visioconférence **choisi par l'établissement**, lien par rendez-vous ; aucune application personnelle.
- Comptes d'animation **nominatifs** ou session effacée après chaque usage ; verrouillage par code.
- Photos : accord du résident (ou de son représentant), envoi par un canal validé, pas de photo qui montre une texture modifiée ou un traitement ; suppression régulière de la tablette.

Étape 4 – Penser aux résidents

Réponse commentée – Étape 4

Un résident a le droit de **refuser** une photo ou un appel. Les familles qui ne savent pas utiliser la vidéo peuvent être aidées par téléphone, pour ne pas créer d'exclusion numérique.

Cas guidé 5 : un plan de sensibilisation dans un service de soins à domicile

Ce cas guidé mobilise les objectifs, l'exercice simulé, l'intervalle de confiance et la présentation des résultats.

Document – La situation

Un service de soins infirmiers à domicile (fictif) compte **45 salariés**, dont beaucoup utilisent un téléphone professionnel pour les plannings et les transmissions. Après deux téléphones perdus et une messagerie piratée, la direction lance un plan. Un premier exercice d'hameçonnage simulé donne **16 clics** et **3 signalements** ; après trois quarts d'heure sécurité, un second exercice donne **6 clics** et **17 signalements**.

Étape 1 – Fixer des objectifs

Réponse commentée – Étape 1

- « Dans six mois, au moins 30 % des salariés signalent le message d'un exercice simulé. »
- « Dans trois mois, 100 % des téléphones professionnels ont un code de 6 chiffres au moins et l'effacement à distance activé. »
- « Dans six mois, le taux de clic est inférieur à 20 %. »

Étape 2 – Calculer les résultats

Réponse commentée – Étape 2

- Clics : 16 / 45 ≈ **35,6 %**, puis 6 / 45 ≈ **13,3 %**. Signalements : 3 / 45 ≈ **6,7 %**, puis 17 / 45 ≈ **37,8 %**.
- Conditions de l'intervalle de confiance : n = 45 ≥ 30 ; 16 et 29, puis 6 et 39 sont tous supérieurs ou égaux à 5.
- IC à 95 % du premier taux de clic ≈ **[21,6 % ; 49,5 %]** ; du second ≈ **[3,4 % ; 23,3 %]**.

Étape 3 – Interpréter avec prudence

Réponse commentée – Étape 3

- Les intervalles se **chevauchent** (entre 21,6 % et 23,3 %) : avec 45 salariés, on ne peut pas affirmer que la baisse du taux de clic n'est pas due au hasard ou au message choisi.
- Mais tous les indicateurs vont dans le même sens, et

les signalements sont passés de 3 à 17 : la vigilance progresse nettement.
- Les objectifs sur les signalements (37,8 % ≥ 30 %) et le taux de clic (13,3 % < 20 %) sont atteints.

Étape 4 – Présenter les résultats

Réponse commentée – Étape 4

En réunion d'équipe, sans aucun nom : « Vous avez été 17 à signaler le dernier faux message, contre 3 la première fois : merci. Voici les trois indices du message. Prochaine étape : la double authentification sur la messagerie le mois prochain. »

Cas guidé 6 : la panne du prestataire d'une cuisine centrale scolaire

Ce cas guidé mobilise la continuité de l'activité, les allergies, le contrat avec un prestataire et la durée maximale d'interruption.

Document – La situation

La cuisine centrale d'une communauté d'agglomération (fictive) prépare **2 400 repas** par jour pour 18 écoles. **64 enfants** ont un projet d'accueil individualisé (PAI) pour une allergie alimentaire. Les inscriptions et les PAI sont gérés dans un logiciel en ligne loué à un éditeur. Un mardi à 6 h, le logiciel est indisponible : l'éditeur subit une panne majeure, qui dure **2 jours**. Il n'existe aucune liste papier à jour. Pendant ces deux jours, 6 agents ont fait 3 heures supplémentaires par jour (coût horaire chargé 29 €).

Étape 1 – Mesurer l'enjeu

Réponse commentée – Étape 1

- Repas des deux jours : 2 400 × 2 = **4 800**.
- Enfants avec PAI : 64 / 2 400 × 100 ≈ **2,7 %** des repas, mais chaque erreur peut provoquer une **réaction allergique grave**.
- Heures supplémentaires : 6 × 3 × 2 = 36 h ; 36 × 29 € = **1 044 €**.

Étape 2 – Gérer les deux jours

Réponse commentée – Étape 2

- Priorité absolue aux **64 enfants avec PAI** : on reconstitue leur liste avec les écoles (les PAI sont aussi conservés à l'école), on prépare des repas d'éviction ou on demande les paniers repas prévus par les PAI.
- Les effectifs sont estimés avec les écoles par téléphone ; une marge est prévue.
- Les familles sont informées par les écoles.

Étape 3 – Fixer les besoins de continuité

Réponse commentée – Étape 3

- Durée maximale d'interruption acceptable pour la liste des PAI : **zéro** au moment de la production : il faut donc une **copie locale** à jour en permanence.
- Export **quotidien** automatique et chiffré des effectifs et des PAI, plus une liste papier des PAI vérifiée chaque semaine et rangée sous clé.

Étape 4 – Revoir le contrat

Réponse commentée – Étape 4

- Délai de rétablissement garanti et pénalités ; information immédiate en cas d'incident.
- Export de secours automatique ; sauvegardes testées sur une infrastructure distincte ; réversibilité.
- Le prestataire est **sous-traitant** : le contrat respecte l'article 28 du RGPD, et l'hébergement des données de santé (PAI) chez un hébergeur certifié est vérifié.

Cas guidé 7 : des podomètres connectés pour des adolescents

Ce cas guidé mobilise les objets connectés, la minimisation, les mineurs et le choix d'un fournisseur.

Document – La situation

Un réseau de prévention de l'obésité de l'enfant (fictif) veut prêter des podomètres connectés à **40 adolescents** de 12 à 15 ans pendant un programme d'activité physique adaptée de 3 mois. Le fournisseur propose : application gratuite, compte créé avec le nom, la date de naissance, le poids et une photo ; classement hebdomadaire des pas visible par tous les participants ; position GPS « pour mesurer les trajets » ; données hébergées « chez nos partenaires dans le monde ».

Étape 1 – Repérer les données inutiles

Réponse commentée – Étape 1

- Utile : le **nombre de pas** par jour.
- Inutiles ou excessifs : la **photo**, la **date de naissance complète** (l'âge ou la tranche d'âge suffit), le **poids** dans l'application (il est suivi en consultation), la **position GPS**.
- Le **classement** visible par tous expose les jeunes qui marchent peu à la moquerie : il est contraire au but éducatif.

Étape 2 – Mesurer l'ampleur de la collecte

Réponse commentée – Étape 2

Avec une position GPS toutes les 5 minutes, 12 × 24 = 288 positions par jour et par adolescent ; sur 3 mois (environ 91 jours) et 40 adolescents : 288 × 91 × 40 = **1 048 320 positions**, qui révèlent le domicile, le collège et les loisirs de mineurs, sans aucune utilité pour le programme.

Étape 3 – Poser les conditions

Réponse commentée – Étape 3

- Compte avec un **pseudonyme**, sans photo ; GPS **désactivé** ; aucun classement nominatif (un total collectif « la classe a fait le tour de la région » motive sans exposer).
- Hébergement connu, dans l'Union européenne, contrat de sous-traitance, suppression des données à la fin du programme.
- Accord des **responsables légaux** et information adaptée aux adolescents ; participation facultative.
- Analyse d'impact avec le DPO avant le lancement (données de mineurs, objets connectés).

Étape 4 – Prévoir une alternative

Réponse commentée – Étape 4

Un podomètre **simple, non connecté**, et un carnet de pas rempli chaque semaine avec l'éducateur : le but éducatif est atteint sans données en ligne.

Cas guidé 8 : coter les risques d'un centre de santé

Ce cas guidé mobilise la cotation des risques et le choix des priorités.

Document – La situation

Un centre de santé (fictif), où consultent deux diététiciennes, prépare son plan de sécurité. Le référent propose six scénarios, cotés en vraisemblance (V) et gravité (G) de 1 à 4 : A. piratage d'une messagerie (V 3, G 4) ; B. panne de l'agenda en ligne (V 2, G 3) ; C. rançongiciel sur le serveur (V 2, G 4) ; D. erreur d'envoi d'un compte rendu (V 4, G 2) ; E. vol d'un portable non chiffré (V 3, G 3) ; F. dégât des eaux dans le local informatique (V 1, G 3).

Étape 1 – Calculer et classer

Réponse commentée – Étape 1

Niveaux : A 3 × 4 = **12** (critique) ; B **6** (modéré) ; C **8** (élevé) ; D **8** (élevé) ; E **9** (élevé) ; F **3** (faible). Ordre de priorité : **A**, **E**, **C** et **D**, **B**, **F**. Somme : 12 + 6 + 8 + 8 + 9 + 3 = **46**.

Étape 2 – Choisir une mesure par scénario

Réponse commentée – Étape 2

- A : double authentification (vraisemblance 3 − 1) : 1 × 4 = **4**.
- B : export hebdomadaire de l'agenda et contrat de rétablissement (vraisemblance 2 − 1) : **3**.
- C : sauvegarde déconnectée testée et mises à jour (vraisemblance 2 − 1, gravité 4 − 3) : **3**.
- D : messagerie sécurisée et vérification du destinataire (4 − 2) : 2 × 2 = **4**.
- E : chiffrement (gravité 3 − 1) : 3 × 1 = **3**.
- F : copie hors site (gravité 3 − 2) : **2**.

Étape 3 – Mesurer l'effet

Réponse commentée – Étape 3

Après mesures : 4 + 3 + 3 + 4 + 3 + 2 = **19**. Baisse : (46 – 19) / 46 × 100 ≈ **58,7 %**. Ce chiffre aide à présenter le plan, mais il reste grossier : les cotations sont subjectives et l'on ne compense pas un risque critique par des risques faibles. Il faut aussi vérifier que les mesures sont **réellement appliquées**.

Cas guidé 9 : la fausse facture de compléments nutritionnels

Ce cas guidé mobilise la fraude au virement, la procédure de paiement et la réaction.

Document – La situation

La comptable d'un EHPAD (fictif) reçoit une facture de **3 960 €** à l'en-tête du fournisseur habituel de compléments nutritionnels oraux, pour « 96 cartons livrés en octobre ». Le RIB est différent de celui du dossier ; le message précise : « Merci de régler sous 48 h, notre banque a changé suite à une fusion. » La diététicienne, qui suit les commandes de compléments, n'a validé aucune livraison de ce volume.

Étape 1 – Repérer les signes

Réponse commentée – Étape 1

RIB **différent** du dossier ; explication toute prête (« fusion ») ; **urgence** (48 h) ; volume inhabituel ; **aucune commande** correspondante validée par la diététicienne. Prix unitaire affiché : 3 960 / 96 = **41,25 € par carton**, à comparer aux factures habituelles.

Étape 2 – Vérifier

Réponse commentée – Étape 2

- La comptable appelle le fournisseur au **numéro du dossier**, pas à celui de la facture.
- La diététicienne compare avec les **bons de commande** et les bons de livraison signés.
- Aucun paiement n'est fait avant ces deux vérifications.

Étape 3 – Réagir si la fraude est confirmée

Réponse commentée – Étape 3

Ne pas payer ; conserver le message et la pièce jointe ; prévenir la direction ; **porter plainte** ; signaler sur 17Cyber ; prévenir le vrai fournisseur, dont la messagerie a peut-être été piratée (l'attaquant connaissait l'EHPAD et le type de produit).

Étape 4 – Renforcer la procédure

Réponse commentée – Étape 4

Rapprochement systématique **commande, livraison, facture** (le rôle de la diététicienne dans la validation des commandes de compléments est précieux) ; changement de RIB seulement après rappel au numéro connu et confirmation écrite ; double signature au-dessus d'un seuil.

Cas guidé 10 : le déménagement d'un cabinet de diététique

Ce cas guidé mobilise la fin de vie du matériel, la continuité et la protection des dossiers pendant un transfert.

Document – La situation

Un cabinet de trois diététiciennes (fictif) déménage. Il laisse dans les anciens locaux : 3 ordinateurs anciens, une imprimante multifonction louée, 2 clés USB « de transfert », la box Internet. Les dossiers des patients sont dans un logiciel en ligne, mais une diététicienne garde aussi des fichiers de bilans sur son ordinateur. Le déménagement a lieu un vendredi ; les consultations reprennent le lundi.

Étape 1 – Faire l'inventaire des données

Réponse commentée – Étape 1

Les ordinateurs (fichiers de bilans, identifiants enregistrés), l'imprimante (disque interne avec les documents numérisés), les clés USB, la box (mot de passe Wi-Fi, réglages) : chacun peut contenir des données de patients ou des accès.

Étape 2 – Organiser le transfert

Réponse commentée – Étape 2

- Ranger les fichiers de bilans dans le **logiciel en ligne** (et non sur une clé) et vérifier qu'ils y sont complets.
- Faire une **sauvegarde** avant le déménagement et tester la restauration d'un fichier.
- Transporter les ordinateurs gardés **éteints**, chiffrés, sans les laisser seuls dans un véhicule.

Étape 3 – Effacer ce qui part

Réponse commentée – Étape 3

Effacement sûr (ou destruction du disque) des 3 ordinateurs et des 2 clés, avec attestation ; demande d'attestation d'effacement du disque de l'imprimante au loueur ; réinitialisation de la box et résiliation ; changement des mots de passe enregistrés sur les anciens postes.

Étape 4 – Préparer le lundi

Réponse commentée – Étape 4

Agenda du lundi et du mardi **imprimé** ou exporté au cas où la connexion ne serait pas prête ; nouveau Wi-Fi avec un réseau séparé pour les patients ; vérification que la messagerie sécurisée et le logiciel fonctionnent depuis les nouveaux locaux.

Cas guidé 11 : le vol d'une tablette pendant une visite à domicile

Ce cas guidé mobilise le chiffrement, l'analyse d'une violation et la décision de notifier.

Document – La situation

Une diététicienne d'un service d'hospitalisation à domicile (fictif) se fait voler sa tablette professionnelle dans sa voiture, pendant une visite, le jeudi à 15 h. Elle s'en aperçoit à 15 h 40 et prévient son cadre à 15 h 50. La tablette contient la liste des **27 patients** de sa tournée (nom, adresse, nutrition entérale ou parentérale, allergies). Deux hypothèses : A, la tablette est chiffrée et protégée par un code de 6 chiffres, avec effacement après 10 essais ; B, elle n'est pas chiffrée et le code est « 0000 ».

Étape 1 – Agir tout de suite

Réponse commentée – Étape 1

Prévenir le cadre et le référent ; demander l'**effacement à distance** ; changer les mots de passe des comptes ouverts sur la tablette ; porter plainte ; noter les faits et les heures.

Étape 2 – Évaluer le risque dans chaque hypothèse

Réponse commentée – Étape 2

- **A** : les données sont chiffrées et la tablette s'efface après 10 essais faux. Les chances de deviner un code de 6 chiffres en 10 essais sont de 10 sur 1 000 000, soit 0,001 % : le risque pour les patients est **faible**.
- **B** : code trivial, données lisibles : adresses de personnes malades à domicile, souvent fragiles, et données de santé : risque **élevé**.

Étape 3 – Décider des déclarations

Réponse commentée – Étape 3

- Dans les deux cas : inscription au **registre** des violations, analyse avec le DPO.
- **A** : la notification à la CNIL peut ne pas être nécessaire si l'analyse confirme l'absence de risque ; on documente la décision.
- **B** : notification à la CNIL avant **dimanche 15 h 50** (72 heures après que le service en a eu connaissance) ; **information des 27 patients**, avec des conseils (méfiance face aux visites ou appels inhabituels).

Étape 4 – Prévenir la prochaine fois

Réponse commentée – Étape 4

Chiffrement et code solide sur tous les appareils, effacement à distance activé, liste de tournée limitée au nécessaire, jamais d'appareil laissé dans un véhicule.

Cas guidé 12 : choisir les mesures d'une maison de santé avec 3 000 €

Ce cas guidé mobilise le coût des mesures, leur effet et la décision sous contrainte de budget.

Document – La situation

Une maison de santé pluriprofessionnelle (fictive) dispose de **3 000 €** cette année pour la sécurité. Le prestataire a estimé la réduction de risque (en points) de chaque mesure (coûts fictifs) : M1 double authentification, 0 €, 6 points ; M2 sauvegarde externalisée avec copie déconnectée, 1 080 €, 9 points ; M3 réseau Wi-Fi séparé pour les patients, 450 €, 5 points ; M4 formation de toute l'équipe, 1 400 €, 7 points ; M5 remplacement de deux postes obsolètes, 1 500 €, 6 points ; M6 gestionnaire de mots de passe, 720 €, 4 points ; M7 exercice de crise, 500 €, 3 points.

Étape 1 – Calculer le coût d'un point

Réponse commentée – Étape 1

M3 : 450 / 5 = **90 €** ; M2 : 1 080 / 9 = **120 €** ; M7 : 500 / 3 ≈ **167 €** ; M6 : 720 / 4 = **180 €** ; M4 : 1 400 / 7 = **200 €** ; M5 : 1 500 / 6 = **250 €**. M1 ne coûte rien : on la retient d'emblée.

Étape 2 – Comparer des combinaisons

Réponse commentée – Étape 2

- M1 + M2 + M3 + M6 + M7 : 0 + 1 080 + 450 + 720 + 500 = **2 750 €** ; 6 + 9 + 5 + 4 + 3 = **27 points**.
- M1 + M2 + M3 + M4 : 0 + 1 080 + 450 + 1 400 = **2 930 €** ; 6 + 9 + 5 + 7 = **27 points**.
- M1 + M2 + M4 + M7 : 2 980 € ; 25 points.
- Aucune combinaison à 3 000 € ou moins ne dépasse 27 points (sur 40 au total pour 5 650 €).

Étape 3 – Décider

Réponse commentée – Étape 3

Les deux premières combinaisons donnent **le même effet**. La première coûte 180 € de moins ; la seconde comprend la **formation**, dont l'effet dure et qui rend les autres mesures efficaces (une équipe formée utilise mieux la double authentification et signale plus vite). On peut défendre l'une ou l'autre, à condition de **justifier** : ici, la seconde, avec le gestionnaire de mots de passe et l'exercice programmés l'année suivante. Le calcul aide à décider, il ne remplace pas le jugement.

Cas guidé 13 : un bilan envoyé à la mauvaise patiente

Ce cas guidé mobilise l'identification des patients, la messagerie, la violation de données et la notification à la CNIL.

Document – La situation

Un centre de santé (fictif) suit deux patientes nommées **Martine Leroy**, nées en 1958 et en 1961. Le **mardi 10 mars 2026 à 10 h 40**, la diététicienne envoie par courriel le bilan de la première (poids, IMC, diabète de type 2, traitement) à l'adresse de la seconde, choisie dans la liste de saisie automatique. À **16 h 05**, la destinataire appelle pour signaler l'erreur. Le centre envoie environ **1 600** courriers et courriels de résultats par an ; sur les deux dernières années, on a relevé **2 erreurs de destinataire pour 1 000 envois**.

Étape 1 – Qualifier l'événement

Réponse commentée – Étape 1

- C'est une **violation de données personnelles** : une atteinte à la **confidentialité** de données de santé, par erreur et non par malveillance.
- La prise de connaissance date de l'appel : **mardi 10 mars à 16 h 05**. Le délai de 72 heures pour une éventuelle notification à la CNIL court jusqu'au **vendredi 13 mars à 16 h 05**.

Étape 2 – Limiter les conséquences

Réponse commentée – Étape 2

- Demander poliment à la destinataire de **supprimer** le message et ses pièces jointes, et de le confirmer par écrit ; la remercier d'avoir signalé.
- Envoyer le bilan à la bonne patiente, par un canal vérifié.
- Prévenir le délégué à la protection des données (DPO) du centre et noter les faits, l'heure et les actions dans la main courante.

Étape 3 – Évaluer le risque et décider des déclarations

Réponse commentée – Étape 3

- Données de santé d'une personne, lues par une seule personne identifiée qui a coopéré : le risque est réel mais limité. Le DPO peut conclure à un **risque** (données de santé) et notifier la CNIL avant vendredi 16 h 05 ; dans tous les cas, l'événement est inscrit au **registre des violations**.
- Si le risque est jugé **élevé**, la patiente concernée doit aussi être informée. Ici, l'informer est de toute façon conseillé : c'est une question de confiance.

Étape 4 – Éviter que cela recommence

Réponse commentée – Étape 4

- Erreurs attendues par an au rythme actuel : 1 600 × 2 /

1 000 ≈ **3,2** erreurs.

- Mesures : vérifier l'**identité** avec plusieurs traits (nom de naissance, prénom, date de naissance) et l'identité nationale de santé (voir chapitre 20) avant tout envoi ; désactiver la saisie automatique des adresses ; utiliser la messagerie sécurisée de santé ou la messagerie de Mon espace santé, qui s'appuient sur des annuaires et des identifiants vérifiés ; prévoir un **délai d'envoi** de quelques minutes pour pouvoir annuler.
- Informer l'équipe au retour d'expérience, sans désigner de coupable : c'est un risque d'organisation.

Cas guidé 14 : un poste partagé en cuisine centrale

Ce cas guidé mobilise les comptes, la traçabilité, les gestes d'hygiène informatique et la sensibilisation.

Document – La situation

Dans une cuisine centrale (fictive) qui produit **3 100 repas** par jour, un seul ordinateur, près de la zone de production, sert aux 14 agents. Tous utilisent le compte « cuisine » ; le mot de passe est écrit sur une étiquette collée à l'écran. Sur ce poste, on imprime les fiches de fabrication, on enregistre les températures de refroidissement, on lit la messagerie du service et l'on consulte, en pause, des sites personnels. Un audit relève qu'une température de refroidissement a été **modifiée après coup** ; personne ne sait qui l'a fait.

Étape 1 – Repérer les risques

Réponse commentée – Étape 1

- **Compte partagé** : impossible de savoir qui a fait quoi ; la traçabilité des enregistrements d'hygiène perd sa valeur de preuve.
- **Mot de passe affiché** : toute personne de passage (livreur, prestataire) peut se connecter.
- **Navigation personnelle** sur le poste de production : risque de logiciel malveillant qui bloquerait l'impression des fiches et l'enregistrement des températures.
- **Messagerie** ouverte en permanence : n'importe qui peut lire ou envoyer un message au nom du service.

Étape 2 – Proposer des mesures adaptées à une cuisine

Réponse commentée – Étape 2

- Un **identifiant personnel** pour chaque agent, avec un badge ou un code court, car on travaille avec des gants et dans l'urgence.
- Un **verrouillage automatique** du poste après quelques minutes.
- Un poste réservé à la production, **sans navigation personnelle** ; un autre accès, en salle de pause, pour les usages personnels.
- Un logiciel qui **garde l'historique** des modifications (qui, quand, ancienne et nouvelle valeur) pour les enregistrements de températures.

Étape 3 – Accompagner le changement

Réponse commentée – Étape 3

- Expliquer le **pourquoi** en lien avec le métier : en cas de toxi-infection alimentaire collective, les enregistrements doivent prouver ce qui a été fait.
- Former en **quart d'heure** à la prise de poste, avec une démonstration ; afficher une consigne en pictogrammes pour les agents qui lisent difficilement.
- Faire le point après un mois avec la cheffe de cuisine : temps de connexion, oublis de déconnexion, difficultés.

Étape 4 – Répondre à une question du jury

Réponse commentée – Étape 4

- Question : « Des comptes personnels, n'est-ce pas trop lourd pour une cuisine ? »
- Réponse : « Le compte personnel protège aussi l'agent : il prouve ce qu'il a fait et ce qu'il n'a pas fait. On l'adapte au terrain avec un badge et un verrouillage court, pour ne pas ralentir la production. »

Cas guidé 15 : sécuriser son propre stage

Ce cas guidé applique le chapitre à l'étudiant lui-même, pendant le stage et la préparation de l'épreuve E5.

Document – La situation

Une étudiante de BTS fait un stage de huit semaines dans le service diététique d'une clinique (fictive). Pour son projet, elle suit **12 patients** en rééducation. Elle a pris l'habitude de photographier avec son téléphone personnel les fiches de suivi alimentaire, de les envoyer sur sa messagerie personnelle, puis de les copier sur une clé USB pour travailler chez elle. Son rapport, dans un service de stockage en ligne gratuit, cite les patients par leurs initiales, leur âge, leur chambre et leur pathologie.

Étape 1 – Repérer les risques

Réponse commentée – Étape 1

- Des **données de santé** quittent la clinique sans autorisation, sur trois supports non maîtrisés : téléphone, messagerie personnelle, clé USB.
- Les photos peuvent être **synchronisées** automatiquement dans un espace en ligne ; la clé USB peut être perdue.
- Initiales + âge + chambre + pathologie permettent souvent de **reconnaître** la personne : ce n'est pas anonyme.
- L'étudiante est tenue au **secret professionnel** comme l'équipe.

Étape 2 – Corriger les pratiques

Réponse commentée – Étape 2

- Demander à la tutrice ce qui peut sortir de la clinique et sous quelle forme ; ne rien photographier sans son accord.
- Recueillir sur place des données **réduites au nécessaire** et **pseudonymisées** : « Patient A, 70-79 ans, rééducation après fracture » ; la table de correspondance reste dans le service.
- Supprimer les photos du téléphone et de l'espace en ligne, puis vider la corbeille ; ne plus utiliser la messagerie personnelle pour ces données.
- Si une clé est nécessaire : clé fournie par la clinique ou clé **chiffrée**, sans aucune donnée directement identifiante.

Étape 3 – Que faire si la clé est perdue ?

Réponse commentée – Étape 3

- Prévenir **tout de suite** la tutrice : la clinique, responsable des données, évalue s'il y a violation et si elle doit la notifier à la CNIL dans les 72 heures.
- Indiquer précisément ce que contenait la clé et si elle était chiffrée : si elle l'était avec un mot de passe solide, les patients n'ont pas à être informés.
- Noter les faits (date, lieu, contenu). Cacher la perte serait une faute bien plus grave que la perte elle-même.

Étape 4 – Le présenter au jury

Réponse commentée – Étape 4

- Dans le dossier : une phrase de méthode : « Les données ont été recueillies avec l'accord de la tutrice, pseudonymisées dans le service et conservées sur un support chiffré ; elles seront supprimées après l'épreuve. »
- À l'oral : savoir expliquer la différence entre **anonymisation** (on ne peut plus retrouver la personne) et **pseudonymisation** (on peut la retrouver avec la table de correspondance, gardée dans le service).

Cas guidé 16 : l'arrivée d'une nouvelle diététicienne

Ce cas guidé mobilise les comptes, l'identification, la charte et la sensibilisation dès le premier jour.

Document – La situation

Un établissement de santé (fictif) recrute une diététicienne qui commence le **lundi 7 septembre**. Le vendredi précédent, on découvre que rien n'est prêt : pas de compte, pas de carte. La cadre propose de lui donner, « pour la première semaine », le compte de la diététicienne partie en juin, dont le mot de passe n'a jamais été changé.

Étape 1 – Analyser la proposition

Réponse commentée – Étape 1

- Le compte de la personne partie aurait dû être **désactivé** à son départ : c'est déjà un défaut.
- Si la nouvelle diététicienne l'utilise, tout ce qu'elle fera sera enregistré au nom d'une autre : la **traçabilité** des prescriptions et des modifications de régime est faussée.
- Le mot de passe est peut-être connu d'autres personnes : la **confidentialité** des dossiers n'est plus garantie.

Étape 2 – Préparer une arrivée correcte

Réponse commentée – Étape 2

- Créer un **compte personnel** avec les seuls droits nécessaires au poste ; commander la **carte CPS** ou activer l'**e-CPS** ; en attendant, un compte provisoire nominatif, créé par le service informatique.
- Désactiver tout de suite l'ancien compte et vérifier qu'il n'a pas été utilisé depuis juin.
- Inscrire l'arrivée dans une **liste de contrôle**, préparée par les ressources humaines et l'informatique quelques jours avant chaque embauche.

Étape 3 – Accueillir la personne

Réponse commentée – Étape 3

- Lui faire lire et signer la **charte informatique** ; lui présenter le référent sécurité et la fiche réflexe incident.
- Lui faire activer la **double authentification** et ranger ses mots de passe dans le gestionnaire de l'établissement.
- Lui proposer un module de formation en ligne gratuit (par exemple celui de l'ANSSI) dans le premier mois.

Étape 4 – Tirer une règle générale

Réponse commentée – Étape 4

- Arrivées et départs sont des **moments à risque** : l'oubli de désactiver un compte ou le prêt d'un compte sont des erreurs fréquentes.
- Une seule règle simple : « Un compte = une personne ; il naît à l'arrivée et meurt au départ. »

Cas guidé 17 : une consultation à distance qui tourne mal

Ce cas guidé mobilise la consultation à distance, la confidentialité et la réaction à un incident.

Document – La situation

Une diététicienne libérale (fictive) fait des consultations par vidéo. Pour gagner du temps, elle envoie à tous ses

patients le **même lien** permanent. Un jeudi, pendant la consultation de **M. D.**, suivi pour une anorexie, une autre patiente, en avance pour son rendez-vous, se connecte et entre dans la séance. Elle reconnaît M. D., qui est son voisin.

Étape 1 – Qualifier l'incident

Réponse commentée – Étape 1

- C'est une **violation de données de santé** : une atteinte à la confidentialité (une tierce personne a vu et entendu une partie de la consultation) et une atteinte au **secret professionnel**.
- La cause est un **réglage** de l'outil (un lien unique pour tous, sans salle d'attente), pas une attaque.

Étape 2 – Réagir dans l'heure

Réponse commentée – Étape 2

- Mettre fin à la séance commune, s'excuser auprès de M. D. et lui expliquer ce qui s'est passé ; lui proposer de reprendre la consultation par un nouveau lien.
- Rappeler à l'autre patiente que ce qu'elle a vu est confidentiel.
- Noter les faits, l'heure et les personnes concernées.

Étape 3 – Décider des déclarations

Réponse commentée – Étape 3

- Inscrire l'événement au **registre des violations**.
- Évaluer le risque : une donnée de santé sensible, connue d'une voisine. Le risque pour la vie privée de M. D. est **élevé** : il faut l'en informer (c'est déjà fait) et notifier la CNIL dans les **72 heures**.

Étape 4 – Corriger l'organisation

Réponse commentée – Étape 4

- Un **lien différent** pour chaque rendez-vous, envoyé au patient seul, et la **salle d'attente** activée : la diététicienne fait entrer elle-même chaque patient.
- Vérifier l'identité au début de chaque séance.
- Choisir un outil de vidéotransmission sécurisé, adapté aux soins à distance, et relire ses réglages après chaque mise à jour.

Cas guidé 18 : la fuite de données chez l'éditeur du logiciel de restauration scolaire

Ce cas guidé mobilise la responsabilité d'un prestataire, la notification et l'information des familles.

Document – La situation

Une commune (fictive) confie à un éditeur la gestion en ligne des inscriptions à la cantine de ses **4 écoles**. Le fichier compte **2 350** enfants, dont **212** avec un projet d'accueil individualisé (PAI) pour une allergie. Le **lundi 5 octobre à 14 h**, l'éditeur écrit au service de restauration : une intrusion a eu lieu neuf jours plus tôt ; les noms, classes, adresses des parents et la mention des allergies ont pu être copiés. La diététicienne de la cuisine centrale est associée à la cellule de crise.

Étape 1 – Répartir les rôles

Réponse commentée – Étape 1

- La **commune** décide pourquoi et comment les données sont utilisées : elle est **responsable du traitement**. C'est elle qui notifie la CNIL et informe les familles.
- L'**éditeur** traite les données pour la commune : il est **sous-traitant**. Il devait prévenir la commune dans les meilleurs délais après avoir découvert la violation, et l'aider à y faire face.
- La **diététicienne** apporte l'expertise métier : elle sait quelles données sont sensibles et quelles conséquences une erreur aurait pour les enfants allergiques.

Étape 2 – Calculer et fixer les délais

Réponse commentée – Étape 2

- Part des enfants dont une allergie a pu être révélée : 212 / 2 350 × 100 ≈ **9,0 %**.
- La commune a eu connaissance de la violation le lundi 5 octobre à 14 h : elle doit notifier la CNIL au plus tard le **jeudi 8 octobre à 14 h**, quitte à compléter ensuite.
- Les neuf jours écoulés avant l'alerte de l'éditeur seront examinés : le contrat prévoit-il un délai d'alerte ? A-t-il été respecté ?

Étape 3 – Évaluer le risque pour les enfants

Réponse commentée – Étape 3

- Une allergie est une **donnée de santé** ; il s'agit d'enfants ; les adresses permettent de les localiser : le risque est **élevé** pour les 212 familles concernées.
- Les familles doivent donc être **informées** directement, avec des mots simples : ce qui s'est passé, les données concernées, les conseils (se méfier de messages ou d'appels qui citeraient l'allergie de l'enfant pour obtenir de l'argent ou des informations), le contact de la commune.
- La diététicienne vérifie aussi que l'**intégrité** des listes d'allergies n'a pas été touchée : une liste modifiée pourrait conduire à servir un plat dangereux.

Étape 4 – Protéger la production et tirer les leçons

Réponse commentée – Étape 4

- Jusqu'à la vérification complète, la cuisine travaille avec la **liste papier des PAI** validée par les écoles et le médecin scolaire.
- La commune revoit le contrat : délai d'alerte de

l'éditeur, double authentification des comptes, chiffrement des données, audits.
- Retour d'expérience commun avec l'éditeur, les écoles et la cuisine, et mise à jour de la fiche réflexe.

Cas guidé 19 : des SMS frauduleux au nom d'un cabinet

Ce cas guidé mobilise l'usurpation d'identité, la communication avec les patients et la plainte.

Document – La situation

Une diététicienne libérale (fictive) suit **640** patients. Un mardi matin, trois d'entre eux l'appellent : ils ont reçu un SMS « Cabinet de diététique : votre rendez-vous de demain n'est pas réglé. Payez 25 € ici pour le confirmer », avec un lien. La diététicienne n'envoie jamais de SMS de paiement. Son logiciel de rendez-vous en ligne lui confirme qu'il n'a constaté aucune intrusion.

Étape 1 – Comprendre ce qui se passe

Réponse commentée – Étape 1

- C'est une **usurpation d'identité** du cabinet pour faire payer des patients : une forme d'hameçonnage par SMS.
- Deux hypothèses : les escrocs envoient des SMS au hasard en utilisant un nom de métier courant ; ou ils ont obtenu une **liste de patients** (fuite chez un prestataire, compte piraté). Trois appels sur 640 patients, soit environ 0,5 %, ne permettent pas encore de trancher.

Étape 2 – Protéger les patients

Réponse commentée – Étape 2

- Prévenir tous les patients par les **canaux habituels** (courriel déjà utilisé, message sur le site, affiche au cabinet, message du répondeur) : « Le cabinet ne demande jamais de paiement par SMS. Ne cliquez pas. Si vous avez payé, faites opposition auprès de votre banque. »
- Ne pas mettre de lien dans le message de prévention : il ressemblerait au message frauduleux.

Étape 3 – Signaler et porter plainte

Réponse commentée – Étape 3

- Demander aux patients de transférer le SMS au **33700**.
- Porter **plainte** pour usurpation d'identité et escroquerie, avec les copies des SMS ; s'appuyer sur **17Cyber** et *cybermalveillance.gouv.fr* pour les conseils.
- Demander au prestataire de rendez-vous de vérifier les connexions récentes et activer la **double authentification** sur le compte du cabinet.

Étape 4 – Décider pour la CNIL

Réponse commentée – Étape 4

- Si l'enquête montre que la liste des patients a fuité, c'est une **violation de données** : notification à la CNIL dans les 72 heures après en avoir eu connaissance, et information des patients si le risque est élevé.
- Si les SMS sont envoyés au hasard, il n'y a pas de violation, mais l'événement est noté dans la main courante.

Cas guidé 20 : les étiquettes scannées d'une cuisine centrale

Ce cas guidé relie la cybersécurité au plan de maîtrise sanitaire : un enregistrement d'hygiène perdu ou modifié ne prouve plus rien.

Document – La situation

Une cuisine centrale (fictive) applique la possibilité, rappelée dans le cours du CNED sur la traçabilité, de **scanner** les étiquettes des matières premières pour les archiver sous forme informatique. Chaque jour ouvré, environ **180 étiquettes** sont scannées, à **0,4 Mo** chacune, et enregistrées sur le disque de l'ordinateur du bureau du chef. Il n'existe aucune autre copie. Un matin, le disque tombe en panne. Le même mois, un contrôle officiel est annoncé, et une famille signale des troubles digestifs après un repas servi trois semaines plus tôt.

Étape 1 – Mesurer ce qui est en jeu

Réponse commentée – Étape 1

- Volume par jour : 180 × 0,4 = **72 Mo**.
- Sur 26 semaines de 5 jours ouvrés (130 jours) : 180 × 130 = **23 400** étiquettes, soit 72 × 130 = 9 360 Mo, environ **9,4 Go**. C'est un petit volume : une sauvegarde complète coûte très peu.
- Sans ces étiquettes, la cuisine ne peut plus retrouver l'origine et les lots des produits servis le jour du repas signalé : la **traçabilité** est rompue.

Étape 2 – Relier l'incident aux objectifs de sécurité

Réponse commentée – Étape 2

- **Disponibilité** : les enregistrements sont perdus au moment où on en a besoin (contrôle officiel, enquête sur un repas).
- **Intégrité** : même sans panne, des fichiers sur un poste partagé peuvent être effacés ou remplacés sans trace ; un enregistrement modifiable par tous a peu de valeur de preuve.
- **Traçabilité** : on doit savoir qui a scanné, quand, et pouvoir montrer que rien n'a été changé ensuite.

Étape 3 – Réagir à la panne

Réponse commentée – Étape 3

- Ne pas manipuler le disque soi-même ; le confier au prestataire, qui tentera une **récupération**.
- Rassembler toutes les autres sources : bons de livraison, factures des fournisseurs, fiches de production, étiquettes papier encore présentes ; les fournisseurs peuvent aussi retrouver les lots livrés.
- Informer la direction ; noter les faits dans la main courante ; pour le contrôle, expliquer l'incident et les mesures prises plutôt que de le cacher.

Étape 4 – Construire une organisation fiable

Réponse commentée – Étape 4

- Enregistrer les scans sur un **espace réseau sauvegardé** selon la règle 3-2-1, et non sur le disque d'un poste.
- Nommer les fichiers de façon régulière (date, fournisseur, lot) pour les retrouver vite.
- Protéger les dossiers en **écriture** : seules les personnes habilitées ajoutent des fichiers ; personne ne les modifie ensuite ; l'historique est conservé.
- **Tester** une fois par trimestre la restauration des scans d'une journée choisie au hasard.
- Pendant une panne, revenir au **papier** : garder les étiquettes originales tant que la copie numérique n'est pas vérifiée.

Étape 5 – Préparer la question du jury

Réponse commentée – Étape 5

- Question : « La cybersécurité, c'est l'affaire de l'informaticien, pas de la diététicienne en restauration ? »
- Réponse : « La diététicienne est garante de la sécurité des repas. Si les enregistrements du plan de maîtrise sanitaire sont perdus ou modifiables, elle ne peut plus prouver que les repas étaient sûrs, ni retrouver un produit en cause. Elle participe donc à fixer les besoins : quoi garder, combien de temps, et ce qu'on accepte de perdre. »

Point d'étape – Je teste mes acquis – Cas guidés 13 à 15

Répondez sans regarder le cours, puis corrigez-vous. Comptez 1 point par réponse juste.

1. À partir de quand court le délai de 72 heures en cas d'envoi au mauvais destinataire ?
2. Citez deux mesures qui réduisent les erreurs de destinataire.
3. Pourquoi un compte partagé en cuisine pose-t-il un problème d'hygiène alimentaire ?
4. Comment adapter l'identification au travail en cuisine ?
5. Quelle différence entre anonymisation et pseudonymisation ?
6. Qui décide de notifier la CNIL quand une stagiaire perd une clé USB ?
7. Initiales, âge, chambre et pathologie : est-ce anonyme ?

Corrigé – Point d'étape – Cas guidés 13 à 15

1. Au moment où la structure prend connaissance de l'erreur.
2. Vérifier l'identité avec plusieurs traits et l'identité nationale de santé ; désactiver la saisie automatique ; utiliser la messagerie sécurisée de santé ; prévoir un délai d'envoi.
3. On ne sait plus qui a enregistré ou modifié une température : la traçabilité perd sa valeur de preuve.
4. Badge ou code court, verrouillage automatique rapide.
5. L'anonymisation empêche de retrouver la personne ; la pseudonymisation le permet avec une table de correspondance.
6. La clinique, responsable des données, après évaluation (avec son DPO).
7. Non : ces éléments permettent souvent de reconnaître la personne.

Point d'étape – Je teste mes acquis – Prestataires, usurpation et vérifications

Répondez sans regarder le cours, puis corrigez-vous. Comptez 1 point par réponse juste.

1. Dans une adresse internet, quelle partie faut-il lire pour savoir à qui appartient le site ?
2. Le cadenas prouve-t-il qu'un site est honnête ?
3. Quelle mise à jour installer en premier ?
4. Une voix reconnue au téléphone suffit-elle à prouver l'identité ?
5. Qui est responsable du traitement quand un éditeur gère les inscriptions d'une commune ?
6. Que doit faire un sous-traitant qui découvre une violation ?
7. Pourquoi ne pas mettre de lien dans un message de prévention envoyé aux patients ?

Corrigé – Point d'étape – Prestataires, usurpation et vérifications

1. Le nom de domaine, juste avant le premier « / ».
2. Non : il montre seulement que la connexion est chiffrée.
3. Celle qui corrige une faille déjà exploitée par des attaquants, souvent celle du système d'exploitation.
4. Non : une voix peut être imitée ; on rappelle au numéro connu.
5. La commune.
6. Prévenir le responsable du traitement dans les meilleurs délais et l'aider.
7. Il ressemblerait au message frauduleux et brouillerait la règle « ne cliquez pas ».

21.7 L'essentiel à retenir

À retenir – Prévenir

- **Acteurs** : ANSSI, cybermalveillance.gouv.fr, CERT Santé (ANS), CNIL ; référentiels du numérique en santé (PGSSI-S, e-CPS).
- **Six gestes** : mots de passe longs et uniques, double authentification, mises à jour, sauvegardes, vigilance, usages séparés et écran verrouillé.
- **Sauvegardes 3-2-1** : 3 copies, 2 supports, 1 hors site ou hors ligne ; tester la restauration.

À retenir – Reconnaître et réagir

- **Menaces** : hameçonnage, rançongiciel, usurpation (fraude au président), faux support, ingénierie sociale.
- **Incident** : isoler sans éteindre, alerter, ne pas payer, signaler (CNIL 72 h, CERT Santé, cybermalveillance.gouv.fr), restaurer, porter plainte, tirer les leçons.

Synthèse : le chapitre en un tableau

Question · Réponse courte · Où revoir

Qui aide et qui contrôle ? — *Réponse courte :* ANSSI (guides), *cybermalveillance.gouv.fr* et 17Cyber (assistance), CERT Santé (structures de santé), CNIL (violations), police et gendarmerie (plainte) ; *Où revoir :* 21.3.1

Que protège-t-on ? — *Réponse courte :* Disponibilité, intégrité, confidentialité, avec traçabilité ; *Où revoir :* 21.3.1

Quels gestes au quotidien ? — *Réponse courte :* Mots de passe longs et uniques, double authentification, mises à jour, comptes nominatifs, verrouillage, chiffrement, vigilance, antivirus ; *Où revoir :* 21.3.2

Comment sauvegarder ? — *Réponse courte :* Règle 3-2-1, copie déconnectée, conservation suffisante, restauration testée ; *Où revoir :* 21.3.2

Quelles attaques ? — *Réponse courte :* Hameçonnage (courriel, SMS, appel, code QR), rançongiciel, fraude au virement, ingénierie sociale, attaque par un prestataire ; sans oublier erreurs et pannes ; *Où revoir :* 21.3.3

Que faire en cas d'incident ? — *Réponse courte :* Isoler sans éteindre, alerter, préserver (main courante), déclarer (CNIL 72 h, CERT Santé, plainte), rétablir, apprendre ; *Où revoir :* 21.3.4

Comment continuer ? — *Réponse courte :* Mode dégradé préparé : listes à jour, fiches réflexes, exercices ; *Où revoir :* 21.3.4

Comment faire progresser l'équipe ? — *Réponse courte :* Plan de sensibilisation, exercices encadrés, indicateurs, aucune sanction de l'erreur ; *Où revoir :* 21.3.4

Et hors des murs ? — *Réponse courte :* Matériel professionnel, connexion protégée, discrétion, objets connectés maîtrisés ; *Où revoir :* 21.4

Et dans une petite structure ? — *Réponse courte :* Référent, mesures gratuites d'abord, autodiagnostic, cotation simple des risques ; *Où revoir :* 21.4.3

Exercices de synthèse

Les exercices suivants mobilisent l'ensemble du chapitre. Faites-les sans regarder le cours, en temps limité (20 minutes chacun), puis comparez avec le corrigé.

À vous de jouer – Exercice d'application 21.78

La journée à corriger. Voici la journée (fictive) d'une diététicienne en clinique. 1) À 8 h 30, elle se connecte au logiciel avec le compte de sa collègue, absente, « pour finir ses bilans ». 2) À 10 h, elle reçoit un message du « service informatique » qui demande de confirmer son mot de passe ; elle le fait. 3) À 13 h, elle quitte son bureau pour déjeuner, session ouverte. 4) À 15 h, elle copie des bilans sur une clé USB personnelle pour travailler chez elle. 5) À 17 h, l'antivirus signale une menace ; elle le désactive « parce qu'il ralentit l'ordinateur ». Relevez les erreurs et proposez la bonne pratique pour chacune.

Corrigé

1. Compte d'une autre personne : **traçabilité** détruite ; elle utilise son propre compte et demande, si besoin, un accès temporaire à son nom. 2. **Hameçonnage** : un service informatique ne demande jamais un mot de passe ; elle change le sien tout de suite et prévient le vrai service. 3. **Verrouillage** oublié : elle verrouille sa session à chaque départ. 4. Clé **personnelle non chiffrée** : risque de perte ; elle travaille à distance avec l'accès sécurisé de la clinique, sans copie. 5. Antivirus **désactivé** : jamais ; elle signale la menace au référent.

À vous de jouer – Exercice d'application 21.79

Les délais à calculer. Une association découvre le mercredi à 17 h 20 que l'ordinateur portable de sa coordinatrice, volé la veille, n'était pas chiffré ; il contenait le fichier de 210 adhérents avec leurs allergies. Elle est assurée contre les cyberattaques. Calculez les heures limites et dites quelles démarches sont obligatoires ou conseillées.

Corrigé

La structure a **connaissance** de la violation (données lisibles) le mercredi à 17 h 20 : notification à la **CNIL** avant le **samedi à 17 h 20**, car des données de santé (allergies) de 210 personnes sont exposées. **Information des adhérents** : obligatoire, car le risque est élevé (ordinateur non chiffré). **Plainte** pour le vol : le plus tôt possible ; elle conditionne aussi les démarches auprès de l'assureur. Le vol d'un ordinateur est un vol matériel ; la règle de la plainte dans les 72 heures (loi du 24 janvier 2023) vise les atteintes aux systèmes d'information : on vérifie le contrat d'assurance. Inscription au **registre** des violations dans tous les cas.

À vous de jouer – Exercice d'application 21.80

Le calcul de sauvegarde. Un service saisit 24 fiches par jour ouvré, de 9 h à 17 h, chacune en 10 minutes. La sauvegarde a lieu chaque vendredi à 18 h sur un disque débranché ensuite. Une panne détruit le disque du serveur le mardi à 13 h. Calculez les fiches perdues et le temps de ressaisie, puis l'effet d'une sauvegarde quotidienne à 18 h.

Corrigé

24 fiches en 8 heures, soit 3 fiches par heure. **Sauvegarde hebdomadaire** : perte du lundi (24) et du mardi de 9 h à 13 h (4 × 3 = 12) : **36 fiches**, soit 36 × 10 = 360 minutes = **6 heures** de ressaisie. **Sauvegarde quotidienne** (lundi 18 h) : perte de **12 fiches**, soit **2 heures**. La perte est divisée par 3. Il faut aussi vérifier que la sauvegarde se restaure, et en garder une copie hors site.

À vous de jouer – Exercice d'application 21.81

Le message à analyser. « De : Mon espace santé <notification@monespace-sante-verif.com>. Objet : Action requise. Votre dossier médical sera supprimé sous 48 h faute de mise à jour de votre carte Vitale. Cliquez ici et saisissez vos coordonnées bancaires pour les frais de 2,90 €. » Un patient âgé vous montre ce message. Relevez quatre signes d'arnaque et donnez trois conseils.

Corrigé

Signes : adresse d'expéditeur qui imite le service sans être officielle ; **menace** et urgence (suppression sous 48 h) ; demande de **coordonnées bancaires** pour un service public gratuit ; lien à cliquer. **Conseils** : ne pas cliquer et supprimer le message ; si des coordonnées ont été données, appeler tout de suite la banque ; en cas de doute, se connecter soi-même au service officiel ou appeler l'Assurance maladie au numéro connu, et signaler sur 17Cyber ou *cybermalveillance.gouv.fr*.

À vous de jouer – Exercice d'application 21.82

Le plan d'une structure. Une cuisine centrale de 22 agents n'a ni référent, ni sauvegarde testée, ni procédure en cas de panne ; elle utilise un compte partagé et reçoit chaque semaine des faux messages de « fournisseurs ». Proposez un plan en cinq mesures classées par priorité, avec un indicateur pour chacune.

Corrigé

1. **Comptes nominatifs** et double authentification : indicateur : 0 compte partagé dans un mois. 2. **Sauvegarde** 3-2-1 avec copie déconnectée et test : indicateur : un test de restauration réussi chaque trimestre. 3. **Mode dégradé** : liste papier des régimes et fiche réflexe : indicateur : âge de la dernière liste (7 jours au plus). 4. **Procédure de paiement** (rappel au numéro connu, double validation) : indicateur : 100 % des changements de RIB vérifiés. 5. **Sensibilisation** (quart d'heure sécurité, désignation d'un référent) : indicateur : nombre de messages suspects signalés par trimestre.

À vous de jouer – Exercice d'application 21.83

L'entretien avec le jury. Le jury vous demande : « Dans votre projet, vous avez utilisé votre téléphone pour photographier les fiches d'inscription des participants. Qu'en pensez-vous avec le recul ? » Rédigez votre réponse (80 mots au plus).

Corrigé

« Avec le recul, c'était une erreur. Les fiches contenaient des données personnelles, parfois des allergies, et mon téléphone personnel se synchronise avec un stockage en ligne que la structure ne contrôle pas. J'aurais dû utiliser le poste de la structure ou une copie papier rangée sous clé. J'ai supprimé les photos et prévenu ma tutrice. J'en retiens qu'il faut prévoir les outils du projet dès le départ, en pensant à la sécurité des données. »

Point d'étape – Je teste mes acquis – Quinze vrai-faux sur le chapitre 21

Répondez par vrai ou faux, puis corrigez-vous. Comptez 1 point par réponse juste.

1. L'ANSSI a été créée en 2009.
2. Un mot de passe de 8 caractères très variés vaut mieux qu'une phrase de passe de 7 mots tirés au hasard.
3. Un mot de passe suivi d'une question secrète est une double authentification.
4. Une sauvegarde sur un disque toujours branché protège d'un rançongiciel.
5. Une sauvegarde différentielle copie ce qui a changé depuis la dernière sauvegarde complète.
6. Face à un message de rançon, il faut éteindre l'ordinateur immédiatement.
7. Le délai de 72 heures pour notifier la CNIL est suspendu pendant le week-end.
8. Le sous-traitant victime d'une attaque notifie lui-même la CNIL à la place de son client.
9. Un message sans faute d'orthographe peut être un hameçonnage.
10. Un changement de RIB annoncé depuis l'adresse habituelle d'un fournisseur peut être une fraude.
11. Le vol d'un ordinateur chiffré avec une clé non volée oblige toujours à informer chaque personne concernée.
12. Un exercice d'hameçonnage simulé peut servir à sanctionner les agents qui cliquent.
13. La loi du 24 janvier 2023 conditionne l'indemnisation par l'assurance d'une cyberattaque à une plainte dans les 72 heures.
14. Le disque d'un photocopieur multifonction peut

contenir des données de patients.

15. Une petite association n'est pas concernée par l'obligation de sécurité du RGPD.

Corrigé – Vrai-faux – Chapitre 21

1. **Vrai** : décret du 7 juillet 2009.
2. **Faux** : la phrase de passe de 7 mots offre beaucoup plus de combinaisons.
3. **Faux** : ce sont deux facteurs de la même catégorie (ce que je sais).
4. **Faux** : le rançongiciel chiffre aussi ce qui est accessible.
5. **Vrai**.
6. **Faux** : on débranche du réseau sans éteindre, pour préserver les traces.
7. **Faux** : ce sont des heures calendaires.
8. **Faux** : il informe son client, responsable du traitement, qui notifie.
9. **Vrai** : les outils de génération de texte écrivent sans faute.
10. **Vrai** : la messagerie du fournisseur peut être piratée.
11. **Faux** : si les données sont inintelligibles, l'information des personnes n'est pas exigée (article 34 du RGPD) ; on documente l'analyse.
12. **Faux** : il sert à apprendre ; les résultats sont anonymes.
13. **Vrai** : article L12-10-1 du code des assurances.
14. **Vrai**.
15. **Faux** : tout responsable du traitement doit assurer une sécurité adaptée au risque (article 32).

Méthode : répondre à une question de cybersécurité à l'épreuve E5

Au temps 1 de l'épreuve, le jury peut interroger le candidat sur la sécurité des données de son projet ; au temps 2, sur la sécurité d'un outil de communication ou d'inscription. Une méthode simple évite les réponses vagues.

Méthode pas à pas – Cinq temps pour répondre

1. Situer : quelles données (et pour quelles personnes), quels outils, qui y a accès.

2. Nommer le risque : objectif atteint (disponibilité, intégrité, confidentialité) et conséquence concrète pour les personnes.

3. Citer la règle avec sa date : RGPD (2016, article 32 ou 33), code de la santé publique (L1111-8), guide de l'ANSSI (2017), recommandation de la CNIL (2022).

4. Proposer la mesure : immédiate (que fais-je tout de suite ?) et durable (qu'est-ce qui empêche que cela recommence ?).

5. Reconnaître les limites : ce qui dépend d'autres acteurs (direction, prestataire, DPO), ce que l'on vérifierait.

Exemple – Une réponse en cinq temps

Question : « Vos fiches d'atelier étaient-elles protégées ? » Réponse : « Les fiches contenaient les noms et les allergies de 12 participants (**situer**). Une perte aurait exposé des données de santé et une erreur sur une allergie aurait pu provoquer une réaction (**risque**). Le RGPD, article 32, demande une sécurité adaptée (**règle**). Je les ai rangées dans l'espace partagé sauvegardé de la structure, avec un accès limité à ma tutrice et à moi, et elles ont été supprimées à la fin du cycle (**mesure**). La sauvegarde dépendait du prestataire : je n'ai pas pu vérifier un test de restauration (**limite**). »

Les chiffres et les délais à retenir

Repère · Valeur · Source

Création de l'ANSSI — *Valeur :* 7 juillet 2009 ; *Source :* Décret n° 2009-834

Mesures du guide d'hygiène informatique — *Valeur :* 42 ; *Source :* ANSSI, 2017

Application du RGPD — *Valeur :* 25 mai 2018 ; *Source :* Règlement (UE) 2016/679

Notification d'une violation à la CNIL — *Valeur :* 72 heures après en avoir eu connaissance, si risque ; *Source :* RGPD, article 33

Plainte pour être indemnisé par l'assurance — *Valeur :* 72 heures après avoir eu connaissance de l'attaque ; *Source :* Loi n° 2023-22 du 24 janvier 2023, article L12-10-1 du code des assurances

Accès frauduleux à un système d'information — *Valeur :* Jusqu'à 3 ans d'emprisonnement et 100 000 € d'amende ; *Source :* Code pénal, article 323-1

Exemples de mots de passe suffisants utilisés seuls — *Valeur :* 12 caractères de 4 types, ou phrase de passe d'au moins 7 mots ; *Source :* CNIL, délibération n° 2022-100 du 21 juillet 2022

Directive NIS 2 — *Valeur :* 14 décembre 2022 ; transposition attendue avant le 17 octobre 2024, non achevée en France au 26 octobre 2026 ; *Source :* Directive (UE) 2022/2555

Programme CaRE — *Valeur :* Présenté en décembre 2023 ; quatre axes ; *Source :* Ministère chargé de la santé

17Cyber — *Valeur :* Ouvert le 17 décembre 2024 ; *Source :* Ministère de l'intérieur, *cybermalveillance.gouv.fr*

Règle des sauvegardes — *Valeur :* 3 copies, 2 supports, 1 hors ligne ou hors site ; *Source :* Recommandation courante (ANSSI, *cybermalveillance.gouv.fr*)

Droit de rétractation après un achat à distance — *Valeur :* 14 jours ; *Source :* Code de la consommation, article L221-18

Les erreurs fréquentes dans les copies et à l'oral

Erreur · Ce qu'il faut dire

« On a changé les mots de passe tous les mois, c'est sécurisé. » — *Ce qu'il faut dire :* Un mot de passe long, unique et protégé par une double authentification vaut mieux qu'un changement fréquent ; on le change en cas de doute

« La sauvegarde est sur un disque branché au serveur. » — *Ce qu'il faut dire :* Elle doit avoir une copie déconnectée ou hors site, et être testée

« Il faut éteindre l'ordinateur infecté. » — *Ce qu'il faut dire :* On le débranche du réseau sans l'éteindre

« Le prestataire a été piraté, ce n'est pas notre problème. » — *Ce qu'il faut dire :* La structure, responsable du traitement, notifie et informe ; le contrat doit encadrer le sous-traitant

« On notifie la CNIL pour toute violation. » — *Ce qu'il faut dire :* Seulement si la violation présente un risque ; toute violation est inscrite au registre

« La personne qui a cliqué sera sanctionnée. » — *Ce qu'il faut dire :* On encourage le signalement ; on corrige les causes

« Notre association est trop petite pour être attaquée. » — *Ce qu'il faut dire :* Les attaques sont souvent automatiques et visent les structures mal protégées

« Le message avait des fautes, donc c'était facile à voir. » — *Ce qu'il faut dire :* Les messages piégés peuvent être parfaits ; c'est la demande inhabituelle qui doit alerter

Citer un texte sans date ou une obligation non vérifiée (NIS 2) — *Ce qu'il faut dire :* Dater chaque source et vérifier l'état d'un texte en cours de transposition

Relier le chapitre aux autres compétences

Chapitre · Lien avec la cybersécurité

Chapitre 7 à 9 (démarche de projet) — *Lien avec la cybersécurité :* La sécurité des données fait partie de la conception du projet, de son plan d'action et de son évaluation (indicateurs de sécurité, risques du projet)

Chapitre 10 à 13 (atelier culinaire) — *Lien avec la cybersécurité :* Fichier des inscrits et des allergies, photos, outils d'inscription en ligne ; liste papier de secours

Chapitre 14 et 15 (communication) — *Lien avec la cybersécurité :* Visioconférence sécurisée, messagerie, réseaux sociaux de la structure, identité numérique et e-réputation

Chapitre 18 (démarche d'étude) — *Lien avec la cybersécurité :* Questionnaires anonymes, stockage des réponses, pseudonymisation

Chapitre 19 (veille) — *Lien avec la cybersécurité :* Veille sur les menaces et les textes (NIS 2, recommandations de la CNIL)

Chapitre 20 (numérique en santé) — *Lien avec la cybersécurité :* RGPD, secret professionnel, hébergement des données de santé, services numériques, intelligence artificielle

Fiche réflexe à garder sur soi

À retenir – Ma fiche réflexe cybersécurité

Au quotidien : mon compte, ma session verrouillée ; mots de passe longs et uniques, double authentification ; mises à jour acceptées ; aucune clé inconnue ; je vérifie le destinataire.

Devant un message : urgence, menace, demande de mot de passe ou de paiement, lien ou pièce jointe inattendus ? Je ne clique pas, je vérifie par un autre canal, je signale.

Devant un paiement inhabituel : rappel au numéro connu, double validation, aucune exception.

En cas d'incident : je débranche du réseau sans éteindre, j'appelle le référent, je note les faits et l'heure, je ne paie pas. La structure déclare : CNIL (72 h si risque), CERT Santé, plainte.

Si l'outil tombe : le classeur du mode dégradé et la liste à jour.

Glossaire complémentaire

Terme · Définition

Authentification — *Définition :* Preuve de l'identité d'un utilisateur (mot de passe, carte, code, empreinte)

Chiffrement — *Définition :* Transformation des données qui les rend illisibles sans la clé

Culture juste — *Définition :* Organisation qui distingue erreur, prise de risque et acte délibéré, et encourage le signalement

Double extorsion — *Définition :* Chiffrement des données et menace de publier les données volées

Durée maximale d'interruption admissible — *Définition :* Temps pendant lequel une activité peut s'arrêter sans conséquence grave

EBIOS Risk Manager — *Définition :* Méthode d'analyse des risques publiée par l'ANSSI en 2018

Fin de support — *Définition :* Date après laquelle un logiciel ne reçoit plus de mises à jour de sécurité

Habilitation — *Définition :* Ensemble des droits d'une personne dans un système d'information

Main courante — *Définition :* Journal daté des faits, décisions et actions pendant un incident

Mode dégradé — *Définition :* Organisation qui permet de poursuivre une activité sans les outils habituels

Moindre privilège — *Définition :* Principe selon lequel chacun n'a que les accès nécessaires à son travail

Perte de données maximale admissible — *Définition :* Quantité de travail que l'on accepte de perdre, exprimée en temps

Plan de continuité d'activité — *Définition :* Organisation qui maintient les activités essentielles pendant un incident

Plan de reprise d'activité — *Définition :* Organisation qui rétablit les outils et les données après un incident

Réseau privé virtuel — *Définition :* Connexion chiffrée entre un appareil et le réseau de la structure

Sauvegarde incrémentale — *Définition :* Copie de ce qui a changé depuis la dernière sauvegarde

Système d'information — *Définition :* Personnes, procédures, outils et données qui traitent l'information d'une structure

Point d'étape – Je teste mes acquis – Les cas guidés

Répondez sans regarder le cours, puis corrigez-vous. Comptez 1 point par réponse juste.

1. Dans une cuisine hospitalière, quelle information est vitale en mode dégradé ?
2. Pourquoi la liste papier imprimée à 14 h ne suffit-elle pas un samedi matin ?
3. Une diététicienne libérale dont la messagerie est piratée doit-elle notifier la CNIL elle-même ?
4. Dans un projet au collège, pourquoi préférer un questionnaire anonyme ?
5. Pourquoi séparer le réseau des tablettes des familles de celui des postes de soins ?
6. Avec 45 agents, pourquoi l'intervalle de confiance d'un taux de clic est-il large ?
7. Quelle priorité absolue en cas de panne du logiciel d'une cuisine scolaire ?
8. Dans le vol d'une tablette chiffrée qui s'efface après 10 essais, le risque est-il élevé ?

Corrigé – Point d'étape – Les cas guidés

1. Les régimes, textures et allergies de chaque patient.
2. Elle ne contient pas les modifications faites depuis 14 h.
3. Oui : elle est responsable du traitement.
4. Pour ne collecter aucune donnée inutile sur des mineurs (minimisation), et pour des réponses plus sincères.
5. Une tablette compromise ne doit pas permettre d'atteindre les postes de soins.
6. Parce que l'effectif est petit : la marge dépend de la

racine de n.

7. La liste à jour des enfants avec un PAI.
8. Non : les données sont illisibles et le code a très peu de chances d'être trouvé.

Point d'étape – Je teste mes acquis – Bilan du chapitre 21

Notez-vous sur 10, sans regarder le cours.

1. Citez les cinq acteurs à contacter selon la situation (aide, contrôle, plainte).
2. Donnez la formule du nombre de combinaisons d'un mot de passe.
3. Énoncez la règle 3-2-1.
4. Citez les six étapes d'une attaque par rançongiciel.
5. Donnez les trois vérifications avant un paiement inhabituel.
6. Citez les étapes de la réaction à un incident.
7. Donnez deux délais de 72 heures et leur objet.
8. Citez trois conditions d'un exercice d'hameçonnage simulé.
9. Citez trois règles du travail à distance.
10. Donnez la formule du niveau de risque simple.

Corrigé – Bilan du chapitre 21

1. *cybermalveillance.gouv.fr* et 17Cyber (aide), CERT Santé (structures de santé), CNIL (violations), police ou gendarmerie (plainte), ANSSI (guides).
2. Nombre de caractères possibles puissance la longueur.
3. Trois copies, deux supports, une copie hors ligne ou hors site.
4. Entrée, installation, exploration, vol de données, chiffrement, chantage.
5. Ne pas se fier au message, rappeler au numéro connu, double validation.
6. Isoler, alerter, préserver, déclarer, rétablir, apprendre.
7. Notification à la CNIL (RGPD, article 33) ; plainte pour l'indemnisation par l'assurance (loi du 24 janvier 2023).
8. Information préalable, message non cruel, résultats anonymes sans sanction (et aucun mot de passe enregistré).
9. Matériel professionnel, connexion protégée, discrétion (ou verrouillage, chiffrement).
10. Vraisemblance × gravité.

21.8 Entraînement

21.8.1 QCM (une ou plusieurs bonnes réponses)

QCM 1 – Un bon mot de passe :

a) est long **b)** est utilisé pour tous ses comptes **c)** peut être une phrase de passe **d)** est conservé dans un gestionnaire de mots de passe

QCM 2 – Un rançongiciel :

a) chiffre les données **b)** exige une rançon **c)** est neutralisé en payant **d)** entre souvent par un hameçonnage

QCM 3 – La règle 3-2-1 prévoit :

a) 3 copies **b)** 2 supports différents **c)** 1 copie hors site ou hors ligne **d)** 1 sauvegarde par an

QCM 4 – Face à un ordinateur infecté, on :

a) l'éteint immédiatement **b)** le débranche du réseau **c)** alerte le référent **d)** paie la rançon si elle est faible

QCM 5 – Un courriel d'hameçonnage présente souvent :

a) une urgence **b)** une adresse d'expéditeur suspecte **c)** une demande d'identifiants **d)** une signature vérifiable

QCM 6 – cybermalveillance.gouv.fr :

a) aide les victimes **b)** propose des fiches de prévention **c)** est réservé aux hôpitaux **d)** met en relation avec des prestataires

QCM 7 – Le CERT Santé :

a) est opéré par l'Agence du numérique en santé **b)** accompagne les structures de santé en cas d'incident **c)** délivre les cartes Vitale **d)** reçoit des signalements d'incidents

Corrigé – Corrigé expliqué des QCM

1. a, c, d. 2. **a, b, d.** 3. **a, b, c.** 4. **b, c.** 5. **a, b, c.** 6. **a, b, d.** 7. **a, b, d.**

21.8.2 Exercices

À vous de jouer – Exercice 1 – Schéma à légender : les menaces

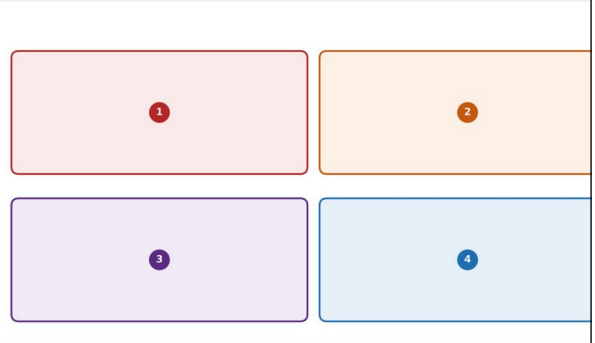


Figure 21.5 – Schéma à légender

Nommez les menaces 1 à 4.

Corrigé

1. Hameçonnage. 2. **Rançongiciel**. 3. **Usurpation d'identité**. 4. **Ingénierie sociale**.

À vous de jouer – Exercice 2 – Schéma à légender : l'hygiène numérique

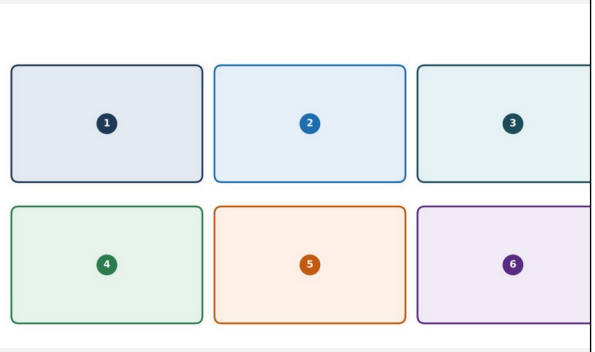


Figure 21.6 – Schéma à légender

Nommez les gestes 1 à 6.

Corrigé

1. Mots de passe. 2. **Double authentification**. 3. **Mises à jour**. 4. **Sauvegardes**. 5. **Vigilance**. 6. **Usages séparés, écran verrouillé**.

À vous de jouer – Exercice 3 – Schéma à légender : réagir

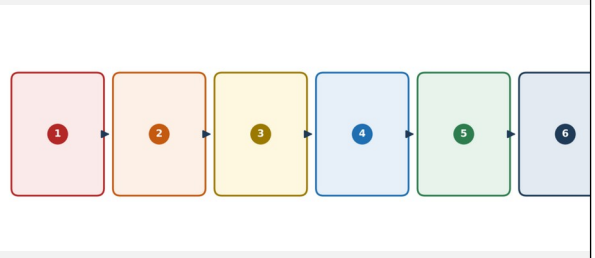


Figure 21.7 – Schéma à légender

Nommez les étapes 1 à 6.

Corrigé

1. Isoler. 2. **Alerter**. 3. **Préserver**. 4. **Signaler**. 5. **Restaurer**. 6. **Tirer les leçons**.

À vous de jouer – Exercice 4 – Schéma à légender : la règle 3-2-1

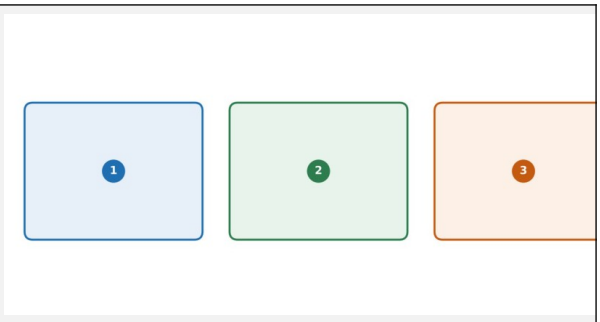


Figure 21.8 – Schéma à légender

Complétez les cases 1 à 3.

Corrigé

1. 3 copies. 2. **2 supports différents**. 3. **1 copie hors site ou hors ligne**.

21.8.3 Mises en situation express

Mise en situation – MSE 1

Le jury : « Comment avez-vous sécurisé les données de votre projet ? »

Corrigé

Tous les fichiers étaient dans l'espace partagé sauvegardé du centre, sur ma session personnelle protégée par une phrase de passe ; je n'ai rien stocké sur une clé personnelle et ma session a été supprimée à la fin du stage.

Mise en situation – MSE 2

Le jury : « Que feriez-vous si un message de rançon apparaissait sur l'ordinateur de l'accueil ? »

Corrigé

Je débrancherais l'ordinateur du réseau sans l'éteindre, j'alerterais immédiatement la directrice et le référent informatique, je ne paierais pas ; la structure signalerait l'incident et restaurerait les données à partir des sauvegardes.

21.9 Glossaire

Terme · Définition

ANSSI — *Définition :* Agence nationale de la sécurité des systèmes d'information

Authentification multifacteur — *Définition :* Vérification d'identité par au moins deux éléments (mot de passe et code, carte)

CERT Santé — *Définition :* Centre d'appui aux structures de santé pour les incidents de sécurité (ANS)

Chiffrement — *Définition :* Transformation de données pour les rendre illisibles sans clé

cybermalveillance.gouv.fr — *Définition :* Dispositif national d'assistance et de prévention

e-CPS — *Définition :* Carte de professionnel de santé sous forme d'application

Gestionnaire de mots de passe — *Définition :* Logiciel qui stocke et génère des mots de passe

Hameçonnage — *Définition :* Message frauduleux visant à voler des identifiants ou à faire cliquer

Ingénierie sociale — *Définition :* Manipulation d'une personne pour obtenir un accès ou une information

Phrase de passe — *Définition :* Mot de passe composé de plusieurs mots

PGSSI-S — *Définition :* Politique générale de sécurité des systèmes d'information de santé

Rançongiciel — *Définition :* Logiciel malveillant qui chiffre les données contre rançon

Règle 3-2-1 — *Définition :* 3 copies, 2 supports, 1 hors site ou hors ligne

Usurpation d'identité — *Définition :* Fait de se faire passer pour une autre personne ou organisation

21.10 Renvois bibliographiques par notion

Notion · Références
Hygiène informatique — *Références :* [1] ANSSI ; [2] ANSSI, mots de passe
Assistance, prévention — *Références :* [3] cybermalveillance.gouv.fr
Santé — *Références :* [4] ANS, CERT Santé ; [5] PGSSI-S
Données — *Références :* [6] CNIL ; [7] RGPD
Directive NIS 2 — *Références :* [8] Directive (UE) 2022/2555

21.12 Bibliographie numérotée

1. ANSSI. *Guide d'hygiène informatique : renforcer la sécurité de son système d'information en 42 mesures*. Paris, 2017.

2. ANSSI. *Recommandations relatives à l'authentification multifacteur et aux mots de passe. cyber.gouv.fr*.

3. GIP ACYMA. *cybermalveillance.gouv.fr* : fiches réflexes et fiches pratiques.

4. Agence du numérique en santé. *CERT Santé. esante.gouv.fr*.

5. Agence du numérique en santé. *Politique générale de sécurité des systèmes d'information de santé (PGSSI-S)*. *esante.gouv.fr*.

6. CNIL. *Guide de la sécurité des données personnelles. cnil.fr*.

7. Règlement (UE) 2016/679 (RGPD), articles 32 à 34.

8. Directive (UE) 2022/2555 du 14 décembre 2022 concernant des mesures destinées à assurer un niveau élevé commun de cybersécurité dans l'ensemble de l'Union (NIS 2).

Cours du CNED (contrôle de conformité, section 21.2.2)

9. CNED. *BTS Diététique – Environnement professionnel : les essentiels*, 2e année, module 1. Réf. 3-6124-AN-WT-00-21. Futuroscope : CNED, 2022.

10. CNED. *Hygiène et réglementation en restauration collective*, BTS Diététique 1re année, module 1 « Hygiène en restauration collective ». Futuroscope : CNED.